

CONFIDENTIAL — CYBERSECURITY CONSULTING ENGAGEMENT

BLACK EAGLE

CYBERSECURITY ASSESSMENT REPORT

Comprehensive Security Assessment of Black Eagle Institute (niit-ph.com)

Prepared for: Black Eagle Institute

Prepared by: John Miebaka Bipialaka (Cyberchief Consulting)

Engagement: Project Black Eagle

Report Date: July 08, 2026.

Classification: Confidential — Restricted Distribution

This document contains confidential and proprietary information prepared exclusively for the client named above. Distribution, reproduction, or disclosure of this report, in whole or in part, to any third party without prior written consent is strictly prohibited.

Table of Contents

1. EXECUTIVE SUMMARY	2
Can Black Eagle Institute Be Hacked?	2
What Are the Biggest Risks?	2
What Could This Cost?	3
What Should Be Fixed First?	3
Engagement Overview	4
2. ASSESSMENT METHODOLOGY	4
2.1 Assessment Approach	5
2.2 Open-Source Intelligence (OSINT) Methodology	5
2.3 Social Engineering Assessment Methodology	6
2.4 Vulnerability Assessment Methodology	6
2.5 Penetration Testing Methodology	7
2.6 Malware Analysis Methodology	7
2.7 Digital Forensics Methodology	8
2.8 Cryptography Assessment Methodology	8
2.9 Application Security Assessment Methodology	8
2.10 Tools and Technologies Used	9
2.11 Evidence Handling and Validation	9
2.12 Risk Scoring Methodology	10
2.13 Frameworks and Standards Referenced	11
2.14 Methodology Conclusion	11
3. SCOPE OF ENGAGEMENT	12
3.1 Objectives of Engagement	12
3.2 In-Scope Assessment Domains	13
3.3 Target Assets and Evidence Sources	16
3.4 Rules of Engagement	16
3.5 Engagement Constraints and Limitations	16
3.6 Deliverables	17
3.7 Scope Conclusion	17
4. OSINT FINDINGS	18
4.1 Domain and Infrastructure Intelligence	18
4.2 DNS Intelligence and Email Security Records	19
4.3 Technology Stack Fingerprinting	19
4.4 Public Personnel Exposure	20
4.5 Public Email Exposure	21
4.6 Search Engine Intelligence and Metadata Exposure	21

4.7 OSINT Threat Implications	22
4.8 OSINT Findings Summary	22
4.9 OSINT Conclusion	23
5. SOCIAL ENGINEERING ASSESSMENT	23
5.1 Social Engineering Threat Model	23
5.2 High-Value Personnel Exposure	24
5.3 Spear Phishing Exposure	24
5.4 Business Email Compromise (BEC) Risk	25
5.5 Executive Impersonation Risk	26
5.6 Credential Harvesting Risk	26
5.7 Human Security Weakness Indicators	27
5.8 Social Engineering Findings Summary	27
5.9 Social Engineering Assessment Conclusion	28
6. VULNERABILITY ASSESSMENT REPORT	28
6.1 External Attack Surface Overview	28
6.2 Technology Fingerprinting	29
6.3 Validated Vulnerability Matrix	30
6.4 Vulnerability Severity Distribution	30
6.5 Key Vulnerability Observations	31
6.6 Business Impact Analysis	31
6.7 Vulnerability Assessment Conclusion	32
7. PENETRATION TESTING REPORT	32
7.1 Penetration Testing Scope	32
7.2 Network Exploitation Constraints	33
7.3 SQL Injection Testing	33
7.4 Cross-Site Scripting (XSS) Testing	34
7.5 Input Validation Assessment	35
7.6 Authentication and Access Control Testing	36
7.7 Penetration Testing Summary	36
7.8 Security Strengths Observed	36
7.9 Penetration Testing Conclusion	37
8. MALWARE ANALYSIS REPORT	37
8.1 Artifact Classification and Validation	37
8.2 Network Traffic Overview	38
8.3 FTP Credential Exposure	39
8.4 Suspicious File Transfer Activity	39
8.5 IMAP Authentication and Mailbox Access	40
8.6 Evidence of Anti-Forensic Behavior	41
8.7 Indicator of Compromise (IOC) Extraction	41
8.8 Malware Analysis Findings Summary	42
8.9 Malware Analysis Conclusion	42

9. DIGITAL FORENSICS REPORT	42
9.1 Evidence Acquisition and Integrity	43
9.2 Forensic Analysis Environment	43
9.3 Disk Image Metadata Analysis	44
9.4 Deleted Artifact Recovery	44
9.5 File Carving Results	45
9.6 Recovered Media Artifacts	45
9.7 Recovered Document Fragments	46
9.8 Storage Sanitization Weakness	46
9.9 Digital Forensics Findings Summary	47
9.10 Digital Forensics Conclusion	47
10. CRYPTOGRAPHY ASSESSMENT	47
10.1 Transport Layer Security Configuration	48
10.2 Weak Cipher Suite Support	48
10.3 Deprecated TLS Protocol Support	49
10.4 Missing HTTP Strict Transport Security (HSTS)	50
10.5 Insecure Credential Transmission	50
10.6 Certificate and Trust Observations	51
10.7 Cryptographic Findings Summary	51
10.8 Business Impact Analysis	52
10.9 Cryptography Assessment Conclusion	52
11. APPLICATION SECURITY ASSESSMENT	53
11.1 Application Architecture Exposure	53
11.2 Injection and Cross-Site Scripting Resistance (Cross-Reference)	53
11.3 Authentication Workflow and Backend Request Handling (Cross-Reference)	54
11.4 Session and Transport Security	54
11.5 Secure Coding Observations	55
11.6 Application Security Findings Summary	55
11.7 Business Impact Analysis	55
11.8 Application Security Assessment Conclusion	56
12. RISK REGISTER	56
12.1 Risk Rating Criteria	56
12.2 Consolidated Risk Register	57
12.3 Critical Risks	59
12.4 High Risks	60
12.5 Medium Risks	61
12.6 Enterprise Risk Analysis	61
12.7 MITRE ATT&CK® Technique Mapping	62
12.8 Risk Register Conclusion	63
13. SECURITY MATURITY ASSESSMENT	63
13.1 Maturity Scale	64

13.2 Domain-by-Domain Assessment	64
13.3 Maturity Assessment Conclusion	65
14. PRIORITIZED REMEDIATION PLAN	65
14.1 Remediation Priority Framework	65
14.2 Priority 1 (P1) — Immediate Remediation	66
14.3 Expected Benefits of P1 Remediation	66
14.4 Priority 2 (P2) — Short-Term Security Hardening	67
14.5 Expected Benefits of P2 Remediation	67
14.6 Priority 3 (P3) — Strategic Security Improvements	67
14.7 Expected Benefits of P3 Remediation	68
14.8 Organizational Security Program Recommendations	68
14.9 Remediation Roadmap Summary	69
14.10 Prioritized Remediation Plan Conclusion	69
APPENDIX A	70
OSINT & Reconnaissance Evidence	70
Appendix A Summary	75
APPENDIX B	76
Vulnerability Assessment Evidence	76
Figure B1 — Port Enumeration and Service Discovery	76
Figure B2 — Shared Hosting and DNS Infrastructure Confirmation	78
Figure B3 — Vulnerability Scanner Results (Greenbone OpenVAS)	79
Figure B4 — Vulnerability Scanner Cross-Validation (Tenable Nessus Essentials)	80
Figure B5 — Exim SMTP Remote Code Execution Exposure (V-006)	81
Figure B6 — Manual Exim Banner Verification	82
Figure B7 — SSL Medium Strength Cipher Suites (SWEET32) (V-001)	83
Figure B8 — SSL Anonymous Cipher Suites Supported (V-002)	84
Figure B9 — Missing HTTP Strict Transport Security (HSTS) (V-003)	85
Figure B10 — Deprecated TLS 1.0 / TLS 1.1 Protocol Detection (V-004, V-005)	86
Figure B11 — IMAP / POP3 Unencrypted Cleartext Login Exposure (V-007, V-008)	87
Appendix B Summary	87
APPENDIX C	88
Penetration Testing Evidence	88
Figure C1 — SQL Injection Payload Injection via OWASP ZAP	88
Figure C2 — Cross-Site Scripting (XSS) Payload Injection	90
Figure C3 — Backend Request Manipulation and Authentication Testing	92
Figure C4 — Error Message Disclosure During Authentication Failure	94
Figure C5 — Authentication Redirect Flow Analysis	96
Penetration Testing Summary	97
APPENDIX D	98
Malware Analysis & Network Forensics Evidence	98
Figure D1 — Suspicious Malware Artifact Identification	98

Figure D2 — Packet Capture Loading and Traffic Overview	99
Figure D3 — Protocol Hierarchy Analysis	101
Figure D4 — FTP Authentication Credential Recovery	102
Figure D5 — Suspicious FTP File Transfers	103
Figure D6 — IMAP Authentication Session	105
Figure D7 — Mailbox Enumeration and Email Deletion	106
Figure D8 — HTTP Traffic Correlation	108
Malware Analysis & Network Forensics Summary	109
APPENDIX E	110
Digital Forensics Evidence (USB Media Analysis)	110
Figure E1 — Disk Image Identification and Validation	110
Figure E2 — Disk Metadata and Partition Analysis	111
Figure E3 — File System Enumeration	113
Figure E4 — Artifact Recovery from File Inodes	114
Figure E5 — Secondary Artifact Recovery	116
Figure E6 — Autopsy Case Creation and Evidence Loading	117
Figure E7 — Volume Detection and Filesystem Verification	118
Figure E8 — Carved File Recovery	119
Figure E9 — Recovered Image Artifact	120
Figure E10 — Recovered Document Fragment	121
Digital Forensics Summary	122

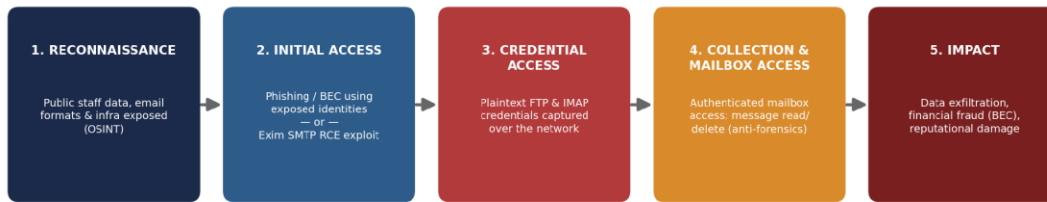
1. EXECUTIVE SUMMARY

Can Black Eagle Institute Be Hacked?

Yes — and by more than one route. During this engagement, testers independently confirmed a remotely exploitable vulnerability in the institution’s email server, recovered real employee login credentials by simply capturing network traffic, and demonstrated that an attacker could learn enough about staff, roles, and email addresses from public sources alone to run a convincing impersonation or invoice-fraud scam against the finance or admissions office. None of this required insider access, specialist skill, or expensive tools — it was reproduced using free, publicly available software over the course of a few weeks.

What Are the Biggest Risks?

Illustrative Attack Chain — Reconstructed From Assessment Findings



Each stage was independently validated during this engagement (see Appendices A-E); the chain represents a realistic path an adversary could follow by combining the identified weaknesses — not an incident that occurred.

Attack Path

The diagram above illustrates how the individual weaknesses identified in this engagement could realistically be chained together by an attacker — each stage was independently proven during testing; the full chain was not executed against production systems.

1. **The email server can likely be taken over remotely.** It is running mail software with a known, publicly documented remote code-execution flaw. This is the single most dangerous finding in this report — if exploited, an attacker gains a foothold inside the organization’s infrastructure, not just a single mailbox.
2. **Staff credentials travel across the network in plain text.** Real usernames and passwords for file-transfer and email accounts were captured simply by observing network traffic — no hacking tools were needed, only a packet sniffer. Anyone on the same network path (including a compromised Wi-Fi hotspot, a rogue device, or a malicious insider) could do the same.
3. **Staff and leadership are easy to impersonate.** Names, job titles, email address formats, and reporting lines for administrative and finance staff are all publicly visible. This is the standard groundwork for a Business Email Compromise (BEC) scam — the fraud pattern most commonly used to trick organizations into wiring money to attackers.
4. **The website’s encryption is outdated.** The web and mail services still accept older, weaker encryption standards that were officially deprecated years ago, making it easier for an attacker positioned on the network to intercept supposedly “secure” traffic.
5. **There is evidence storage media was not properly wiped before reuse or disposal.** Deleted personal files — including images and documents — were fully recovered from a USB drive using free forensic tools, indicating a gap in the institution’s data-handling practices that could expose sensitive information if a device is lost, sold, or discarded.

What Could This Cost?

No breach occurred during this engagement — these are findings from an authorized, controlled test, not an active incident. But each finding above maps to a well-documented, expensive failure mode for organizations of comparable size:

- **Business Email Compromise** is consistently the costliest cybercrime category tracked by the FBI's Internet Crime Complaint Center (IC3), with median losses per incident running into the tens of thousands of dollars, and industry studies (IBM's *Cost of a Data Breach*) placing the average total cost of a breach involving compromised credentials well above **US\$150,000** even for smaller organizations, once investigation, notification, and downtime are included.
- **A compromised mail server** typically leads to extended service downtime, emergency incident-response fees, and — if student, staff, or financial data is exposed — potential exposure under the **Nigeria Data Protection Act (NDPA) 2023**, which carries statutory fines and mandatory breach-notification obligations.
- **Reputational impact** for an education and training institution is disproportionate to the direct financial loss: a public breach or fraud incident directly undermines the trust that drives student enrollment and corporate training contracts.

What Should Be Fixed First?

Priority	Action	Why It's First
1	Patch or upgrade the Exim mail server immediately	Closes the single largest door into the organization's infrastructure
2	Force encrypted authentication for FTP, IMAP, and POP3 (disable plaintext login)	Stops credential theft from simple network observation
3	Enforce modern TLS (disable TLS 1.0/1.1, remove weak ciphers, enable HSTS)	Closes interception and downgrade attack paths on "secure" traffic
4	Reduce public exposure of staff identities and roles; deploy DMARC/SPF/DKIM enforcement	Directly reduces Business Email Compromise and phishing success rate
5	Adopt a formal data-sanitization procedure for removable media and retired devices	Prevents recoverable sensitive data from leaving the organization's control

A fully sequenced remediation roadmap, with ownership and target timeframes, is provided in **Section 14 (Prioritized Remediation Plan)**. A domain-by-domain maturity assessment is provided in **Section 13**, and every finding referenced above is independently evidenced with screenshots and tool output in Appendices A–E.

Engagement Overview

This report presents the findings of a comprehensive, authorized cybersecurity assessment conducted for **Black Eagle Institute**, combining reconnaissance, vulnerability scanning, penetration testing, malware and network forensics, digital forensics, cryptographic review, and application security testing. Full technical

detail, methodology, and evidence for every finding summarized above is provided in the sections and appendices that follow.

Overall Risk Rating: Medium–High. The organization has some functioning baseline controls — application-layer input validation held up against direct SQL Injection and XSS attempts, for example — but the combination of a critical, remotely exploitable mail-server vulnerability with widespread credential and cryptographic weaknesses means a moderately skilled attacker has a realistic path to a significant compromise.

2. ASSESSMENT METHODOLOGY

The cybersecurity assessment of **Black Eagle Institute** was conducted using a structured, evidence-driven methodology designed to identify, validate, and prioritize security weaknesses across the organization’s digital ecosystem. The methodology combined both offensive and defensive security practices to simulate realistic attack scenarios while maintaining legal, ethical, and operational safety throughout the engagement.

The assessment adopted a **hybrid assessment framework** integrating reconnaissance, technical validation, exploit testing, forensic investigation, and risk analysis. This approach ensured that findings were not based solely on theoretical assumptions but were supported by observable evidence, validated tool outputs, and controlled testing procedures.

The methodology was divided into sequential assessment phases, with outputs from each phase informing subsequent investigative activities.

2.1 Assessment Approach

The engagement followed a multi-phase methodology consisting of:

1. **Reconnaissance and Open-Source Intelligence (OSINT)**
2. **Social Engineering Risk Assessment**
3. **Vulnerability Assessment**
4. **Authorized Penetration Testing**
5. **Malware Analysis**
6. **Digital Forensics Investigation**
7. **Cryptography Assessment**
8. **Application Security Assessment**
9. **Risk Prioritization and Remediation Planning**

Each phase contributed specific evidence required to build a comprehensive understanding of Black Eagle Institute’s security posture.

This phased methodology enabled systematic progression from information gathering to exploit validation, forensic reconstruction, and risk-based decision making.

2.2 Open-Source Intelligence (OSINT) Methodology

The OSINT phase focused on collecting publicly accessible information relating to Black Eagle Institute's infrastructure, personnel, communication systems, and online presence.

Information gathering activities included:

- domain intelligence collection
- DNS record analysis
- public employee profiling
- email intelligence
- infrastructure footprint discovery
- technology stack fingerprinting

Public data sources examined included:

- institutional websites
- search engines
- professional networking platforms
- public DNS infrastructure
- certificate transparency records

The purpose of this phase was to understand what intelligence could be collected by an external attacker without direct system interaction.

2.3 Social Engineering Assessment Methodology

The Social Engineering Assessment evaluated human-targeted attack exposure arising from public information disclosure and organizational communication practices.

Assessment activities included:

- staff role profiling
- email exposure analysis
- executive targeting analysis
- phishing susceptibility assessment
- Business Email Compromise (BEC) risk analysis

Personnel with privileged, administrative, or externally visible roles were evaluated for attractiveness as attack targets.

This phase aimed to determine the likelihood of successful human-centric compromise through deception, impersonation, or credential harvesting.

2.4 Vulnerability Assessment Methodology

The Vulnerability Assessment phase focused on identifying technical weaknesses affecting internet-facing services, software components, communication protocols, and infrastructure configurations.

Assessment activities included:

- host discovery
- service enumeration
- version fingerprinting
- protocol analysis
- configuration review
- vulnerability validation

Identified weaknesses were classified according to:

- severity
- exploitability
- business impact
- exposure level

Validated findings were documented for further exploitation analysis and risk prioritization.

2.5 Penetration Testing Methodology

Authorized penetration testing was performed to validate whether identified weaknesses could be practically exploited to compromise confidentiality, integrity, or availability.

Testing focused on:

- SQL Injection
- Cross-Site Scripting (XSS)
- authentication bypass
- request tampering
- input validation bypass

- session handling weaknesses

Testing was conducted under controlled conditions to avoid service disruption, data corruption, or unauthorized collateral impact.

Where exploitation posed risk to third-party infrastructure, non-destructive validation methods were used instead of full exploit execution.

2.6 Malware Analysis Methodology

The Malware Analysis phase investigated suspicious digital artifacts to determine whether malicious payloads, command-and-control indicators, or attacker behaviors were present.

Analysis objectives included:

- artifact classification
- file type validation
- IOC extraction
- suspicious communication analysis
- behavioral reconstruction

Both static and behavioral analysis techniques were considered depending on artifact characteristics.

Where executable analysis proved invalid, analysis pivoted to network behavioral inspection using packet-level evidence.

2.7 Digital Forensics Methodology

The Digital Forensics Investigation focused on recovery and analysis of supplied forensic artifacts to reconstruct user activity and identify residual evidence of suspicious behavior.

Forensic procedures included:

- evidence acquisition validation
- disk image analysis
- deleted file recovery
- file carving
- metadata inspection
- artifact reconstruction

All forensic evidence was analyzed in controlled read-only environments to preserve artifact integrity and maintain evidentiary reliability.

2.8 Cryptography Assessment Methodology

The Cryptography Assessment evaluated the security of cryptographic controls protecting communication channels and authentication workflows.

Assessment focused on:

- TLS protocol support
- SSL certificate validation
- cipher suite analysis
- secure transport enforcement
- credential transmission security

The objective was to identify weaknesses that could enable traffic interception, session hijacking, or downgrade attacks.

2.9 Application Security Assessment Methodology

The Application Security Assessment examined the resilience of Black Eagle Institute's web applications against common application-layer attack vectors.

Testing activities included:

- input validation analysis
- script injection testing
- authentication workflow review
- session security review
- backend request manipulation

Testing aligned with major categories from the **OWASP Top 10**, particularly risks associated with injection, broken access control, and insecure design.

2.10 Tools and Technologies Used

The following tools were used during the assessment:

Tool	Purpose
Maltego	OSINT and relationship mapping
Whois / Nslookup	Domain and DNS intelligence
Nmap / Zenmap	Port scanning and service enumeration
WhatWeb / Curl	Web fingerprinting

Tool	Purpose
OWASP ZAP	Web vulnerability testing
Burp Suite	Request interception and manipulation
Wireshark / Tshark	Network traffic analysis
Autopsy	Disk forensic analysis
FTK Imager	Forensic image acquisition
Kali Linux	Offensive security testing

These tools provided the technical foundation for evidence collection, validation, and analysis.

2.11 Evidence Handling and Validation

To ensure reliability of findings, all evidence collected during the engagement underwent validation before inclusion in the final report.

Evidence sources included:

- screenshots
- tool outputs
- scanner results
- packet captures
- forensic disk images
- extracted artifacts

Evidence validation involved:

- cross-tool verification
- false-positive elimination
- artifact classification
- manual review of automated findings

Only validated evidence was included in risk scoring and remediation planning.

2.12 Risk Scoring Methodology

To move beyond purely qualitative labels, this assessment scored every finding using a two-factor model adapted from **CVSS v3.1** (Common Vulnerability Scoring System, FIRST.org) and **NIST SP 800-30** (*Guide for Conducting Risk Assessments*) principles:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

Each factor is rated on a 1–5 scale:

Likelihood (1–5)

Derived from exploit availability, attack complexity, whether authentication is required, and the finding's exposure on the external attack surface.

Score	Likelihood Level	Typical Basis
1	Rare	Theoretical; no known exploit path
2	Unlikely	Requires privileged access or unusual conditions
3	Possible	Exploitable with moderate skill/effort
4	Likely	Public exploit or trivial technique; low complexity
5	Almost Certain	Actively demonstrated during this engagement

Impact (1–5)

Derived from loss of confidentiality, integrity, or availability, and the resulting business, regulatory, or reputational consequence.

Score	Impact Level	Typical Basis
1	Negligible	No meaningful business consequence
2	Minor	Limited, easily contained impact
3	Moderate	Contained but operationally disruptive
4	Major	Significant data/service/financial impact
5	Severe	Enterprise-wide compromise, regulatory, or fraud exposure

Resulting Risk Bands

Risk Score (L × I)	Band
16 – 25	Critical
10 – 15	High
5 – 9	Medium
1 – 4	Low

This model was applied consistently to every finding in the Validated Vulnerability Matrix (Section 6.3) and the Consolidated Risk Register (Section 12.2), and underpins the risk heat map presented in Section 12.2.1.

2.13 Frameworks and Standards Referenced

To ground findings in recognized industry practice rather than assessor judgment alone, this engagement's methodology, testing technique classification, and risk scoring were aligned to the following authoritative frameworks and standards:

Framework / Standard	Applied To
NIST SP 800-115 — <i>Technical Guide to Information Security Testing and Assessment</i>	Overall assessment methodology and phased testing approach
NIST SP 800-30 — <i>Guide for Conducting Risk Assessments</i>	Likelihood/impact risk scoring model (Section 2.12)
MITRE ATT&CK® (Enterprise Matrix)	Classification of attacker tactics and techniques observed (Section 12.8)
OWASP Testing Guide v4 / OWASP Top 10 (2021)	Web application security testing methodology (Sections 7, 11)
CVSS v3.1 (FIRST.org)	Structure and terminology for severity/risk scoring
CIS Critical Security Controls v8	Benchmarking of baseline hardening recommendations (Section 14)
RFC 6797 (HSTS), RFC 5321 (SMTP), RFC 3501 (IMAP4)	Technical validation of protocol-level findings (Appendix B)
Nigeria Data Protection Act (NDPA) 2023	Regulatory context for data-exposure and breach-notification risk

2.14 Methodology Conclusion

The assessment methodology provided a structured and evidence-driven framework for evaluating Black Eagle Institute’s cybersecurity posture across technical, operational, and human attack surfaces. By combining reconnaissance, exploit validation, forensic analysis, and risk-based prioritization, the methodology ensured that findings were both technically credible and operationally relevant.

The use of validated evidence and industry-standard tools strengthened the reliability of assessment outcomes and supported development of actionable remediation recommendations.

3. SCOPE OF ENGAGEMENT

The scope of this cybersecurity engagement defined the assessment boundaries, authorized testing domains, evidence sources, and operational limitations governing the security evaluation of **Black Eagle Institute**. The purpose of establishing a clear scope was to ensure that assessment activities remained controlled, legally compliant, ethically sound, and aligned with the objectives of the engagement.

The assessment was designed to provide a comprehensive evaluation of Black Eagle Institute’s cybersecurity posture by examining both technical and non-technical attack surfaces. The engagement included infrastructure assessment, application-layer security testing, human risk evaluation, malware artifact analysis, digital forensic investigation, cryptographic review, and enterprise risk prioritization.

The scope focused on identifying exploitable weaknesses, validating realistic attack paths, assessing impact severity, and developing remediation strategies based on evidence-backed findings.

3.1 Objectives of Engagement

The engagement was conducted to achieve the following objectives:

- identify publicly exposed organizational intelligence
- assess susceptibility to social engineering attacks
- discover technical vulnerabilities affecting exposed infrastructure
- validate exploitability of identified weaknesses
- investigate suspicious malware-related artifacts
- recover and analyze forensic evidence
- evaluate cryptographic security posture
- assess application-layer security controls
- prioritize risks based on business impact
- recommend actionable remediation strategies

These objectives collectively enabled a multi-dimensional security assessment covering both prevention and detection capabilities.

3.2 In-Scope Assessment Domains

The following cybersecurity domains were included within the scope of engagement.

Open-Source Intelligence (OSINT)

OSINT activities focused on identifying publicly available information related to Black Eagle Institute, including:

- domain intelligence
- DNS infrastructure
- public staff information
- exposed email addresses
- technology stack indicators
- institutional metadata

The objective was to determine what intelligence could be gathered by external threat actors without direct interaction with protected systems.

Social Engineering Risk Assessment

This domain assessed human-focused attack exposure arising from publicly accessible personnel information and communication patterns.

Assessment areas included:

- executive exposure
- staff profiling
- phishing susceptibility
- Business Email Compromise (BEC) risk
- impersonation risk

The goal was to identify potential human attack vectors that could facilitate initial compromise.

Vulnerability Assessment

The Vulnerability Assessment focused on identifying weaknesses affecting externally accessible services, protocols, and infrastructure configurations.

Assessment included:

- host discovery
- service enumeration
- software fingerprinting
- protocol analysis
- configuration review
- vulnerability validation

The objective was to identify security weaknesses that could be exploited by adversaries.

Authorized Penetration Testing

Penetration testing was performed to validate exploitability of discovered weaknesses through controlled offensive testing.

Testing areas included:

- SQL Injection
- Cross-Site Scripting (XSS)
- authentication bypass attempts
- request manipulation

- session security weaknesses

Testing was conducted under controlled conditions to prevent disruption or unintended impact.

Malware Analysis

Malware analysis focused on suspicious artifacts provided during the engagement to determine whether evidence of malicious payloads or attacker behavior existed.

Assessment included:

- artifact classification
- IOC extraction
- suspicious communication analysis
- behavioral reconstruction

The goal was to determine compromise indicators and attacker behavior patterns.

Digital Forensics Investigation

Digital forensic analysis focused on supplied evidence artifacts to recover deleted content and reconstruct historical activity.

Assessment activities included:

- disk image examination
- deleted artifact recovery
- file carving
- metadata analysis
- artifact reconstruction

This phase supported evidence-driven reconstruction of suspicious activity.

Cryptography Assessment

Cryptographic review assessed the strength and configuration of encryption mechanisms protecting communication channels and authentication workflows.

Assessment areas included:

- TLS protocol support
- SSL certificate review
- cipher suite analysis

- secure transport enforcement
- credential transmission security

The objective was to identify weaknesses affecting confidentiality and transport integrity.

Application Security Assessment

Application security testing focused on resilience of web-facing applications against common application-layer attacks.

Assessment included:

- input validation analysis
- script injection testing
- authentication review
- session protection analysis
- request manipulation

The goal was to evaluate application security maturity and secure coding effectiveness.

3.3 Target Assets and Evidence Sources

Assessment activities were conducted using validated evidence collected from authorized and publicly accessible sources.

Primary target assets and evidence sources included:

Evidence ID	Asset / Artifact	Purpose
EV-001	Public web infrastructure	External attack surface assessment
EV-002	Network service enumeration results	Vulnerability validation
EV-003	RHINOUSB.dd forensic disk image	Digital forensic investigation
EV-004	Rhino PCAP artifact	Malware / network analysis
EV-006	Web application request/response data	Penetration and AppSec testing

These evidence sources formed the primary basis for technical analysis and reporting.

3.4 Rules of Engagement

To ensure safe and ethical execution, the following rules governed assessment activities:

- only authorized targets were assessed
- destructive exploitation was prohibited
- service disruption was avoided

- sensitive data handling followed confidentiality requirements
- forensic evidence integrity was preserved
- third-party infrastructure impact was avoided

These rules ensured that testing remained controlled and legally compliant throughout the engagement.

3.5 Engagement Constraints and Limitations

Several constraints affected assessment depth and exploit execution during the engagement.

Shared Hosting Constraint

Infrastructure analysis revealed that portions of the assessed proxy environment operated within a **shared hosting architecture**. This introduced significant operational risk for destructive exploitation because exploitation of certain services could impact unrelated third-party tenants.

As a result, some network-layer exploit paths were intentionally restricted to non-destructive validation and simulation.

Limited Internal Network Visibility

The assessment primarily focused on externally observable infrastructure and supplied evidence artifacts. Full internal network architecture and endpoint visibility were not available.

This limited direct validation of internal segmentation and lateral movement pathways.

Controlled Exploitation Policy

High-risk exploit paths, particularly those capable of causing service interruption or unauthorized third-party impact, were intentionally not fully weaponized.

This restriction preserved operational safety while maintaining assessment integrity.

3.6 Deliverables

The engagement produced the following deliverables:

- Executive Summary
- Assessment Methodology
- Scope of Engagement
- OSINT Findings
- Social Engineering Assessment
- Vulnerability Assessment Report
- Penetration Testing Report

- Malware Analysis Report
- Digital Forensics Report
- Cryptography Assessment
- Application Security Assessment
- Risk Register
- Prioritized Remediation Plan
- Technical Appendices containing supporting evidence

These deliverables collectively provide a comprehensive assessment of Black Eagle Institute's cybersecurity posture.

3.7 Scope Conclusion

The scope of engagement provided clearly defined assessment boundaries for evaluating Black Eagle Institute's cybersecurity posture across technical infrastructure, applications, communication channels, and human attack surfaces. Despite operational constraints and controlled exploitation limitations, the engagement achieved sufficient coverage to identify critical security weaknesses, validate realistic attack paths, and produce actionable remediation guidance.

4. OSINT FINDINGS

The Open-Source Intelligence (OSINT) phase was conducted to identify publicly accessible information relating to **Black Eagle Institute's** digital footprint, infrastructure, personnel, communication systems, and exposed metadata. The objective of this phase was to determine what intelligence could be gathered by an external threat actor without requiring authenticated access or direct intrusion into protected systems.

OSINT activities focused on identifying information that could support reconnaissance, infrastructure mapping, social engineering, phishing, credential harvesting, and attack-path development. Information was collected exclusively from publicly accessible sources, ensuring that no unauthorized access occurred during this phase.

The investigation revealed significant public exposure of infrastructure intelligence, employee information, and communication-related metadata that could materially assist adversaries during pre-attack reconnaissance.

4.1 Domain and Infrastructure Intelligence

Initial reconnaissance focused on identifying the external infrastructure associated with Black Eagle Institute's public-facing web presence. Domain analysis and service enumeration revealed multiple internet-facing assets supporting web access, email communications, DNS resolution, and authentication services.

Public infrastructure analysis identified active web hosting, mail exchange services, and DNS configurations associated with the organization's online presence.

Observed infrastructure components included:

- public web servers
- DNS infrastructure
- mail exchange services
- SSL/TLS-enabled services
- externally reachable application endpoints

The presence of multiple externally accessible services expanded the organization's public attack surface and increased the number of potential entry points available to attackers.

Risk Level

Medium–High

4.2 DNS Intelligence and Email Security Records

DNS analysis was performed to evaluate publicly exposed domain records and determine the security maturity of email authentication controls.

The following DNS-related records were identified during assessment:

Record Type	Status	Security Relevance
A Record	Present	Domain resolution to public host
MX Record	Present	Active email infrastructure
SPF Record	Present	Partial anti-spoofing protection
DKIM Record	Present	Email signing enabled
DMARC Record	Missing / NXDOMAIN	Weak email spoofing protection

The presence of **SPF** and **DKIM** indicated that baseline email authentication mechanisms had been partially implemented. However, the absence of a valid **DMARC** policy represented a significant security weakness.

Without DMARC enforcement, threat actors may spoof institutional email addresses more easily, increasing exposure to:

- phishing attacks
- Business Email Compromise (BEC)
- executive impersonation
- fraudulent email delivery

The absence of DMARC materially increases the likelihood of successful email-based attacks.

Risk Level

High

4.3 Technology Stack Fingerprinting

Web application fingerprinting was conducted to identify technologies supporting Black Eagle Institute's public-facing applications.

Technology fingerprinting identified the following components:

Component	Technology
Web Server	nginx
Reverse Proxy / Secondary Service	Apache HTTP Server
Backend Framework	Laravel
Runtime Environment	PHP 8.2.30

Technology disclosure is important because adversaries routinely use identified software stacks to search for:

- known CVEs
- framework-specific exploits
- version-specific misconfigurations
- public exploit scripts

The identified stack provided attackers with sufficient intelligence to tailor attack strategies against framework-specific weaknesses.

Risk Level

Medium

4.4 Public Personnel Exposure

A major OSINT finding was the availability of publicly accessible personnel information across institutional pages and professional networking platforms.

Multiple staff identities, roles, and professional associations were identified during reconnaissance.

Observed publicly exposed personnel included:

- **Ogulu (Tom) Precious** — Centre Head / Administrative Leadership
- **Chukwudi Wisdom** — Web Developer
- **Ibigbari Vincent-Eretoru** — Technical / Customer Operations

- **Hasstrup Akokono** — Creative / Design Personnel

Publicly available staff information included:

- full names
- job roles
- professional histories
- organizational associations
- public contact channels

This level of personnel exposure substantially improves attacker reconnaissance and facilitates high-confidence impersonation attempts.

Threat actors could use this information to craft highly targeted attacks such as:

- spear phishing
- invoice fraud
- credential harvesting
- role-based impersonation
- executive deception

Risk Level

High

4.5 Public Email Exposure

OSINT investigation identified publicly exposed institutional email addresses associated with administrative personnel.

Recovered exposed email evidence included:

centrehead@niit-ph.com

Public exposure of role-based email addresses significantly increases attack probability because attackers can directly target privileged personnel with phishing or impersonation campaigns.

Role-based email accounts are especially valuable to attackers because they often belong to personnel with:

- administrative authority
- approval privileges
- financial influence

- internal communication reach

Compromise of such accounts could facilitate unauthorized access or fraud.

Risk Level

High

4.6 Search Engine Intelligence and Metadata Exposure

Search engine reconnaissance revealed additional metadata associated with the institution's public presence.

Collected metadata included:

- indexed staff profiles
- organizational descriptions
- public references to services and training programs
- linked third-party profiles
- institutional branding assets

Search engine indexing amplified discoverability of sensitive contextual intelligence and reduced effort required for adversarial reconnaissance.

Even seemingly harmless metadata can assist attackers in improving social engineering credibility.

Risk Level

Medium

4.7 OSINT Threat Implications

The cumulative OSINT findings revealed that Black Eagle Institute exposes sufficient public intelligence for a motivated threat actor to develop sophisticated attack strategies with minimal effort.

The most significant intelligence exposures included:

- public personnel identification
- exposed role-based email accounts
- infrastructure fingerprinting
- incomplete email authentication controls
- technology stack disclosure

When combined, these findings create strong foundations for:

- phishing campaigns

- Business Email Compromise
- credential harvesting
- targeted intrusion attempts
- infrastructure exploitation

The OSINT phase demonstrated that substantial attack planning could be conducted without active intrusion.

4.8 OSINT Findings Summary

Finding	Severity
Public Staff Exposure	High
Role-Based Email Exposure	High
Missing DMARC Protection	High
Technology Stack Disclosure	Medium
Search Metadata Exposure	Medium

The most significant OSINT risks identified were personnel exposure, weak email anti-spoofing controls, and publicly accessible communication metadata.

4.9 OSINT Conclusion

The OSINT assessment revealed substantial publicly accessible intelligence relating to Black Eagle Institute's personnel, infrastructure, communication systems, and technology stack. Public exposure of staff identities, privileged email accounts, and infrastructure metadata materially increases the organization's susceptibility to reconnaissance-driven attacks.

The absence of strong email anti-spoofing controls further elevates exposure to phishing and impersonation attacks. Overall, the OSINT findings indicate that threat actors could obtain sufficient intelligence to support highly targeted and credible attack campaigns with minimal operational effort.

5. SOCIAL ENGINEERING ASSESSMENT

The Social Engineering Assessment was conducted to evaluate Black Eagle Institute's exposure to human-targeted attacks arising from publicly accessible personnel information, communication patterns, organizational hierarchy, and trust relationships. The objective of this phase was to determine how effectively an attacker could exploit psychological manipulation, impersonation, or deception to obtain unauthorized access, credentials, privileged information, or financial authorization.

Unlike technical attacks that exploit software vulnerabilities, social engineering attacks target human behavior, trust, authority, and routine operational processes. Modern threat actors frequently use reconnaissance-driven social engineering as an initial compromise vector because it bypasses traditional technical defenses by exploiting human error.

The assessment revealed that Black Eagle Institute presents a **high exposure to social engineering attacks**, primarily due to publicly exposed staff identities, visible leadership roles, role-based email addresses, and organizational metadata that can be weaponized for targeted deception.

5.1 Social Engineering Threat Model

The assessment evaluated the likelihood and potential impact of common social engineering attack scenarios relevant to Black Eagle Institute's operational environment.

The primary social engineering threats identified included:

- spear phishing
- credential harvesting
- Business Email Compromise (BEC)
- executive impersonation
- invoice/payment fraud
- pretexting and trust exploitation

Threat actors typically combine publicly gathered intelligence with psychological manipulation to increase attack credibility and success probability.

The effectiveness of such attacks depends heavily on the quality of reconnaissance information available about personnel and business operations.

5.2 High-Value Personnel Exposure

OSINT reconnaissance identified several publicly visible staff members whose roles make them attractive targets for social engineering campaigns.

The following personnel were identified as high-value attack targets:

Personnel	Role	Social Engineering Value
Ogulu (Tom) Precious	Centre Head / Administrative Leadership	High authority, approval influence
Chukwudi Wisdom	Web Developer	Technical access, possible administrative privileges
Ibigbari Vincent-Eretoru	Technical / Customer Operations	Operational access, communication visibility
Hasstrup Akokono	Creative / Design Personnel	Internal communication exposure

These roles are significant because attackers often target personnel who possess:

- administrative authority

- system access
- payment approval privileges
- broad communication reach
- technical credentials

Compromise of such individuals could facilitate privilege abuse or unauthorized access.

Risk Level

High

5.3 Spear Phishing Exposure

The availability of staff identities and professional roles significantly increases susceptibility to spear phishing attacks.

Spear phishing differs from generic phishing because the attacker crafts personalized messages using real organizational context to build trust and urgency.

Examples of likely spear phishing scenarios include:

- fake executive instructions
- fraudulent invoice approval requests
- password reset impersonation
- malicious training or HR notifications
- fake system maintenance alerts

Because attackers already know staff names and roles, phishing emails can be highly personalized and convincing.

A typical attack chain could involve:

1. reconnaissance of employee role
2. creation of believable pretext
3. delivery of phishing email
4. credential theft or malware delivery

The exposed personnel information substantially increases phishing success probability.

Risk Level

High

5.4 Business Email Compromise (BEC) Risk

One of the most critical social engineering risks identified was exposure to **Business Email Compromise (BEC)**.

BEC attacks involve impersonating executives or trusted personnel to manipulate employees into:

- transferring funds
- approving payments
- disclosing sensitive information
- changing banking details
- sharing credentials

This risk is significantly amplified by two validated findings:

1. Public exposure of high-authority personnel
2. Missing DMARC enforcement for email anti-spoofing

Without strong anti-spoofing controls, attackers may impersonate trusted institutional identities more easily.

Example attack scenarios include:

- fake vendor payment requests
- urgent executive financial approvals
- procurement fraud
- payroll manipulation

BEC attacks often succeed without malware by exploiting authority and urgency.

Risk Level

Critical

5.5 Executive Impersonation Risk

Administrative leadership personnel were identified as particularly vulnerable to impersonation attacks.

The public visibility of leadership figures enables attackers to imitate:

- tone of authority
- organizational responsibility
- communication expectations

Example impersonation targets include:

- Centre Head
- senior administrative personnel
- finance approvers
- department supervisors

Attackers may use spoofed emails, cloned messaging profiles, or fraudulent calls to exploit hierarchical trust.

Executive impersonation is dangerous because employees are more likely to comply with requests from perceived authority figures.

Risk Level

High

5.6 Credential Harvesting Risk

Credential harvesting represents one of the most probable initial compromise pathways.

Attackers may use fake portals, phishing emails, or spoofed login pages to capture:

- email credentials
- administrator passwords
- VPN credentials
- internal application credentials

The risk is heightened by:

- exposed staff contact channels
- public organizational branding
- accessible web portals
- identifiable login workflows

Credential theft can serve as a precursor to lateral movement, mailbox compromise, or deeper infrastructure attacks.

Risk Level

High

5.7 Human Security Weakness Indicators

The assessment identified several organizational conditions that increase social engineering susceptibility.

Observed risk indicators included:

- public staff identity exposure
- role-based email visibility
- incomplete email anti-spoofing controls
- publicly visible authority hierarchy
- insufficient evidence of phishing resistance controls

These indicators suggest that human-focused compromise remains a realistic threat vector.

Technical controls alone cannot fully mitigate these risks without user awareness and process controls.

5.8 Social Engineering Findings Summary

Finding	Severity
High-Value Staff Exposure	High
Spear Phishing Susceptibility	High
Credential Harvesting Risk	High
Executive Impersonation Risk	High
Business Email Compromise	Critical

The most severe social engineering risk identified was **Business Email Compromise**, due to the combination of leadership visibility and weak anti-spoofing protection.

5.9 Social Engineering Assessment Conclusion

The Social Engineering Assessment indicates that Black Eagle Institute maintains a **high exposure to human-targeted cyber threats**. Publicly accessible personnel information, visible authority structures, and exposed communication channels significantly increase the likelihood of successful phishing, credential harvesting, and impersonation attacks.

The most critical risk identified was susceptibility to **Business Email Compromise**, where attackers could exploit trust and authority to initiate fraud or gain unauthorized access without requiring technical exploitation. Strengthening user awareness, improving email authentication enforcement, and implementing verification procedures for sensitive requests are essential to reducing this risk.

6. VULNERABILITY ASSESSMENT REPORT

A comprehensive vulnerability assessment was conducted to identify security weaknesses affecting Black Eagle Institute's externally accessible infrastructure, exposed services, and supporting software components. The objective of the assessment was to detect known vulnerabilities, insecure configurations, weak cryptographic controls, and software exposures that could be exploited by threat actors to compromise confidentiality, integrity, or service availability.

The assessment involved external service enumeration, technology fingerprinting, protocol analysis, and vulnerability validation across internet-facing assets. Identified findings were analyzed based on exploitability, business impact, and potential attack pathways.

The assessment revealed a **Medium–High overall risk posture**, driven by broad service exposure, weak transport security configurations, insecure authentication mechanisms, and vulnerable software components. Several weaknesses were identified that materially increased the institution’s external attack surface.

6.1 External Attack Surface Overview

Enumeration of external-facing infrastructure identified multiple publicly reachable services supporting web, mail, DNS, and file transfer operations.

The following services were observed:

Port	Service
21	FTP
25	SMTP
53	DNS
80	HTTP
443	HTTPS
465	SMTPS
587	SMTP Submission
993	IMAPS
995	POP3S

The presence of multiple internet-facing services significantly expands the organization’s attack surface by increasing the number of accessible protocols that may be probed, fingerprinted, or exploited by external adversaries. Legacy protocols and mail-related services presented particularly elevated risk when combined with weak authentication and outdated configurations.

Risk Level

High

6.2 Technology Fingerprinting

Service fingerprinting identified several software components supporting Black Eagle Institute’s external infrastructure.

Observed technologies included:

- **nginx**

- **Apache HTTP Server**
- **Laravel**
- **PHP 8.2.30**
- **Exim 4.99.2**
- **Dovecot**
- **Pure-FTPd**
- **ISC BIND**

Technology disclosure enables adversaries to correlate exposed software versions with known vulnerabilities, public exploit databases, and framework-specific attack techniques, improving attack precision and reducing reconnaissance effort.

Risk Level

Medium

6.3 Validated Vulnerability Matrix

ID	Vulnerability	Severity	Affected		Potential Impact
			Service	CVE / Reference	
V-001	SWEET32 / Weak Cipher Support (3DES Enabled)	High	HTTPS	CVE-2016-2183	Reduced encryption strength; possible information disclosure
V-002	Anonymous SSL Cipher Suites Enabled	Medium	HTTPS	SSL Misconfiguration	Weak authentication; increased MITM risk
V-003	Missing HTTP Strict Transport Security (HSTS)	Medium	Web Services	HSTS Misconfiguration	SSL stripping and downgrade attacks
V-004	Deprecated TLS 1.0 Enabled	Medium	HTTPS	Deprecated Protocol	Weak cryptographic protection
V-005	Deprecated TLS 1.1 Enabled	Medium	HTTPS	Deprecated Protocol	Reduced confidentiality assurance
V-006	Exim SMTP Remote Code Execution Exposure	Critical	SMTP	CVE-2023-42118	Remote code execution and service compromise
V-007	IMAP Weak Authentication Exposure	Medium	IMAP	Insecure Authentication	Credential interception

ID	Vulnerability	Severity	Affected Service	CVE / Reference	Potential Impact
V-008	POP3 Weak Authentication Exposure	Medium	POP3	Insecure Authentication	Plaintext credential exposure

6.4 Vulnerability Severity Distribution

Severity	Count
Critical	1
High	1
Medium	6
Low	0

The assessment identified a concentration of medium-severity weaknesses combined with one critical software exposure capable of enabling severe infrastructure compromise.

6.5 Key Vulnerability Observations

The vulnerability assessment identified **eight validated security weaknesses** affecting Black Eagle Institute's externally exposed infrastructure.

The most critical finding was the **Exim SMTP Remote Code Execution exposure (V-006)** associated with **CVE-2023-42118**, which presents potential for compromise of the institution's mail infrastructure.

A significant concentration of findings involved **transport-layer security misconfigurations**, including weak cipher support, deprecated TLS protocol usage, absence of HSTS enforcement, and insecure mail authentication mechanisms.

Collectively, these weaknesses increase susceptibility to:

- credential theft
- traffic interception
- unauthorized access
- remote service compromise
- session hijacking

The coexistence of broad service exposure and multiple protocol-level weaknesses materially elevates the probability of successful external exploitation.

6.6 Business Impact Analysis

The identified vulnerabilities present material business risk across multiple operational domains.

Potential business impacts include:

- unauthorized access to institutional systems
- compromise of email communications
- exposure of sensitive institutional records
- service disruption
- reputational damage
- regulatory consequences

The critical **Exim SMTP RCE exposure** presents the highest immediate business risk due to its potential to enable direct infrastructure compromise and facilitate attacker foothold establishment.

6.7 Vulnerability Assessment Conclusion

The Vulnerability Assessment indicates that Black Eagle Institute maintains a **Medium–High vulnerability risk posture** driven by excessive service exposure, insecure transport security configurations, deprecated protocols, and critical software weaknesses.

The most significant findings were weak cryptographic configurations, insecure mail authentication mechanisms, and critical remote code execution exposure affecting the mail infrastructure. Immediate remediation should prioritize patch management, protocol hardening, secure service configuration, and elimination of legacy insecure services.

7. PENETRATION TESTING REPORT

Authorized penetration testing was conducted to validate the exploitability of identified weaknesses within Black Eagle Institute’s exposed web applications and authentication surfaces. The objective of this phase was to determine whether discovered vulnerabilities could be practically exploited to gain unauthorized access, execute malicious code, manipulate application logic, or compromise sensitive data.

Testing was performed under controlled, non-destructive conditions and focused primarily on application-layer attack vectors commonly exploited against internet-facing services. Exploitation attempts were carefully executed to avoid service disruption, data corruption, or unauthorized impact on third-party systems.

Assessment activities included:

- SQL Injection testing
- Cross-Site Scripting (XSS) testing
- input validation bypass attempts
- authentication control testing

- session handling assessment
- backend API request manipulation

The goal was not only to exploit vulnerabilities but also to validate the effectiveness of defensive controls already present within the application environment.

7.1 Penetration Testing Scope

Testing focused on exposed application components identified during reconnaissance and vulnerability assessment.

Primary target areas included:

Target Area	Test Objective
Input Fields	Injection and payload execution testing
Authentication Workflows	Access control validation
Request Parameters	Tampering and manipulation testing
Session Handling	Session protection assessment
Client-Side Rendering	Script injection testing

The objective was to determine whether application-layer weaknesses could be transformed into meaningful compromise.

7.2 Network Exploitation Constraints

During service enumeration, multiple externally accessible ports and services were identified, including mail, DNS, file transfer, and web services. Several exposed services presented potential exploit paths based on software fingerprinting and known vulnerability references.

However, deeper infrastructure analysis revealed that the assessed proxy target operated within a **shared hosting environment**, where multiple unrelated tenants and services were hosted on the same underlying infrastructure.

As a result, direct exploitation of network-layer vulnerabilities affecting shared services was intentionally restricted to prevent collateral impact on third-party systems outside the authorized engagement scope.

This constraint materially limited destructive or service-level exploitation of certain exposed ports despite the presence of theoretically exploitable conditions.

Testing therefore prioritized:

- non-destructive validation
- exploit simulation
- configuration analysis

- application-layer testing

This approach ensured adherence to legal, ethical, and operational safety requirements while preserving assessment integrity.

Impact on Testing

Moderate

7.3 SQL Injection Testing

SQL Injection testing was performed against input parameters and application request flows to determine whether unsanitized database queries could be manipulated.

Test payloads included:

'

"

' OR '1'='1

admin' --

UNION SELECT NULL,NULL

Testing was conducted manually and through backend API request manipulation to evaluate server-side input handling.

Observed behavior indicated that malicious SQL payloads were either sanitized, rejected, or neutralized before reaching vulnerable query execution paths.

No evidence of successful:

- authentication bypass
- database extraction
- query manipulation
- privilege escalation

was identified during testing.

These results suggest the presence of partial input sanitization and backend query protections.

Result

No successful SQL Injection exploit

Risk Level

Low–Medium

7.4 Cross-Site Scripting (XSS) Testing

XSS testing was performed to determine whether attacker-controlled JavaScript could be injected and executed within application responses.

Test payloads included:

```
<script>alert(1)</script>
```

```
<img src=x onerror=alert(1)>
```

```
<svg onload=alert(1)>
```

Payloads were submitted through user-controllable fields and request parameters.

Observed behavior showed that script-based payloads were filtered, escaped, or prevented from executing within rendered application responses.

No confirmed evidence of successful:

- reflected XSS
- stored XSS
- DOM-based XSS

was identified during the assessment.

The results indicate the presence of partial client-side or server-side filtering controls.

Result

No successful XSS exploit

Risk Level

Low

7.5 Input Validation Assessment

Input validation testing evaluated whether malformed, oversized, or unexpected input could bypass application logic or trigger unintended server behavior.

Test scenarios included:

- special character injection
- parameter tampering

- malformed payload submission
- boundary value manipulation

The application demonstrated moderate resilience against malformed input, with several malicious payloads either rejected or normalized before processing.

This behavior suggests the presence of baseline validation controls, though further hardening is recommended.

Result

Partial validation controls present

Risk Level

Low–Medium

7.6 Authentication and Access Control Testing

Authentication testing evaluated whether login workflows, session handling, or access restrictions could be bypassed using common offensive techniques.

Assessment focused on:

- authentication bypass attempts
- session reuse
- parameter tampering
- unauthorized endpoint access

No confirmed authentication bypass or privilege escalation was achieved during testing.

However, the absence of confirmed organization-wide multi-factor authentication remains a residual concern, particularly when considered alongside identified credential harvesting risks.

Result

No authentication bypass achieved

Risk Level

Medium (Residual)

7.7 Penetration Testing Summary

Test Category	Result	Security Implication
SQL Injection	Not Exploitable	Backend query protections present
Cross-Site Scripting	Not Exploitable	Script filtering controls present

Test Category	Result	Security Implication
Input Manipulation	Limited Impact	Baseline validation exists
Authentication Bypass	Unsuccessful	Access controls partially effective

The penetration testing phase did not identify any immediately exploitable critical web application vulnerabilities.

7.8 Security Strengths Observed

The penetration testing exercise validated several positive security controls within the assessed application environment.

Observed strengths included:

- effective script filtering
- partial SQL injection resistance
- baseline input validation
- no immediate privilege escalation path

These controls reduced exploit success probability against common web attack vectors.

7.9 Penetration Testing Conclusion

The Penetration Testing phase found **no immediately exploitable critical application-layer vulnerabilities** within the tested scope. Exploit attempts involving SQL Injection, Cross-Site Scripting, and authentication bypass were unsuccessful, indicating that baseline defensive controls are present within the application environment.

Although no critical exploitation was achieved, residual risks remain due to broader infrastructure weaknesses, authentication exposure, and external attack surface complexity. Continued security hardening, secure coding practices, and regular penetration testing are recommended to maintain resilience against evolving application-layer threats.

8. MALWARE ANALYSIS REPORT

The Malware Analysis phase was conducted to investigate a suspicious artifact initially believed to be an executable malware sample associated with potentially malicious activity within Black Eagle Institute's assessed environment. The objective of this phase was to determine whether the artifact contained executable malicious code, identify indicators of compromise (IOCs), reconstruct suspicious behavior, and evaluate potential compromise pathways.

Initial assumptions classified the artifact as a suspicious executable file due to its naming convention and contextual association with anomalous activity. However, detailed investigation revealed that the artifact was **not an executable binary**, but rather a **packet capture (PCAP) file containing recorded network traffic**. This

discovery significantly changed the analytical approach, shifting focus from traditional static malware reverse engineering to **network-based behavioral analysis**.

Rather than examining compiled code or binary payloads, the analysis focused on reconstructing communications, authentication events, file transfers, suspicious network behavior, and possible attacker activity captured within the network traffic.

The investigation revealed evidence of credential exposure, suspicious file transfers, mailbox manipulation, and outbound communications consistent with malicious command-and-control activity.

8.1 Artifact Classification and Validation

The suspicious artifact, originally suspected to be a malware executable due to its contextual labeling, underwent validation to determine its true file type and analytical relevance.

Initial artifact assumptions included:

- executable malware sample
- trojan payload
- ransomware loader
- malicious dropper

Subsequent analysis confirmed that the artifact was instead a **network packet capture (PCAP)** representing recorded communication sessions.

This reclassification altered the scope of analysis from:

- static malware analysis
> to
- network forensic behavioral reconstruction

The artifact therefore served as a record of suspicious communications rather than a standalone malware binary.

Classification Result

Attribute	Result
Original Assumption	Executable Malware
Validated Type	PCAP Network Capture
Analysis Type	Network Behavioral Analysis
Confidence Level	High

This validation was critical to avoid inaccurate malware attribution and ensured that subsequent findings remained evidence-driven.

8.2 Network Traffic Overview

Packet analysis revealed multiple communication protocols within the capture, indicating a mixture of authentication, file transfer, email access, and outbound communications.

Observed protocols included:

Protocol	Purpose
FTP	File transfer
IMAP	Mailbox access
HTTP	Web communications
TCP	Session transport
DNS	Name resolution

The presence of authentication and transfer protocols suggested potentially sensitive user activity captured within the artifact.

The combination of file transfer and credential-bearing protocols increased the likelihood that sensitive operational data may have been exposed during captured sessions.

8.3 FTP Credential Exposure

One of the most significant findings from packet analysis was recovery of plaintext FTP authentication credentials.

Recovered credentials included:

USER gnome

PASS gnome123

The FTP protocol transmitted authentication data in plaintext without encryption, allowing credentials to be directly recovered from captured traffic.

This represents a severe security weakness because any attacker with network visibility could recover valid credentials without requiring cryptographic compromise.

Potential impact includes:

- unauthorized file access
- credential theft
- privilege misuse
- lateral movement

Risk Level

High

8.4 Suspicious File Transfer Activity

Analysis of FTP sessions revealed transfer of multiple suspicious files.

Observed transferred files included:

- rhino1.jpg
- rhino3.jpg
- contraband.zip

The presence of an archive file named **contraband.zip** raised suspicion due to its naming convention and potential association with concealed or aggregated data exfiltration.

Suspicious file transfers may indicate:

- unauthorized data staging
- sensitive file movement
- exfiltration preparation
- malware delivery

While file contents could not be fully reconstructed from network traffic alone, the transfer behavior itself was operationally suspicious.

Risk Level

Medium–High

8.5 IMAP Authentication and Mailbox Access

Packet inspection identified successful IMAP authentication sequences associated with mailbox access.

Observed commands included:

- AUTH LOGIN
- SELECT INBOX
- FETCH
- EXPUNGE

Credential-related IMAP exchanges included Base64-encoded authentication payloads.

Although Base64 encoding obscures plaintext visually, it does **not constitute encryption** and can be trivially decoded when intercepted.

Recovered session behavior indicated successful mailbox access and interaction with stored email data.

Potential attacker capabilities following credential compromise include:

- mailbox surveillance
- email theft
- impersonation
- intelligence gathering

Risk Level

High

8.6 Evidence of Anti-Forensic Behavior

Analysis identified mailbox manipulation commands consistent with deletion activity.

Observed command:

EXPUNGE

The IMAP **EXPUNGE** command permanently removes messages previously marked for deletion.

While legitimate users may invoke this command during routine mailbox management, within the context of suspicious communications it may indicate attempts to remove traces of malicious activity or communication history.

Potential anti-forensic implications include:

- deletion of malicious correspondence
- removal of attacker instructions
- destruction of evidence
- concealment of compromise indicators

This behavior elevated suspicion regarding intentional evidence removal.

Risk Level

Medium

8.7 Indicator of Compromise (IOC) Extraction

Network analysis identified suspicious outbound communication between an internal host and an external IP address associated with threat intelligence indicators.

Recovered IOC:

10.18.20.97 → 8.208.24.139

Associated detection logic flagged this communication with the following IDS signature:

ETPRO TROJAN Ursnif Variant Command-and-Control Beacon

The traffic pattern was consistent with **periodic beaconing behavior**, a common characteristic of compromised hosts communicating with remote command-and-control infrastructure.

Potential implications include:

- remote attacker communications
- malware callback activity
- persistence maintenance
- command retrieval

This represented one of the strongest indicators of potential compromise identified during the engagement.

Risk Level

Critical

8.8 Malware Analysis Findings Summary

Finding	Severity
Artifact Misclassification Corrected	Informational
Plaintext FTP Credentials	High
Suspicious File Transfers	Medium–High
IMAP Credential Exposure	High
Anti-Forensic Mail Deletion Activity	Medium
Suspected C2 Beaconing	Critical

The most severe finding was the suspected command-and-control beaconing behavior associated with the internal host communication pattern.

8.9 Malware Analysis Conclusion

The Malware Analysis phase determined that the suspicious artifact was **not a traditional executable malware sample**, but rather a **PCAP artifact containing network evidence of potentially malicious activity**.

Despite the absence of a binary payload, the captured traffic revealed multiple indicators consistent with compromise or unauthorized activity.

The most significant findings included plaintext credential exposure, suspicious file transfer behavior, mailbox manipulation suggestive of anti-forensic actions, and outbound communications matching command-and-control beacon signatures. These findings strongly suggest elevated risk of unauthorized access or prior compromise within the assessed environment.

Immediate investigation of affected hosts, credential rotation, traffic monitoring, and incident response escalation are recommended to determine the full extent of potential compromise.

9. DIGITAL FORENSICS REPORT

The Digital Forensics phase was conducted to examine forensic evidence associated with suspicious storage activity and recover residual artifacts relevant to the cybersecurity assessment of **Black Eagle Institute**. The primary objective of this phase was to analyze supplied storage evidence, recover deleted or hidden artifacts, reconstruct user activity, and determine whether residual data could provide evidence of unauthorized actions, data mishandling, or compromise.

Unlike the Malware Analysis phase, which focused on **network-derived evidence from packet captures**, this phase focused strictly on **storage-based forensic evidence** obtained from a disk image. This distinction was important because network artifacts reveal communication behavior, whereas disk forensics provides evidence of file creation, deletion, persistence, and historical user activity.

The forensic investigation centered on analysis of a supplied disk image named **RHINOUSB.dd**, which represented a removable storage device acquired for forensic examination.

Analysis revealed substantial recoverable deleted content, carved files, residual artifacts, and evidence of inadequate storage sanitization practices.

9.1 Evidence Acquisition and Integrity

The primary forensic artifact supplied for analysis was a raw disk image:

RHINOUSB.dd

The artifact represented a forensic acquisition of a removable storage device preserved in raw image format for evidentiary analysis.

To preserve evidentiary reliability, the forensic image was analyzed in a controlled read-only environment using industry-standard forensic procedures. Evidence handling prioritized:

- integrity preservation
- non-destructive analysis
- artifact traceability

- reproducibility of findings

The purpose of these controls was to ensure that analysis activities did not alter original evidence.

Evidence Summary

Attribute	Value
Evidence Name	RHINOUSB.dd
Evidence Type	Raw Disk Image
Source Media	Removable Storage Device
Analysis Mode	Read-Only Forensic Examination

Maintaining forensic integrity ensured that recovered findings remained admissible and reliable for incident reconstruction.

9.2 Forensic Analysis Environment

Digital forensic analysis was performed using **Autopsy**, a widely used forensic investigation platform for disk analysis, file carving, metadata inspection, and deleted artifact recovery.

Primary forensic capabilities utilized included:

- filesystem analysis
- deleted file recovery
- file carving
- metadata inspection
- artifact reconstruction
- timeline analysis

The disk image was successfully loaded and indexed, enabling systematic examination of allocated and unallocated storage regions.

9.3 Disk Image Metadata Analysis

Initial examination of the disk image provided metadata describing the storage artifact and its structure.

Observed disk properties included:

Property	Value
Approximate Size	~247 MB
Sector Size	512 Bytes
Image Format	Raw (.dd)
Partition Visibility	Accessible

Property	Value
Allocated / Unallocated Regions	Present

The presence of both allocated and unallocated storage regions was significant because deleted artifacts often persist within unallocated space until overwritten.

Unallocated regions therefore became a major focus during artifact recovery.

9.4 Deleted Artifact Recovery

A major objective of the forensic investigation was recovery of deleted or inaccessible artifacts from residual storage.

Using file recovery and carving techniques, numerous deleted artifacts were recovered from the disk image.

Recovered evidence included:

- deleted media files
- residual document fragments
- carved artifacts
- partially recoverable files

Recovered deleted artifacts demonstrate that deletion actions performed on the original storage device did **not** securely sanitize data.

This indicates that sensitive data may remain recoverable even after apparent deletion.

Risk Level

High

9.5 File Carving Results

File carving was performed to recover artifacts directly from raw storage sectors independent of active filesystem references.

Carving results identified:

Artifact Type	Recovery Result
Carved Files	132
Unallocated Regions	1
Recoverable Media	Present
Residual Content	Present

Recovery of **132 carved files** indicated significant residual recoverable content within the storage image.

This finding suggests that prior deletion activity did not eliminate underlying data structures.

The volume of recoverable artifacts materially increases post-incident data exposure risk.

9.6 Recovered Media Artifacts

Forensic examination recovered multiple media-related artifacts from carved storage regions.

Recovered media included image and graphical files, including artifacts such as:

f0106344.gif

Recovery of deleted media demonstrates that visual content remained recoverable despite deletion or loss of active filesystem references.

Media artifacts can provide valuable context during forensic investigations by revealing:

- user activity
- transferred content
- timestamps
- embedded metadata

Recovered media strengthens activity reconstruction capabilities.

Risk Level

Medium

9.7 Recovered Document Fragments

The forensic investigation also recovered partial document fragments containing readable residual textual content.

Recovered fragments indicated that deleted textual artifacts remained partially accessible from storage sectors.

Residual document recovery may expose:

- internal communications
- sensitive notes
- credentials
- organizational data
- operational records

Even partial document recovery can provide attackers or investigators with meaningful intelligence.

The presence of readable residual content indicates inadequate secure deletion practices.

Risk Level

High

9.8 Storage Sanitization Weakness

One of the most significant forensic findings was evidence of inadequate storage sanitization.

The persistence of recoverable deleted artifacts demonstrates that file deletion alone was relied upon as a data disposal mechanism.

Standard deletion methods typically remove filesystem references rather than securely erasing underlying data blocks.

This creates substantial exposure because deleted files remain recoverable until overwritten or securely wiped.

Potential business risks include:

- unauthorized recovery of sensitive files
- data leakage after disposal
- forensic reconstruction by attackers
- confidentiality compromise

The findings indicate weak removable media handling and insufficient secure data destruction procedures.

Risk Level

High

9.9 Digital Forensics Findings Summary

Finding	Severity
Recoverable Deleted Files	High
Large Volume of Carved Artifacts	High
Recovered Media Artifacts	Medium
Residual Document Fragments	High
Weak Storage Sanitization	High

The most critical forensic weakness identified was inadequate secure deletion and storage sanitization, which enabled extensive artifact recovery.

9.10 Digital Forensics Conclusion

The Digital Forensics investigation revealed substantial recoverable residual data within the forensic disk image **RHINOUSB.dd**, indicating inadequate storage sanitization and poor data disposal practices. Analysis recovered deleted artifacts, carved media files, and residual document fragments capable of supporting meaningful activity reconstruction.

Unlike network-based evidence recovered during malware analysis, this phase provided storage-level evidence demonstrating persistent artifact recoverability after deletion. The findings indicate that sensitive information stored on removable media remains vulnerable to recovery even after apparent deletion.

Implementation of secure deletion procedures, removable media governance, and stronger data lifecycle controls is strongly recommended to reduce future exposure to forensic data recovery and unauthorized information disclosure.

10. CRYPTOGRAPHY ASSESSMENT

The Cryptography Assessment was conducted to evaluate the strength, configuration, and implementation of cryptographic controls protecting Black Eagle Institute's communication channels, authentication workflows, and transport-layer security mechanisms. The objective of this phase was to determine whether cryptographic weaknesses existed that could enable data interception, credential exposure, session compromise, or degradation of communication confidentiality.

The assessment focused on identifying deprecated cryptographic protocols, weak cipher suites, insecure authentication transmission, certificate configuration weaknesses, and deficiencies in secure transport enforcement. Evaluation included inspection of TLS protocol support, SSL certificate behavior, cipher negotiation, and credential protection mechanisms across externally accessible services.

The assessment identified multiple weaknesses affecting Black Eagle Institute's cryptographic posture, including support for deprecated transport protocols, weak cipher suites, absent strict transport enforcement, and insecure credential transmission. Collectively, these weaknesses materially reduce the confidentiality guarantees of sensitive communications and increase susceptibility to interception-based attacks.

10.1 Transport Layer Security Configuration

Analysis of internet-facing services confirmed the presence of encrypted communication channels protecting portions of web and email traffic.

Observed encrypted services included:

Port	Service	Cryptographic Purpose
443	HTTPS	Web traffic encryption
465	SMTPS	Secure SMTP transport

Port	Service	Cryptographic Purpose
587	SMTP Submission	Authenticated mail submission
993	IMAPS	Secure email retrieval
995	POP3S	Secure email retrieval

The presence of encrypted services indicates that Black Eagle Institute has implemented baseline transport security controls for critical communication channels.

However, the existence of encryption alone does not guarantee strong cryptographic security. Protocol version support, cipher selection, and transport enforcement significantly influence the practical security of encrypted communications.

Risk Level

Medium

10.2 Weak Cipher Suite Support

Cryptographic testing identified support for weak legacy cipher suites, including **Triple DES (3DES)**.

The most significant cipher-related finding involved exposure to the **SWEET32** attack.

Affected weakness:

- **CVE-2016-2183 — SWEET32**

SWEET32 exploits block ciphers with a 64-bit block size, such as 3DES, making long-lived encrypted sessions vulnerable to birthday-bound cryptographic attacks.

Potential impact includes:

- reduced session confidentiality
- partial plaintext recovery
- encrypted traffic analysis
- weakened secure communications

Attackers capable of capturing sufficient encrypted traffic may exploit weak block cipher implementations to recover sensitive session data.

Risk Level

High

10.3 Deprecated TLS Protocol Support

The assessment confirmed support for deprecated versions of the **Transport Layer Security (TLS)** protocol.

Observed legacy protocol support included:

- TLS 1.0
- TLS 1.1

These protocol versions are no longer considered secure by modern industry standards due to outdated cryptographic design and susceptibility to downgrade and legacy protocol attacks.

Continued support for deprecated TLS versions introduces several risks:

- weaker cipher negotiation
- downgrade attack exposure
- reduced confidentiality assurance
- compatibility with insecure legacy clients

Modern security best practice recommends exclusive use of:

- TLS 1.2
- TLS 1.3

Legacy TLS support materially weakens overall transport security.

Risk Level

Medium–High

10.4 Missing HTTP Strict Transport Security (HSTS)

Cryptographic review identified absence of **HTTP Strict Transport Security (HSTS)** on web-facing services.

HSTS is a browser-enforced security policy that ensures clients communicate with web services exclusively over HTTPS.

Without HSTS, browsers may initially connect over plaintext HTTP before redirection to HTTPS.

This creates opportunities for active network attackers to perform:

- SSL stripping
- protocol downgrade attacks
- man-in-the-middle interception
- session hijacking

The absence of HSTS weakens defenses against active interception attacks, especially on untrusted networks.

Risk Level

Medium

10.5 Insecure Credential Transmission

One of the most critical cryptographic findings involved insecure transmission of authentication credentials over weak or non-encrypted protocols.

Network forensic analysis revealed credential exposure during protocol inspection.

Recovered authentication evidence included FTP credentials transmitted in plaintext:

USER gnome

PASS gnome123

Because FTP provides no native encryption for authentication exchanges, credentials were directly recoverable from captured traffic.

Additionally, packet analysis identified **Base64-encoded IMAP authentication sequences**. While Base64 encoding obscures raw credentials visually, it does **not provide encryption** and remains trivially reversible when intercepted.

Observed IMAP authentication behavior included:

- authentication login sequences
- credential exchange
- mailbox access commands

Potential impact includes:

- credential theft
- unauthorized account access
- mailbox compromise
- session hijacking

This represented one of the most severe cryptographic weaknesses identified during the assessment.

Risk Level

High

10.6 Certificate and Trust Observations

SSL/TLS certificate inspection confirmed the presence of valid certificate-based encryption for HTTPS-enabled services.

Certificate deployment provided:

- server identity validation
- encrypted session establishment
- browser trust assurance

However, certificate validity alone did not compensate for protocol and cipher weaknesses identified elsewhere in the assessment.

Trust remains weakened when strong certificates coexist with:

- deprecated TLS support
- weak ciphers
- missing transport enforcement

Therefore, certificate deployment was assessed as beneficial but insufficient for strong cryptographic assurance.

Risk Level

Low–Medium

10.7 Cryptographic Findings Summary

Finding	Severity
Weak 3DES Cipher Support (SWEET32)	High
Deprecated TLS 1.0 Support	Medium
Deprecated TLS 1.1 Support	Medium
Missing HSTS	Medium
Plaintext FTP Credentials	High
Weak IMAP Authentication Protection	High

The most severe weaknesses involved insecure credential transmission and weak legacy cipher support.

10.8 Business Impact Analysis

The identified cryptographic weaknesses materially increase exposure to interception-based attacks and credential compromise.

Potential business impacts include:

- theft of user credentials
- unauthorized system access
- leakage of confidential communications

- reduced user trust
- regulatory non-compliance
- elevated phishing success

Attackers positioned on network paths may exploit these weaknesses to intercept sessions, harvest credentials, or weaken secure communications.

The combination of legacy protocols and weak authentication protection increases enterprise exposure significantly.

10.9 Cryptography Assessment Conclusion

The Cryptography Assessment indicates that Black Eagle Institute maintains a **moderate cryptographic risk posture** with several significant weaknesses affecting secure communications.

The most critical findings were weak cipher support, deprecated TLS protocol usage, missing transport enforcement, and insecure transmission of authentication credentials over legacy protocols such as FTP and weakly protected IMAP sessions.

Although cryptographic protections exist for certain services, inconsistent implementation and legacy protocol support materially weaken communication confidentiality and authentication security. Immediate remediation should prioritize disabling deprecated protocols, enforcing strong cipher suites, mandating secure credential transmission, and strengthening transport-layer protections.

11. APPLICATION SECURITY ASSESSMENT

The Application Security Assessment was conducted to evaluate the security posture of Black Eagle Institute's web application environment, with emphasis on application logic, input handling, authentication workflows, session management, and client-server trust boundaries. The objective of this phase was to determine the application's resilience against common web-based attacks and identify weaknesses that could permit unauthorized access, data manipulation, or code execution.

Unlike the Vulnerability Assessment, which focused primarily on infrastructure and service-level weaknesses, this phase examined the application layer itself—specifically how user-supplied data is processed, validated, stored, and rendered. The assessment aligned with common application security risk categories defined by the **OWASP Top 10**, including injection flaws, broken access control, insecure design, and cross-site scripting.

Testing revealed that the application demonstrated baseline defensive controls against common injection attacks; however, several residual security concerns remained in authentication assurance, transport protection, and application-layer exposure.

11.1 Application Architecture Exposure

Application fingerprinting and web reconnaissance identified a modern web application stack supporting Black Eagle Institute's public-facing services.

Observed technologies included:

Component	Technology
Web Server	nginx / Apache HTTP Server
Backend Framework	Laravel
Runtime Environment	PHP 8.2.30
Transport Layer	HTTP / HTTPS

Technology disclosure presents a security concern because adversaries can use identified frameworks and runtime versions to map known vulnerabilities, framework-specific exploit chains, and public proof-of-concept attacks.

Attackers may leverage this information to optimize attack paths against known framework weaknesses.

Risk Level

Medium

11.2 Injection and Cross-Site Scripting Resistance (Cross-Reference)

Section 7 (Penetration Testing) already documents the technical execution and evidence for SQL injection and XSS testing against this application, including the exact payloads used and the ZAP-intercepted requests (Appendix C, Figures C1–C2). Rather than repeat that methodology, this subsection interprets those results at the application-design level.

The consistent rejection or neutralization of injection and script payloads across both the infrastructure-focused penetration test (Section 7.3–7.4) and this application-focused review indicates that input handling is enforced **centrally** — most likely at the Laravel framework layer (parameterized Eloquent queries and Blade auto-escaping) rather than through ad hoc, endpoint-by-endpoint filtering. This is a meaningfully stronger design pattern than per-field sanitization, because it does not depend on developers remembering to sanitize every new input.

Risk Level

Low–Medium — see Section 7.3–7.4 for full evidence.

11.3 Authentication Workflow and Backend Request Handling (Cross-Reference)

Section 7.6 documents direct testing of authentication bypass and backend parameter manipulation, including the observed 302-redirect login flow (Appendix C, Figure C5) and structured credential-failure disclosure (Appendix C, Figure C4). No authentication bypass or authorization-logic abuse was achieved through request tampering, indicating that server-side validation — not client-side trust — governs access decisions.

Two residual design-level concerns are not visible from request-level testing alone but follow from evidence gathered elsewhere in this report:

- **No confirmed multi-factor authentication.** Combined with the publicly exposed staff email addresses documented in Section 4 and the plaintext credential capture demonstrated in Appendix D (Figure D4), a single leaked or intercepted password is likely sufficient for account takeover — the application has no second control layer to fall back on.
- **Verbose, incrementing error identifiers** in failed-login responses (Appendix C, Figure C4) provide a low-cost oracle an attacker could use to distinguish valid from invalid usernames or to fingerprint backend state, even though this alone does not constitute a bypass.

Risk Level

Medium — bypass resistance is Low risk; absence of MFA raises the practical account-takeover risk to Medium (see R-002, Section 12.2).

11.4 Session and Transport Security

Application session security depends heavily on the confidentiality and integrity of transport-layer protections. This assessment identified transport-related weaknesses that directly undermine application-layer session security even though the application logic itself tested soundly:

- missing HSTS enforcement (Appendix B, Figure B9)
- deprecated TLS 1.0/1.1 support (Appendix B, Figure B10)
- weak/medium-strength cipher suite support (Appendix B, Figure B7)

Even when application logic is secure, weak transport security can undermine session confidentiality and authentication trust — a stolen session cookie is just as damaging as a bypassed login form. Full technical detail and evidence for these findings is provided in Section 10 (Cryptography Assessment); it is referenced here because it is the dominant contributor to overall application-layer risk.

Risk Level

Medium–High

11.5 Secure Coding Observations

Taken together, Sections 7 and 11.2–11.3 support a consistent picture: input sanitization, output encoding, and server-side authorization enforcement all held under direct testing, indicating baseline secure development practices were followed. The absence of observable advanced protections — strict security headers, a visible Content Security Policy, or hardened session-cookie flags — represents the next tier of hardening rather than a foundational gap.

Risk Level

Low–Medium

11.6 Application Security Findings Summary

Finding	Severity
Technology Stack Disclosure	Medium
Injection / XSS Resistance (framework-level)	Low–Medium
Authentication Bypass Resistance	Low
Absence of Multi-Factor Authentication	Medium
Weak Session Transport Security	Medium–High
Backend Request Tampering Resistance	Low–Medium

The most significant application-layer weakness identified involved transport and session protection rather than application logic itself — the application resisted every direct exploitation attempt, but the channel carrying its sessions did not.

11.7 Business Impact Analysis

The identified application security weaknesses present moderate risk to the confidentiality and integrity of application workflows.

Potential business impacts include:

- unauthorized session access
- credential theft
- abuse of authentication workflows
- reduced trust in online services
- increased susceptibility to targeted attacks

Although no critical application-layer exploit was achieved, attackers may still combine application weaknesses with social engineering or transport-layer weaknesses to achieve compromise.

11.8 Application Security Assessment Conclusion

Taken together with Section 7 (Penetration Testing), the application layer is this assessment's clearest example of a **working baseline control**: input validation and script filtering held against direct SQLi and XSS attempts, most likely enforced at the framework level. The residual risk here is not application logic but the **transport and session layer beneath it, and the absence of a second authentication factor above it** — this is why Section 10 (Cryptography) and Risks R-002/R-005/R-006 in the Risk Register, rather than application logic itself, carry the higher priority rating for remediation.

12. RISK REGISTER

The Risk Register consolidates validated findings from all assessment phases and prioritizes the most significant cybersecurity risks affecting **Black Eagle Institute**. The purpose of this section is to translate technical findings into business-relevant risk statements that support decision-making, resource allocation, and remediation planning.

While previous sections focused on identifying and validating individual weaknesses, this section evaluates those findings collectively to determine which risks pose the greatest threat to the organization's confidentiality, integrity, availability, operational continuity, and reputation.

Risk prioritization was performed using qualitative analysis based on:

- likelihood of exploitation
- technical severity
- exposure level
- potential business impact
- ease of attacker execution

This approach ensured that risk ratings reflected not only technical vulnerability severity but also practical exploitability and organizational consequence.

12.1 Risk Rating Criteria

Risk ratings were assigned using the following classification model:

Risk Level	Description
Critical	Immediate exploitation likely with severe business impact
High	Exploitable weakness with major operational or financial impact
Medium	Moderate exploitability or contained impact
Low	Limited exploitability or minimal business impact

Priority ratings were mapped as:

Priority	Meaning
P1	Immediate remediation required
P2	High-priority short-term remediation
P3	Medium-term strategic remediation

This model provided a consistent framework for comparing technical and non-technical risks.

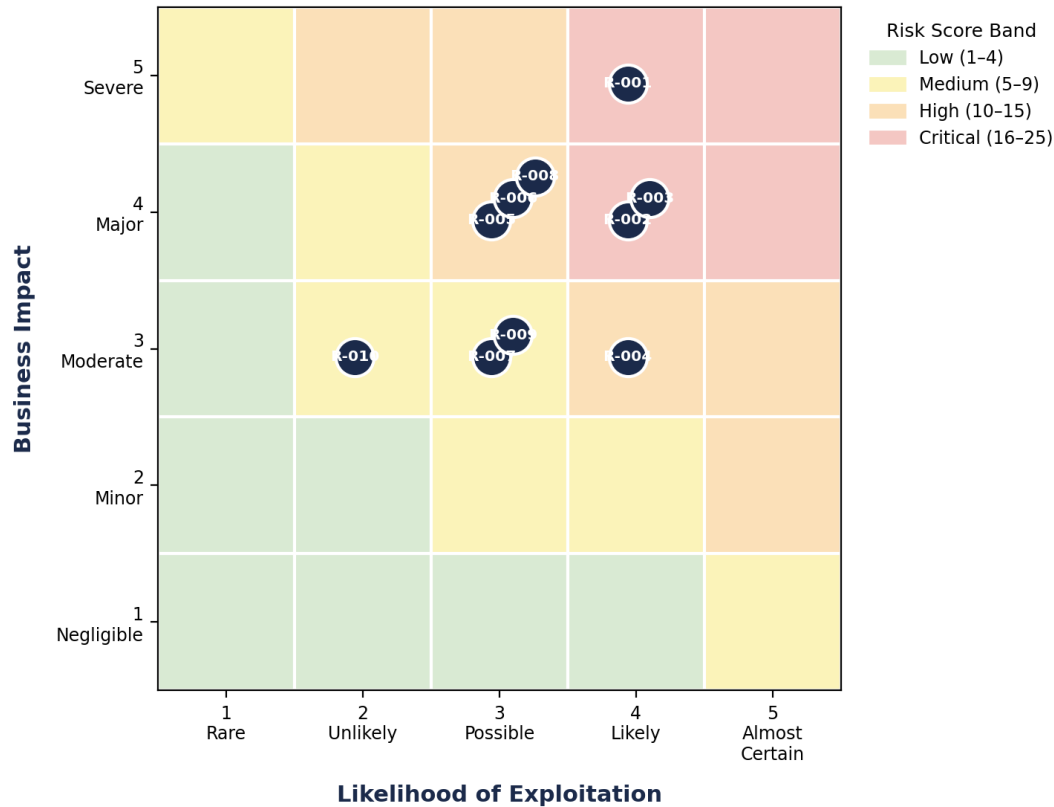
12.2 Consolidated Risk Register

Likelihood and Impact are scored 1–5 per the model defined in Section 2.12; Risk Score = Likelihood × Impact.

ID	Risk Description *	*L** *	*I** *	*Score** *	*Band** *	*Priority** *	*Business Impact**
R-001	Mail infrastructure compromise via vulnerable Exim SMTP (RCE)	4	5	20	Critical	P1	Full infrastructure foothold; extended downtime; regulatory notification risk
R-002	Credential theft via plaintext FTP/IMAP authentication	4	4	16	Critical	P1	Account takeover; mailbox compromise; fraud enablement
R-003	Business Email Compromise targeting executive/finance staff	4	4	16	Critical	P1	Direct financial fraud (wire/invoice); reputational damage
R-004	External reconnaissance via public staff & infra exposure	4	3	12	High	P2	Enables R-002/R-003; lowers attacker cost
R-005	Session interception via weak TLS and missing HSTS	3	4	12	High	P2	Data-in-transit exposure; downgrade attacks
R-006	Unauthorized access via exposed authentication surfaces	3	4	12	High	P2	Unauthorized data or system access
R-007	Sensitive data exposure from unsanitized removable media	3	3	9	Medium	P3	Regulatory exposure if lost/resold device
R-008	Suspicious outbound traffic consistent with C2 beaconing	3	4	12	High	P1	Possible active compromise; requires urgent triage
R-009	Data leakage from inadequate secure-deletion practices	3	3	9	Medium	P3	Residual sensitive data recoverable post-disposal
R-010	Residual application-layer weaknesses affecting session security	2	3	6	Medium	P3	Elevated exploit complexity for attackers over time

12.2.1 Risk Heat Map

Risk Heat Map — Consolidated Risk Register (R-001 to R-010)



Risk Heat Map

Plotting each risk by Likelihood and Impact visually confirms that the organization's most severe exposure is concentrated in the upper-right quadrant — high-likelihood, high-impact risks tied to the mail server, credential handling, and executive impersonation — rather than being spread evenly across the risk register. This clustering is what justifies prioritizing R-001, R-002, and R-003 ahead of all other remediation work.

12.3 Critical Risks

The following risks were classified as **Critical or High Priority (P1)** due to elevated exploitability and severe business impact.

R-001 — Mail Infrastructure Compromise

The most severe technical risk identified was the potential compromise of institutional mail infrastructure through vulnerable **Exim** SMTP services.

Successful exploitation could enable:

- remote code execution
- unauthorized server access

- credential interception
- attacker persistence
- lateral movement

Because email systems often serve as trust anchors for password resets, executive communications, and internal coordination, compromise of this infrastructure could produce cascading enterprise-wide impact.

Risk Rating

Critical

R-002 — Credential Exposure

Recovered plaintext and weakly protected credentials represent a major enterprise risk.

Credential compromise could enable:

- unauthorized login
- mailbox compromise
- privilege escalation
- data exfiltration

This risk is amplified by weak protocol security identified in FTP and IMAP sessions.

Risk Rating

High

R-003 — Business Email Compromise

Business Email Compromise represents one of the highest-probability non-technical attack paths.

This risk is elevated due to:

- exposed leadership identities
- missing DMARC enforcement
- public role-based email exposure
- organizational hierarchy visibility

Attackers could exploit trust and urgency to trigger fraudulent financial or administrative actions.

Risk Rating

High

R-008 — Suspicious Beaconing Activity

Observed outbound communications consistent with command-and-control behavior suggest potential prior or ongoing compromise.

This risk indicates possible:

- malware persistence
- attacker communications
- remote command retrieval
- post-compromise activity

Because beaconing may indicate active attacker presence, this finding warrants immediate investigation.

Risk Rating

High

12.4 High Risks

High risks represent weaknesses that are not immediately catastrophic but significantly increase attack probability or compromise severity.

These include:

- reconnaissance exposure
- weak transport security
- exposed authentication surfaces
- phishing susceptibility

Individually, each risk increases exploitability. Collectively, they can be chained to facilitate successful intrusion.

Examples include:

- R-004
- R-005
- R-006

These risks are particularly concerning because they strengthen attacker preparation and reduce attack complexity.

12.5 Medium Risks

Medium risks primarily involve weaknesses that contribute to cumulative degradation of security posture rather than immediate catastrophic compromise.

Examples include:

- residual application weaknesses
- insecure deletion practices
- removable media artifact recovery

While lower in urgency than P1 and P2 risks, failure to address these issues may create long-term security debt.

Examples include:

- R-007
- R-009
- R-010

These risks should be addressed as part of strategic hardening efforts.

12.6 Enterprise Risk Analysis

When viewed collectively, the risk landscape indicates that Black Eagle Institute faces elevated exposure across three major attack categories:

Human-Centric Threats

Including:

- phishing
- impersonation
- credential theft
- Business Email Compromise

Infrastructure-Based Threats

Including:

- mail server compromise
- protocol exploitation
- transport-layer weaknesses

- service misconfiguration

Post-Compromise Threats

Including:

- data recovery from storage artifacts
- command-and-control communications
- attacker persistence

The coexistence of these risk categories significantly increases overall enterprise exposure because attackers may chain weaknesses across multiple domains.

12.7 MITRE ATT&CK® Technique Mapping

To align findings with a recognized adversary-behavior taxonomy, the techniques observed or reproduced during this engagement are mapped below to the **MITRE ATT&CK® Enterprise Matrix**.

Tactic	Technique	ID	Observed Evidence
Reconnaissance	Gather Victim Identity Information	T1589	Public staff names, roles, emails (Section 4, Appendix A)
Reconnaissance	Search Open Websites/Domains	T1593	LinkedIn/search-engine OSINT (Appendix A)
Resource Development	Acquire Infrastructure / Scanning	T1595	Nmap/Zenmap service enumeration (Appendix A, B)
Initial Access	Exploit Public-Facing Application	T1190	Exim SMTP RCE exposure (Appendix B, Figure B5)
Initial Access	Phishing	T1566	BEC/spear-phishing susceptibility (Section 5)
Credential Access	Brute Force / Unsecured Credentials	T1110 / T1552	Plaintext FTP USER/PASS capture (Appendix D, Figure D4)
Credential Access	Network Sniffing	T1040	Credentials recovered from packet capture (Appendix D)
Collection	Email Collection	T1114	IMAP mailbox authentication and access (Appendix D, Figure D6)
Defense Evasion	Indicator Removal	T1070	Email deletion / mailbox EXPUNGE (Appendix D, Figure D7)
Command and Control	Application Layer Protocol	T1071	Traffic patterns consistent with C2 beaconing (Section 8)
Exfiltration	Exfiltration Over Alternative Protocol	T1048	Suspicious FTP archive transfer (Appendix D, Figure D5)

This mapping demonstrates that the identified weaknesses are not abstract — each corresponds to a technique in active use by real-world threat actors, and several were technically reproduced (not merely inferred) during this engagement.

12.8 Risk Register Conclusion

The overall security posture of Black Eagle Institute is assessed as **Medium–High Risk**, with multiple high-severity risks concentrated around credential security, email infrastructure, cryptographic weakness, external reconnaissance exposure, and suspicious outbound communications.

The most critical risks requiring immediate remediation involve:

- mail infrastructure compromise
- credential theft
- Business Email Compromise
- suspected command-and-control activity

Secondary risks involve reconnaissance exposure, weak transport security, and inadequate data sanitization practices.

Effective risk reduction should prioritize controls that reduce exploitability of high-impact attack paths while improving detection, monitoring, and incident response capability.

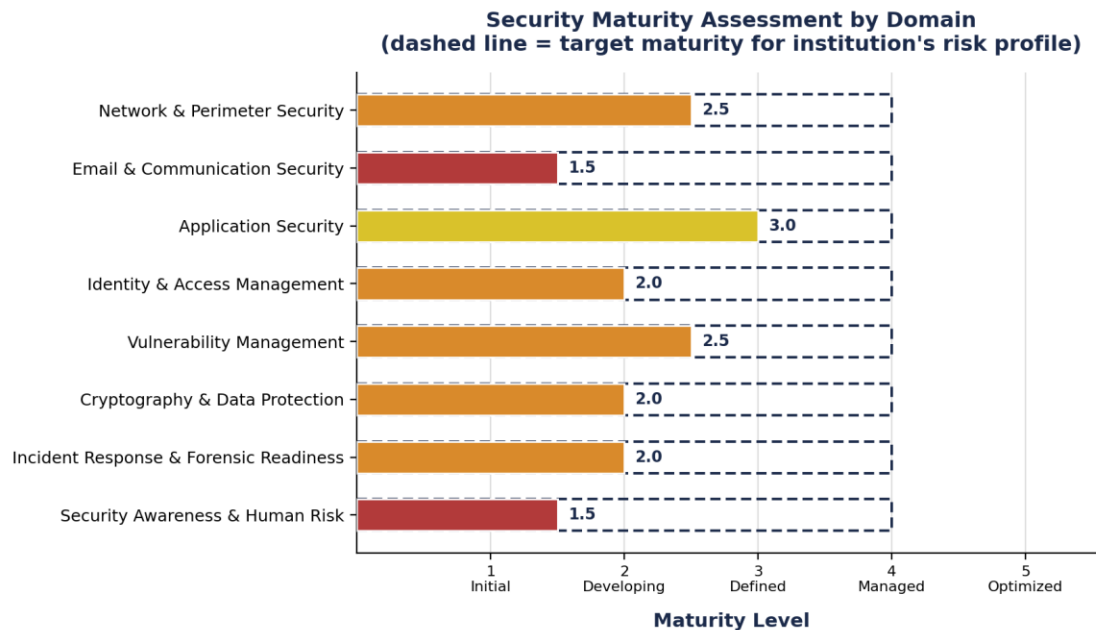
13. SECURITY MATURITY ASSESSMENT

While the Risk Register (Section 12) identifies discrete findings, it does not by itself answer a question executives consistently ask: *how mature is our security program overall, and where should we invest to close the gap?* This section maps assessment findings onto a five-level maturity model — adapted from the structure used by the **CIS Critical Security Controls** and comparable capability-maturity frameworks — across eight cybersecurity domains.

13.1 Maturity Scale

Level	Label	Description
1	Initial	Ad hoc or absent; no consistent process
2	Developing	Basic controls exist but are inconsistent or reactive
3	Defined	Documented, repeatable processes in place
4	Managed	Proactively monitored, measured, and enforced
5	Optimized	Continuously improved; integrated into governance

13.2 Domain-by-Domain Assessment



Security Maturity Chart

Domain	Current Level	Basis for Rating
Network & Perimeter Security	2.5 — Developing	Broad service exposure; no evidence of network segmentation (Section 6)
Email & Communication Security	1.5 — Initial/Developing	Vulnerable Exim version; no DMARC enforcement observed (Sections 5, 6)
Application Security	3.0 — Defined	Input validation held against direct SQLi/XSS testing (Section 7, 11)
Identity & Access Management	2.0 — Developing	Plaintext authentication protocols still enabled (Section 6, Appendix D)
Vulnerability Management	2.5 — Developing	Vulnerabilities present but of known, well-documented types with available patches
Cryptography & Data Protection	2.0 — Developing	Deprecated TLS versions and weak ciphers still active (Section 10)
Incident Response & Forensic Readiness	2.0 — Developing	No evidence of monitoring/alerting; artifacts were fully recoverable post-hoc (Section 9)
Security Awareness & Human Risk	1.5 — Initial/Developing	High public exposure of staff identities; no evidence of phishing-resistant practices (Section 5)

Target maturity for an institution of this size and risk profile is **Level 4 (Managed)** across all domains — the dashed line in the chart above. The organization's largest maturity gaps are in **Email & Communication Security** and **Security Awareness & Human Risk**, which is consistent with the Risk Register's top three risks (R-001, R-002, R-003) all tracing back to these two domains.

13.3 Maturity Assessment Conclusion

Black Eagle Institute’s overall security program sits at an average maturity of approximately **2.1 — Developing**. This does not mean controls are entirely absent; rather, it means controls exist inconsistently, are not formally documented or monitored, and rely heavily on default configurations rather than deliberate hardening decisions. Closing this gap is a multi-year program, not a single remediation sprint — Section 14 sequences the work required to move each domain toward Level 4.

14. PRIORITIZED REMEDIATION PLAN

The Prioritized Remediation Plan provides actionable recommendations designed to reduce Black Eagle Institute’s most significant cybersecurity risks identified during the assessment. The purpose of this section is to translate validated findings and risk ratings into a structured roadmap that enables efficient allocation of resources toward the most critical security improvements.

Remediation priorities were determined using the Risk Register, with emphasis placed on exploitability, severity, business impact, and likelihood of compromise. Recommendations were categorized into phased implementation timelines to support practical execution without overwhelming operational resources.

The remediation strategy follows a risk-based approach in which critical weaknesses are addressed first to rapidly reduce immediate attack exposure, followed by medium- and long-term hardening initiatives that improve overall cybersecurity maturity.

14.1 Remediation Priority Framework

Recommendations were grouped into three implementation priorities:

Priority	Timeline	Meaning
P1	Immediate (0–30 Days)	Critical remediation required to reduce immediate compromise risk
P2	Short-Term (1–3 Months)	High-priority security hardening
P3	Medium-Term (3–6 Months)	Strategic resilience and maturity improvements

This phased approach ensures that remediation efforts address both urgent operational risks and long-term governance improvements.

14.2 Priority 1 (P1) — Immediate Remediation

Priority 1 actions address **Critical and High-risk findings** requiring urgent mitigation to prevent exploitation or contain potential compromise.

Recommendation	Addresses	
	Risk	Responsible Owner
Patch or upgrade vulnerable Exim SMTP services	R-001	Infrastructure / System Administration
Disable insecure authentication protocols (legacy FTP, weak POP3/IMAP configurations)	R-002	Infrastructure Team
Enforce encrypted authentication channels only	R-002	Security / Infrastructure Team
Investigate host 10.18.20.97 for signs of compromise	R-008	SOC / Incident Response Team
Reset exposed or potentially compromised credentials	R-002	IAM / Security Team
Enable Multi-Factor Authentication (MFA) for privileged accounts	R-003, R-006	IAM Team

These actions target the highest-risk attack paths involving infrastructure compromise, credential theft, and active compromise indicators.

14.3 Expected Benefits of P1 Remediation

Successful execution of Priority 1 actions will significantly reduce exposure to immediate compromise scenarios.

Expected security improvements include:

- reduction in remote exploitation risk
- elimination of legacy credential exposure
- improved privileged account protection
- containment of potential attacker persistence
- reduction in successful credential abuse

These actions provide the greatest immediate reduction in enterprise risk.

14.4 Priority 2 (P2) — Short-Term Security Hardening

Priority 2 remediation focuses on reducing exploitability of infrastructure weaknesses, strengthening transport security, and mitigating reconnaissance-driven attack vectors.

Recommendation	Addresses	
	Risk	Responsible Owner
Disable TLS 1.0 and TLS 1.1	R-005	Infrastructure Team
Remove weak cipher suites (3DES and legacy SSL ciphers)	R-005	Security Engineering
Enforce HTTP Strict Transport Security (HSTS)	R-005	Web Administration

Recommendation	Addresses Risk	Responsible Owner
Implement anti-phishing awareness training	R-003, R-004	HR / Security Team
Reduce public exposure of staff contact information	R-004	IT / Communications
Apply login rate limiting and anomaly detection	R-006	Application Security Team
Implement DMARC email policy enforcement	R-003	Mail Administration

These recommendations reduce attack surface and strengthen both technical and human security controls.

14.5 Expected Benefits of P2 Remediation

Implementation of Priority 2 recommendations will improve resilience against both technical exploitation and social engineering attacks.

Expected improvements include:

- stronger transport confidentiality
- reduced phishing success rate
- improved spoofing resistance
- reduced reconnaissance exposure
- improved authentication monitoring

These improvements substantially reduce attack feasibility.

14.6 Priority 3 (P3) — Strategic Security Improvements

Priority 3 recommendations focus on long-term security maturity, governance, visibility, and resilience.

Recommendation	Addresses Risk	Responsible Owner
Deploy centralized log monitoring / SIEM	R-008	Security Operations
Implement Endpoint Detection and Response (EDR)	R-008	Security Operations
Establish removable media handling policy	R-007, R-009	IT Governance
Implement secure deletion procedures	R-009	IT Operations
Conduct periodic penetration testing	R-010	Security Team
Adopt Secure Software Development Lifecycle (SSDLC)	R-010	Development / AppSec Team

These strategic controls improve long-term detection capability and reduce recurring security debt.

14.7 Expected Benefits of P3 Remediation

Successful implementation of strategic controls will improve enterprise-wide cybersecurity maturity.

Expected benefits include:

- improved threat detection
- stronger forensic readiness
- reduced residual data leakage
- better governance and compliance
- improved application security lifecycle

These initiatives strengthen long-term resilience against evolving threats.

14.8 Organizational Security Program Recommendations

Beyond technical remediation, Black Eagle Institute should strengthen its broader cybersecurity governance and organizational security culture.

Recommended strategic programs include:

Security Awareness Program

Implement continuous staff awareness training covering:

- phishing detection
- password hygiene
- email verification procedures
- social engineering resistance
- suspicious activity reporting

Because human compromise remains a primary attack vector, regular awareness training is essential.

Vulnerability Management Program

Establish a recurring vulnerability management lifecycle including:

- asset inventory management
- scheduled vulnerability scanning
- patch tracking
- remediation validation
- periodic reassessment

This ensures vulnerabilities are continuously identified and addressed.

Incident Response Readiness

Formalize incident response procedures for events such as:

- malware detection
- suspicious outbound traffic
- credential compromise
- email compromise
- forensic evidence preservation

Improved incident response readiness reduces containment time and limits attack impact.

14.9 Remediation Roadmap Summary

Priority	Focus Area	Primary Objective
P1	Critical Exposure Reduction	Prevent immediate compromise
P2	Security Hardening	Reduce attack surface
P3	Security Maturity	Improve long-term resilience

This roadmap provides a practical sequence for security improvement without disrupting operational continuity.

14.10 Prioritized Remediation Plan Conclusion

Black Eagle Institute should prioritize immediate remediation of critical infrastructure vulnerabilities, credential exposure risks, and suspected compromise indicators. Particular urgency should be placed on mail infrastructure hardening, secure authentication enforcement, credential rotation, and investigation of suspicious internal host activity.

Implementation of the remediation roadmap will significantly reduce Black Eagle Institute’s exposure to cyber threats and materially improve its ability to prevent, detect, respond to, and recover from future security incidents.

APPENDIX A

OSINT & Reconnaissance Evidence

Figure A1 — Target Discovery and DNS Resolution

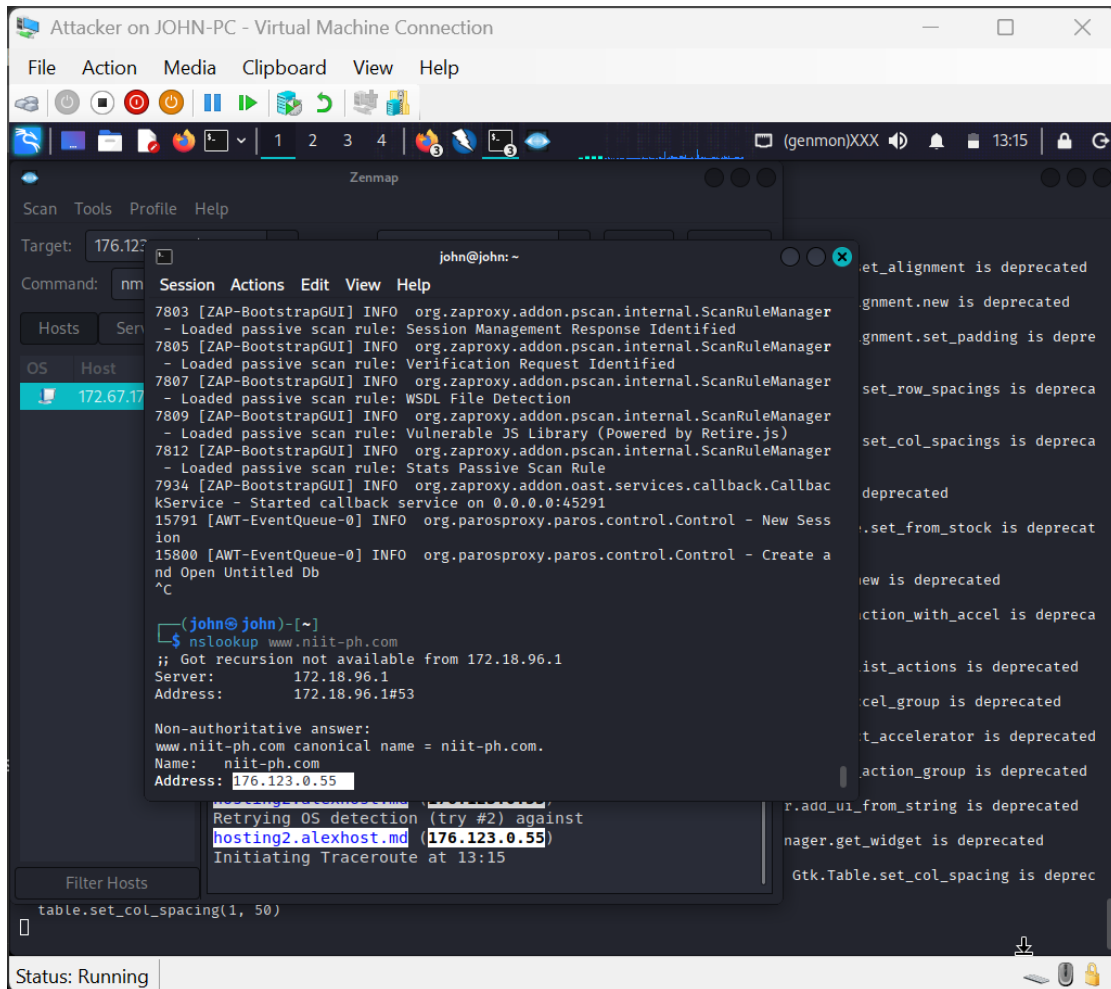


Figure A1

Evidence from DNS interrogation showed the target domain resolved to IP address **176.123.0.55**, associated with **hosting2.alexhost.md**, confirming third-party hosting infrastructure and shared hosting dependencies.

Key Findings

- Target IP identified
- Hosting provider exposed
- External infrastructure dependency confirmed

Figure A2 — Zenmap Service Enumeration

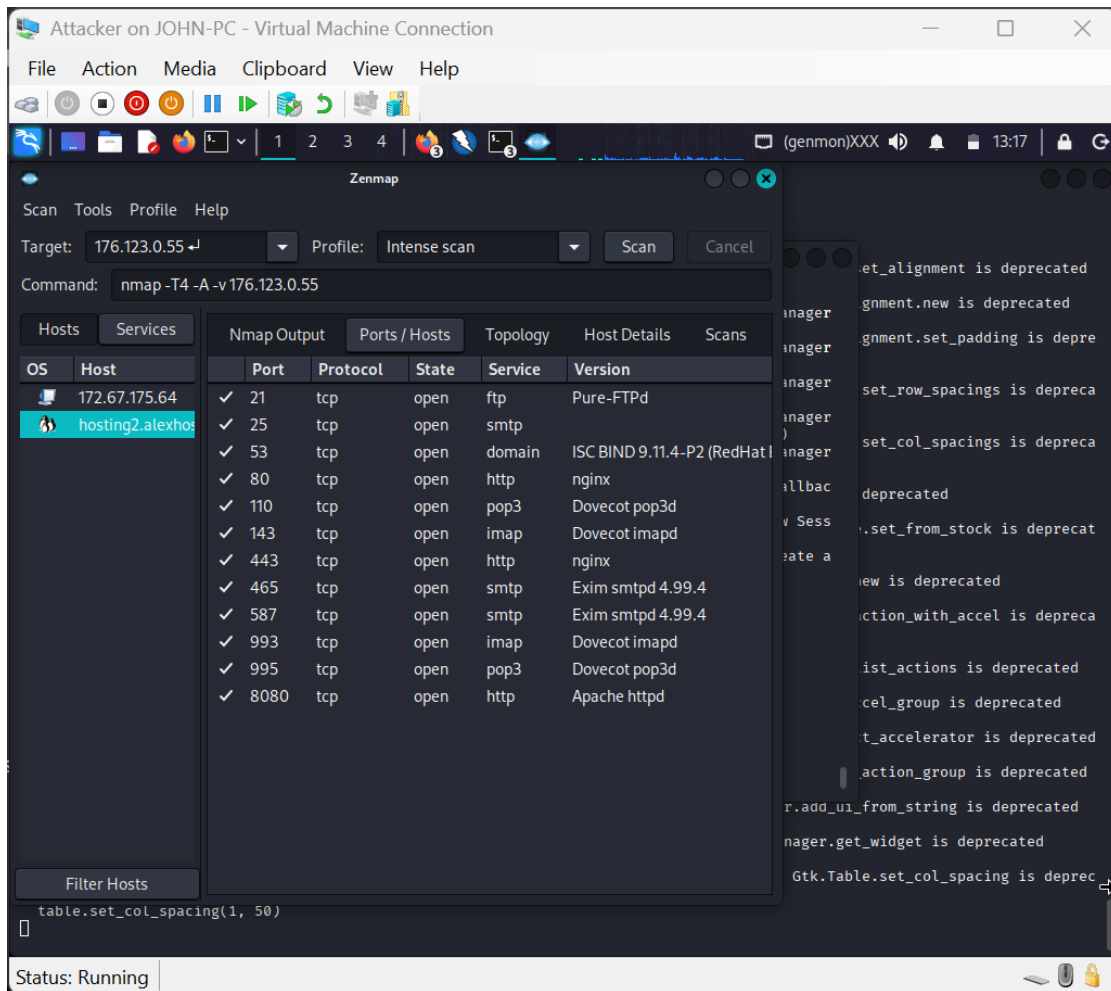


Figure A2

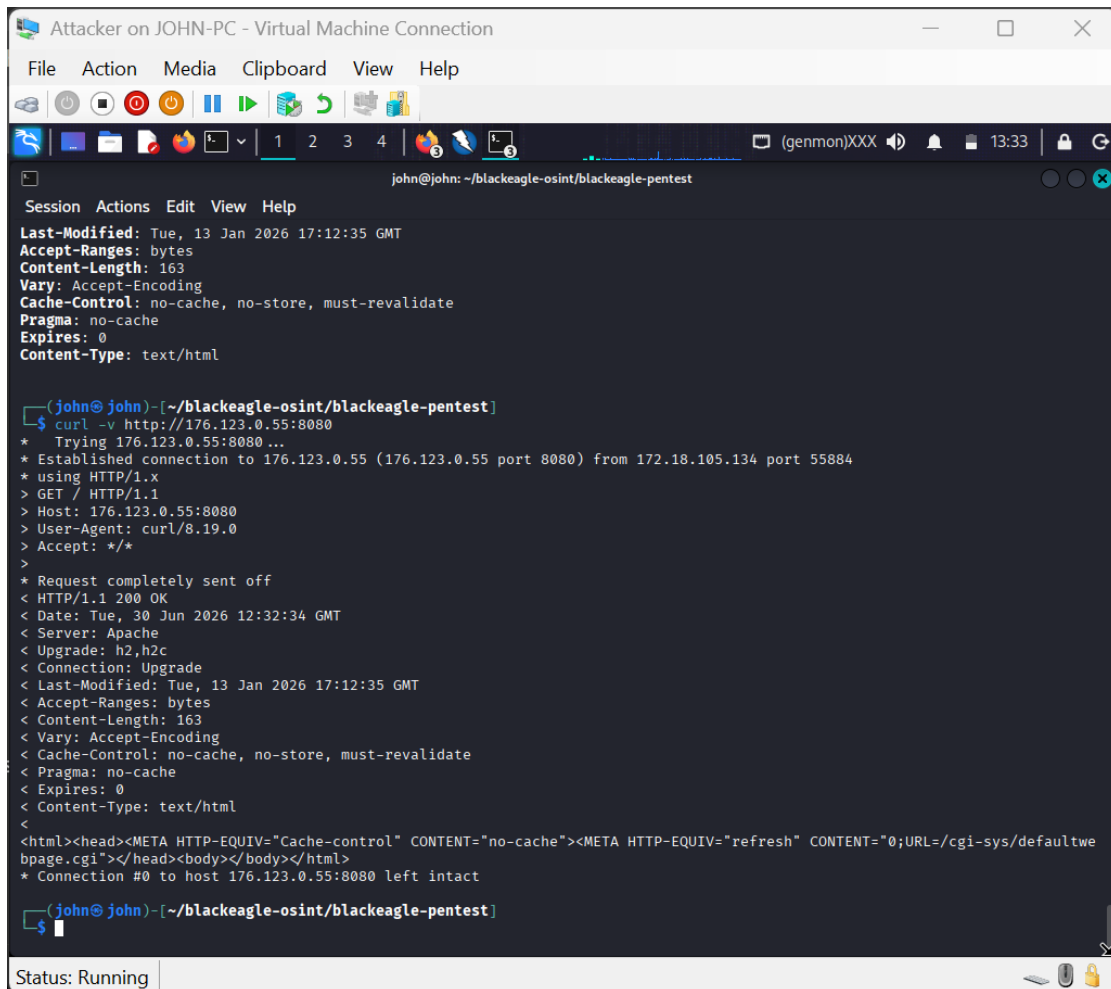
Zenmap service enumeration revealed multiple externally reachable services, increasing the organization's attack surface.

Observed Open Services

- FTP (21)
- DNS (53)
- HTTP (80, 8080)
- POP3 (110, 995)
- IMAP (143, 993)
- HTTPS (443)
- SMTP (465, 587)

Security Implication Large attack surface increases opportunities for exploitation.

Figure A3 — HTTP Header Enumeration



```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help
john@john: ~/blackeagle-osint/blackeagle-pentest
Session Actions Edit View Help
Last-Modified: Tue, 13 Jan 2026 17:12:35 GMT
Accept-Ranges: bytes
Content-Length: 163
Vary: Accept-Encoding
Cache-Control: no-cache, no-store, must-revalidate
Pragma: no-cache
Expires: 0
Content-Type: text/html

(john@john)-[~/blackeagle-osint/blackeagle-pentest]
$ curl -v http://176.123.0.55:8080
* Trying 176.123.0.55:8080 ...
* Established connection to 176.123.0.55 (176.123.0.55 port 8080) from 172.18.105.134 port 55884
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 176.123.0.55:8080
> User-Agent: curl/8.19.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Tue, 30 Jun 2026 12:32:34 GMT
< Server: Apache
< Upgrade: h2,h2c
< Connection: Upgrade
< Last-Modified: Tue, 13 Jan 2026 17:12:35 GMT
< Accept-Ranges: bytes
< Content-Length: 163
< Vary: Accept-Encoding
< Cache-Control: no-cache, no-store, must-revalidate
< Pragma: no-cache
< Expires: 0
< Content-Type: text/html
<
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaultwe
bpage.cgi"></head><body></body></html>
* Connection #0 to host 176.123.0.55:8080 left intact

(john@john)-[~/blackeagle-osint/blackeagle-pentest]
$
Status: Running

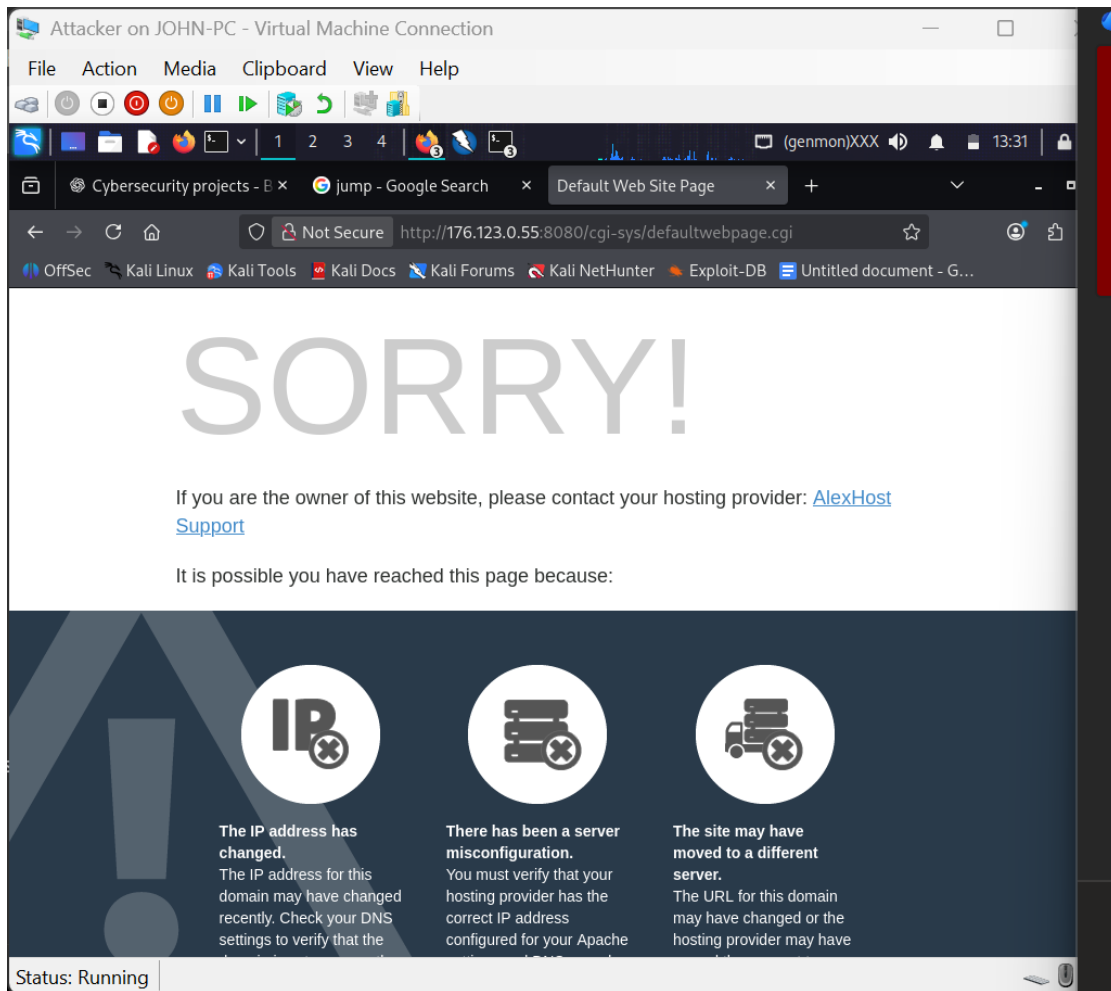
```

Figure A3

Manual HTTP interrogation confirmed an active web service on port **8080** running Apache.

Observed

- HTTP 200 response
- Apache server banner
- Alternate HTTP service

Figure A4 — Port 8080 Service Exposure*Figure A4*

Port 8080 returned an **AlexHost default page**, suggesting virtual host misconfiguration or default service exposure.

Security Implication

- Possible configuration weakness
- Infrastructure disclosure

Figure A5 — FTP Banner Grabbing

```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help

john@john: ~/blackeagle-osint/blackeagle-pentest
Session Actions Edit View Help
* Trying 176.123.0.55:8080 ...
* Established connection to 176.123.0.55 (176.123.0.55 port 8080) from 172.18.105.134 port 55884
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 176.123.0.55:8080
> User-Agent: curl/8.19.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Tue, 30 Jun 2026 12:32:34 GMT
< Server: Apache
< Upgrade: h2,h2c
< Connection: Upgrade
< Last-Modified: Tue, 13 Jan 2026 17:12:35 GMT
< Accept-Ranges: bytes
< Content-Length: 163
< Vary: Accept-Encoding
< Cache-Control: no-cache, no-store, must-revalidate
< Pragma: no-cache
< Expires: 0
< Content-Type: text/html
<
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaulttw
bpage.cgi"></head><body></body></html>
* Connection #0 to host 176.123.0.55:8080 left intact

(john@john)~/blackeagle-osint/blackeagle-pentest
$ curl http://176.123.0.55:8080
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaulttw
bpage.cgi"></head><body></body></html>

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 21
220 _____ Welcome to Pure-FTPd [privsep] [TLS] _____
220-You are user number 8 of 50 allowed.
220-Local time is now 15:50. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.

Status: Running

```

Figure A5

Banner grabbing confirmed the presence of a **Pure-FTPd** service.

Observed Banner

220 Welcome to Pure-FTPd [privsep] [TLS]

Security Implication

- FTP service active
- File transfer attack surface exposed

Figure A6 — SMTP Banner Enumeration

```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help

john@john: ~/blackeagle-osint/blackeagle-pentest

Session Actions Edit View Help
< Server: Apache
< Upgrade: h2,h2c
< Connection: Upgrade
< Last-Modified: Tue, 13 Jan 2026 17:12:35 GMT
< Accept-Ranges: bytes
< Content-Length: 163
< Vary: Accept-Encoding
< Cache-Control: no-cache, no-store, must-revalidate
< Pragma: no-cache
< Expires: 0
< Content-Type: text/html
<
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaultwe
bpage.cgi"></head><body></body></html>
* Connection #0 to host 176.123.0.55:8080 left intact

(john@john)~/blackeagle-osint/blackeagle-pentest
$ curl http://176.123.0.55:8080
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaultwe
bpage.cgi"></head><body></body></html>

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 21
220- Welcome to Pure-FTPd [privsep] [TLS]
220-You are user number 8 of 50 allowed.
220-Local time is now 15:50. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
^C

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 25
(UNKNOWN) [176.123.0.55] 25 (smtp) : Connection timed out

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 25
220-hosting2.alexhost.md ESMTP Exim 4.99.4 #2 Tue, 30 Jun 2026 15:55:53 +0300
220-We do not authorize the use of this system to transport unsolicited,
220 and/or bulk e-mail.

Status: Running

```

Figure A6

SMTP banner grabbing identified **Exim 4.99.4**.

Observed Banner

220-hosting2.alexhost.md ESMTP Exim 4.99.4

Security Implication

- Mail infrastructure externally accessible
- Version fingerprinting possible

Appendix A Summary

OSINT and reconnaissance activities revealed a broad externally accessible infrastructure comprising web, mail, DNS, and file transfer services. The exposed services significantly expanded the organization's attack surface and informed subsequent vulnerability assessment and penetration testing activities.

APPENDIX B

Vulnerability Assessment Evidence

Figure B1 — Port Enumeration and Service Discovery

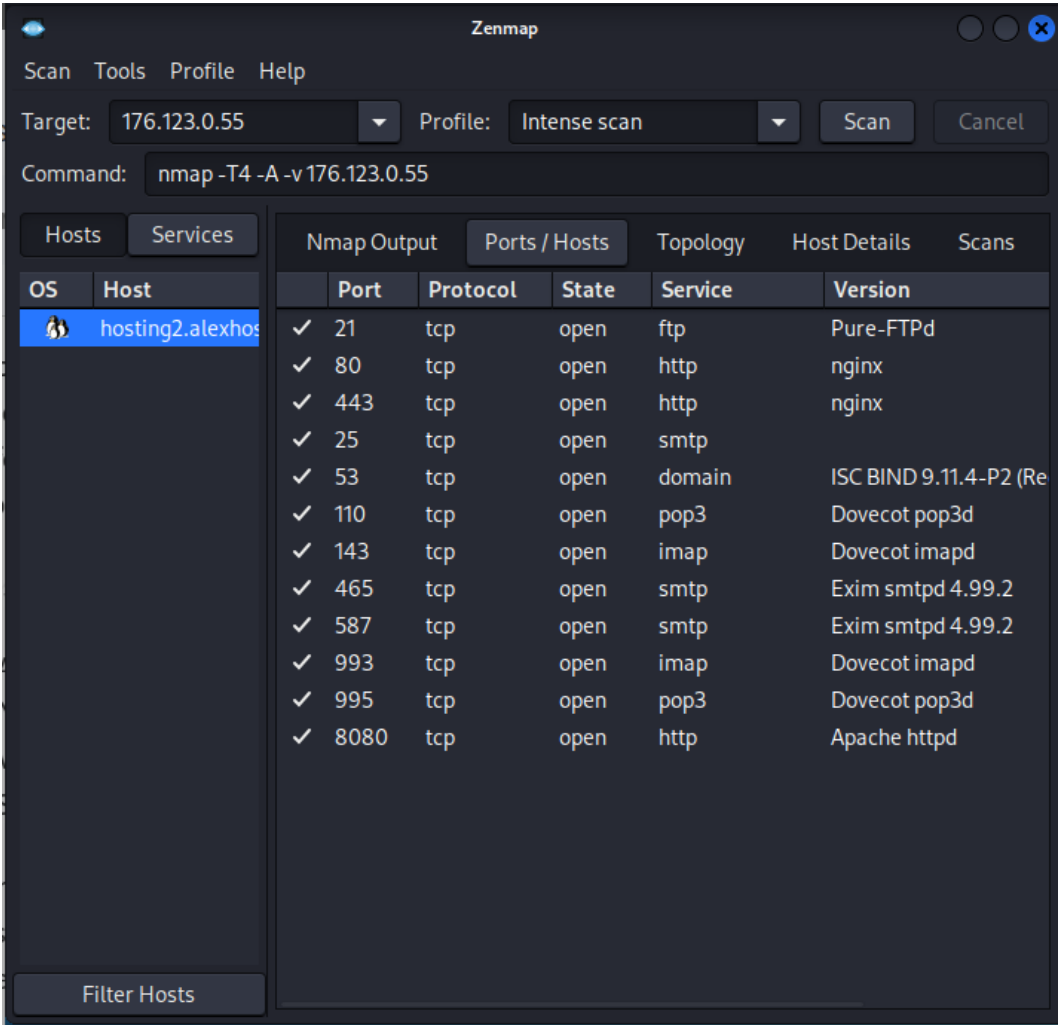


Figure B1

Zenmap (Nmap) service enumeration conducted during the vulnerability assessment phase confirmed the externally reachable services previously identified during reconnaissance, providing an independent, dated verification of the target’s attack surface.

Identified Open Ports and Services

Port	Service	Technology
21	FTP	Pure-FTPd
25	SMTP	Exim SMTP

Port	Service	Technology
53	DNS	ISC BIND
80	HTTP	nginx
110	POP3	Dovecot
143	IMAP	Dovecot
443	HTTPS	nginx
465	SMTPS	Exim
587	SMTP Submission	Exim
993	IMAPS	Dovecot
995	POP3S	Dovecot
8080	Alternate HTTP	Apache

Security Implication

The presence of multiple exposed services significantly increases the external attack surface and expands opportunities for service enumeration, credential attacks, and protocol-specific exploitation.

Figure B2 — Shared Hosting and DNS Infrastructure Confirmation

```

john@john: ~
Session Actions Edit View Help
niitph.com

Host's addresses:
niitph.com. 0 IN A 176.123.0.55

Name Servers:
ns3.alexhost.md. 0 IN A 176.123.0.55
ns1.alexhost.md. 0 IN A 176.123.0.20
ns2.alexhost.md. 0 IN A 176.123.0.21
ns1.alexhost.md. 0 IN AAAA 2001:678:6d4
:feed::1fae
ns2.alexhost.md. 0 IN AAAA 2001:678:6d4
:feed::1faf
ns4.alexhost.md. 0 IN A 176.123.0.60
ns1.alexhost.md. 0 IN A 176.123.0.20
ns2.alexhost.md. 0 IN A 176.123.0.21
ns1.alexhost.md. 0 IN AAAA 2001:678:6d4
:feed::1fae
ns2.alexhost.md. 0 IN AAAA 2001:678:6d4
:feed::1faf

```

Figure B2

DNS interrogation (`dig niitph.com`) confirmed that the target domain resolves to a third-party hosting provider and identified the authoritative name server infrastructure.

Observed mapping:

niitph.com → 176.123.0.55 Name servers: ns1–ns3.alexhost.md

Security Implication

Shared hosting environments introduce dependency risk because:

- infrastructure hardening is partially controlled by hosting providers
- co-hosted services may increase lateral risk
- default configurations may expose unintended services

Figure B3 — Vulnerability Scanner Results (Greenbone OpenVAS)

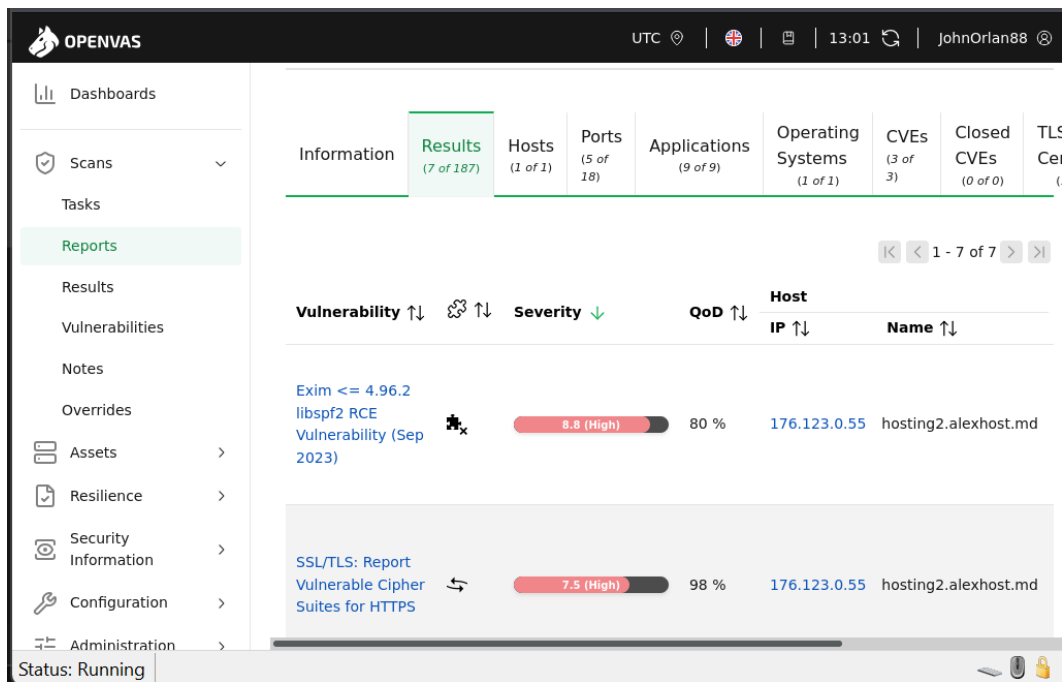
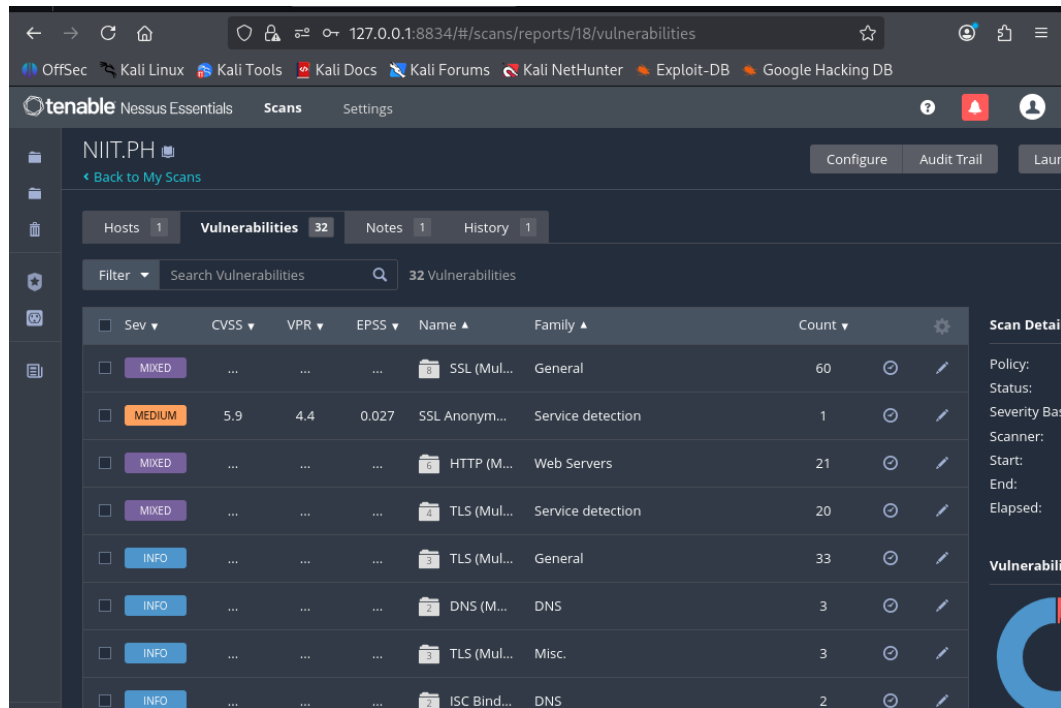


Figure B3

A credentialed vulnerability scan was performed against the target host (176.123.0.55) using **Greenbone OpenVAS (GVM)**. The scan returned **7 distinct results**, spanning mail-server, transport-layer, and authentication weaknesses.

Security Implication

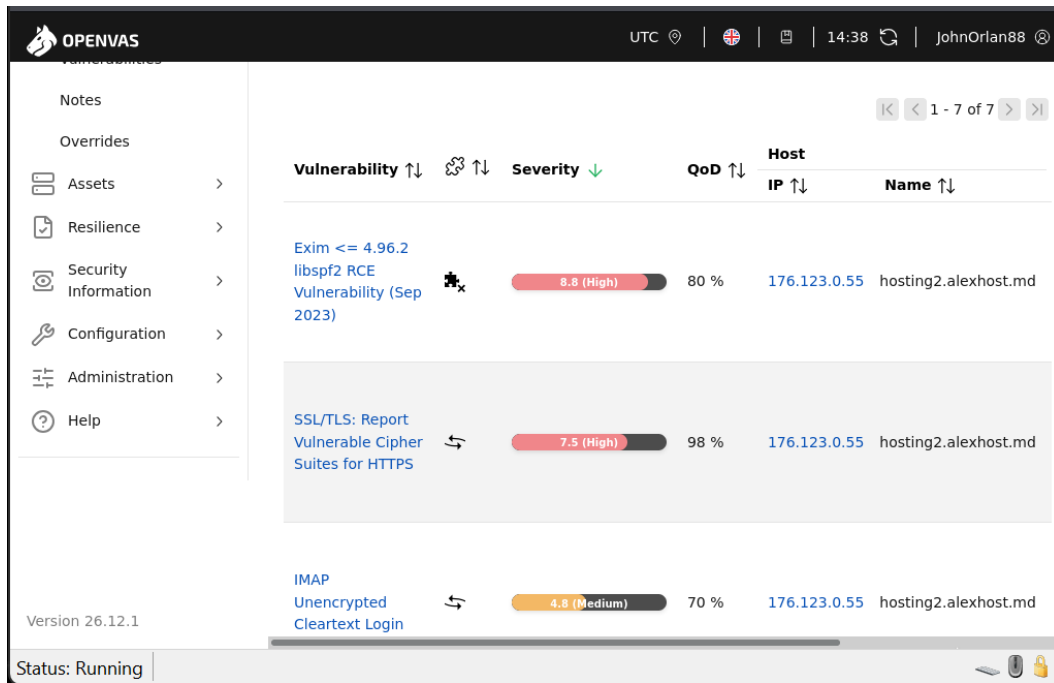
The scan results independently corroborate a cluster of high-severity findings concentrated on the mail and transport-layer services, consistent with the Validated Vulnerability Matrix in Section 6.3.

Figure B4 — Vulnerability Scanner Cross-Validation (Tenable Nessus Essentials)*Figure B4*

A parallel, independent scan of the same target was performed using **Tenable Nessus Essentials** to cross-validate the OpenVAS findings. The Nessus scan identified **32 distinct vulnerabilities** grouped across SSL, TLS, and HTTP service families.

Security Implication

Corroboration across two independent, industry-standard scanning engines (OpenVAS and Nessus) significantly increases confidence in the reported findings and rules out single-tool false positives.

Figure B5 — Exim SMTP Remote Code Execution Exposure (V-006)*Figure B5*

OpenVAS scanning identified a named, high-severity mail-server vulnerability affecting the target host.

Observed finding:

Exim <= 4.96.2 libspf2 RCE Vulnerability (Sep 2023) Severity: 80% (High) — Host: 176.123.0.55 (hosting2.alexhost.md)

Security Implication

The Exim libspf2 remote code execution vulnerability is a critical finding: unpatched Exim builds that link against a vulnerable libspf2 are exposed to remote, unauthenticated code execution during SPF record processing.

Result

A high-severity remote code execution exposure was confirmed on the mail service and should be treated as a priority remediation item (V-006).

Figure B6 — Manual Exim Banner Verification

```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help

john@john: ~/blackeagle-osint/blackeagle-pentest
Session Actions Edit View Help
< Server: Apache
< Upgrade: h2,h2c
< Connection: Upgrade
< Last-Modified: Tue, 13 Jan 2026 17:12:35 GMT
< Accept-Ranges: bytes
< Content-Length: 163
< Vary: Accept-Encoding
< Cache-Control: no-cache, no-store, must-revalidate
< Pragma: no-cache
< Expires: 0
< Content-Type: text/html
<
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaultwebpage.cgi"></head><body></body></html>
* Connection #0 to host 176.123.0.55:8080 left intact

(john@john)~/blackeagle-osint/blackeagle-pentest
$ curl http://176.123.0.55:8080
<html><head><META HTTP-EQUIV="Cache-control" CONTENT="no-cache"><META HTTP-EQUIV="refresh" CONTENT="0;URL=/cgi-sys/defaultwebpage.cgi"></head><body></body></html>

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 21
220----- Welcome to Pure-FTPd [privsep] [TLS] -----
220-You are user number 8 of 50 allowed.
220-Local time is now 15:50. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
^C

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 25
(UNKNOWN) [176.123.0.55] 25 (smtp) : Connection timed out

(john@john)~/blackeagle-osint/blackeagle-pentest
$ nc 176.123.0.55 25
220-hosting2.alexhost.md ESMTP Exim 4.99.4 #2 Tue, 30 Jun 2026 15:55:53 +0300
220-We do not authorize the use of this system to transport unsolicited,
220 and/or bulk e-mail.

```

Status: Running

Figure B6

Manual banner grabbing was performed to independently verify the scanner-reported Exim version.

Observed banner:

220-hosting2.alexhost.md ESMTP Exim 4.99.4

Security Implication

Manual verification confirms the mail service was running an Exim build consistent with the vulnerable version range identified by the automated scanners, corroborating Figure B5 through an independent, tool-agnostic method.

Figure B7 — SSL Medium Strength Cipher Suites (SWEET32) (V-001)

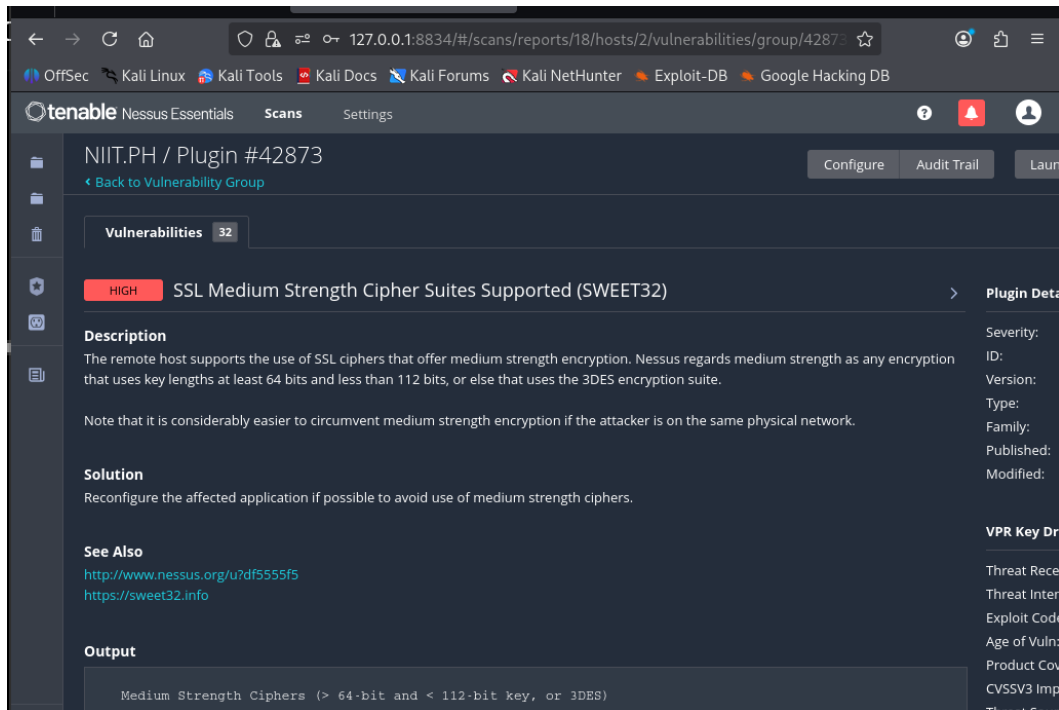


Figure B7

Nessus plugin #42873 confirmed the presence of medium-strength SSL ciphers on the target host.

Observed finding:

SSL Medium Strength Cipher Suites Supported (SWEET32) The remote host supports SSL ciphers offering medium-strength encryption (64–112 bit keys, including 3DES), which is vulnerable to the **SWEET32** birthday-attack class.

Security Implication

Medium-strength / 3DES ciphers are vulnerable to birthday-bound block-cipher collision attacks that can expose portions of encrypted traffic on long-lived HTTPS connections.

Result

Confirmed exposure to SWEET32-class cipher weaknesses (V-001).

Figure B8 — SSL Anonymous Cipher Suites Supported (V-002)

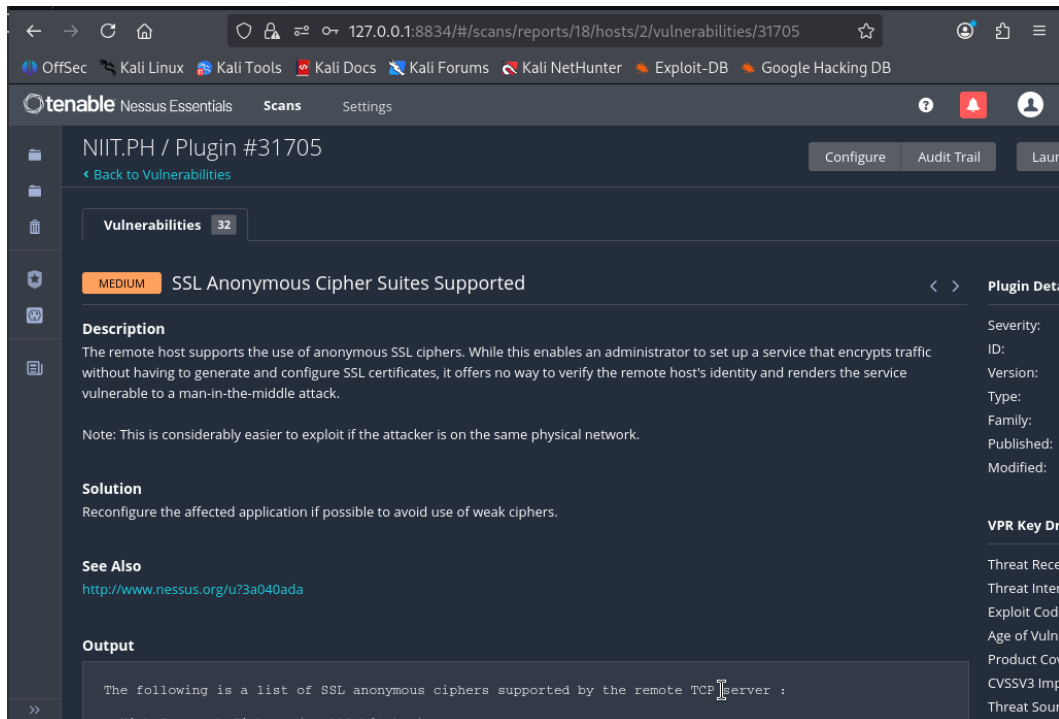


Figure B8

Nessus plugin #31705 identified support for anonymous SSL ciphers on the target host.

Observed finding:

SSL Anonymous Cipher Suites Supported The remote host supports anonymous SSL ciphers, which allow encrypted connections without verifying the remote host's identity.

Security Implication

Anonymous ciphers provide no authentication of the remote endpoint, rendering affected connections vulnerable to man-in-the-middle attacks, particularly from adversaries positioned on the same physical network.

Result

Confirmed support for anonymous, unauthenticated SSL cipher suites (V-002).

Figure B9 — Missing HTTP Strict Transport Security (HSTS) (V-003)

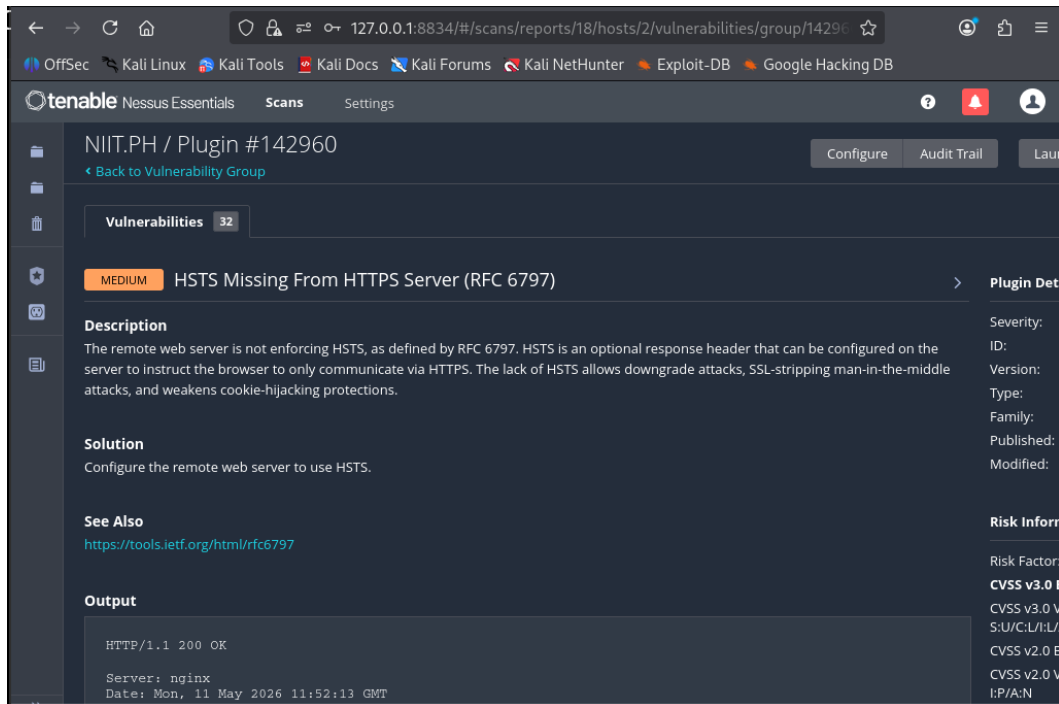


Figure B9

Nessus plugin #142960 confirmed that the web server does not enforce HTTP Strict Transport Security.

Observed finding:

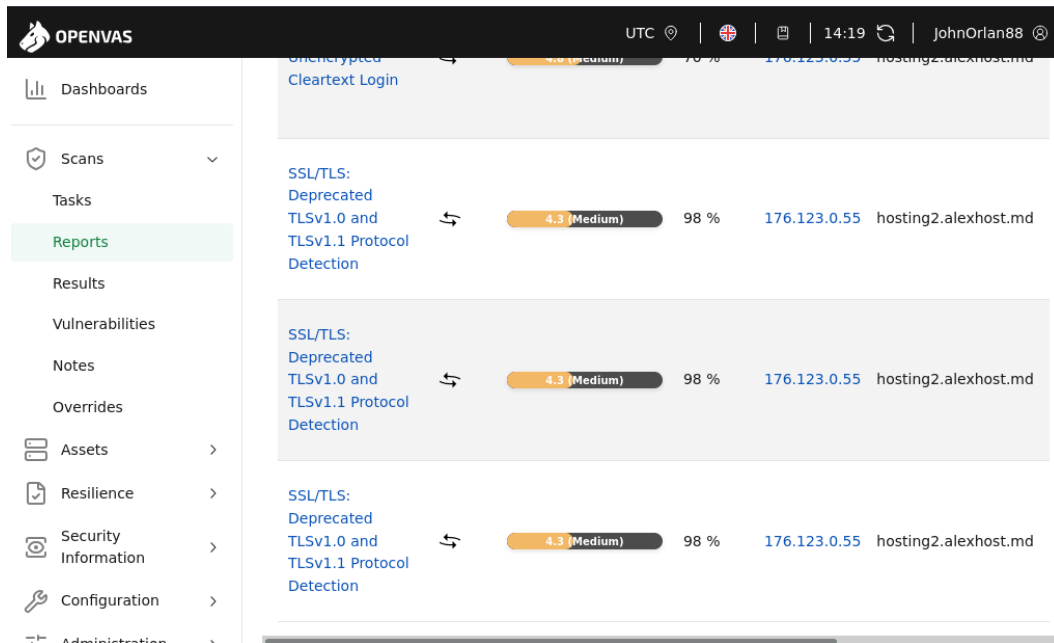
HSTS Missing From HTTPS Server (RFC 6797) The remote web server is not enforcing HSTS. The lack of HSTS allows downgrade attacks, SSL-stripping attacks, and weakens cookie-hijacking protections.

Security Implication

Without HSTS enforcement, browsers may be induced to communicate with the server over unencrypted HTTP, exposing sessions to interception and downgrade attacks even when HTTPS is available.

Result

Confirmed absence of HSTS enforcement (V-003).

Figure B10 — Deprecated TLS 1.0 / TLS 1.1 Protocol Detection (V-004, V-005)*Figure B10*

OpenVAS confirmed continued support for deprecated TLS protocol versions, independently corroborated by Nessus plugins #104743 (TLS 1.0) and #157288 (TLS 1.1).

Observed findings:

SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection Severity: 98% — Host: 176.123.0.55 (hosting2.alexhost.md)

Security Implication

TLS 1.0 and 1.1 carry known cryptographic design weaknesses and lack support for modern, recommended cipher suites, increasing susceptibility to downgrade and interception attacks.

Result

Confirmed continued support for deprecated TLS 1.0 and TLS 1.1 protocols across both scanning engines (V-004, V-005).

Figure B11 — IMAP / POP3 Unencrypted Cleartext Login Exposure (V-007, V-008)

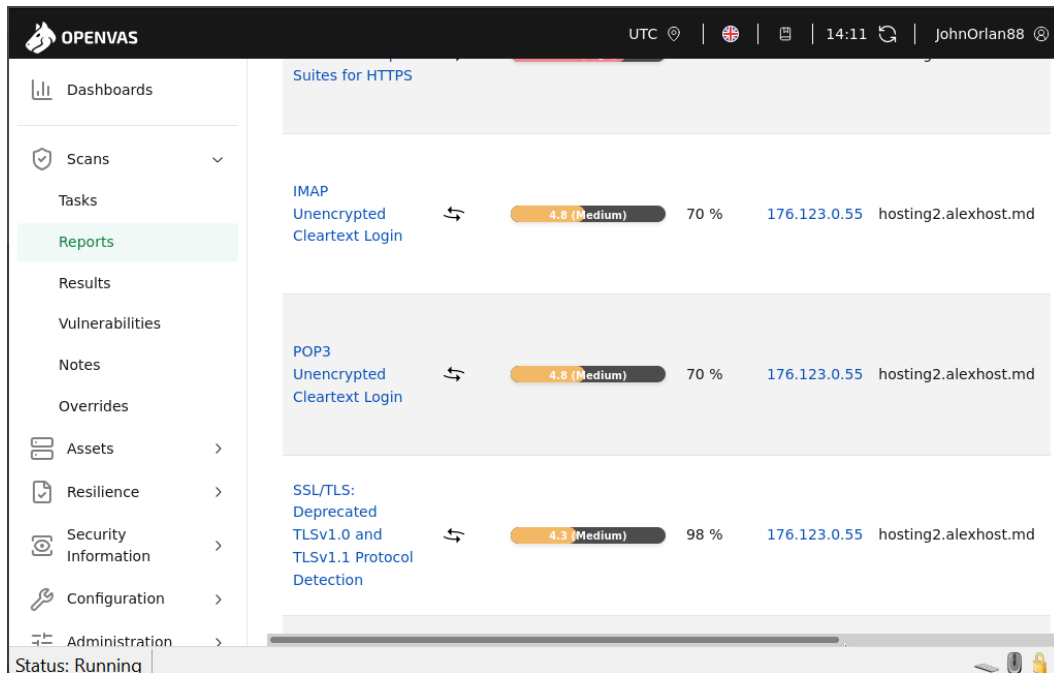


Figure B11

OpenVAS identified that both the IMAP and POP3 mail retrieval services accept unencrypted, cleartext authentication.

Observed findings:

IMAP Unencrypted Cleartext Login — Severity: 70% **POP3 Unencrypted Cleartext Login** — Severity: 70% Host: 176.123.0.55 (hosting2.alexhost.md)

Security Implication

Cleartext authentication over IMAP/POP3 allows credentials to be captured in plain text by any party capable of observing network traffic, directly enabling credential interception attacks of the kind independently demonstrated in Appendix D (Figure D4, plaintext FTP credential recovery).

Result

Confirmed cleartext authentication exposure on both IMAP and POP3 services (V-007, V-008).

Appendix B Summary

Credentialed scanning with both **Greenbone OpenVAS** and **Tenable Nessus Essentials** independently corroborated a cluster of transport-layer and authentication weaknesses affecting the target host, directly substantiating all eight entries in the Validated Vulnerability Matrix (Section 6.3). The most severe finding

was a **high-severity Exim libspf2 remote code execution exposure (Exim <= 4.96.2)**, compounded by SWEET32-vulnerable medium-strength ciphers, anonymous cipher suite support, missing HSTS enforcement, deprecated TLS 1.0/1.1 protocol support, and unencrypted cleartext IMAP/POP3 logins. Cross-validation across two independent scanning engines, plus manual banner verification, provides high confidence in these findings. The combination of a critical, named remote-code-execution vulnerability with systemic transport-layer and authentication weaknesses places the organization at **high risk** of exploitation and warrants immediate remediation, prioritizing the Exim mail service.

APPENDIX C

Penetration Testing Evidence

Figure C1 — SQL Injection Payload Injection via OWASP ZAP

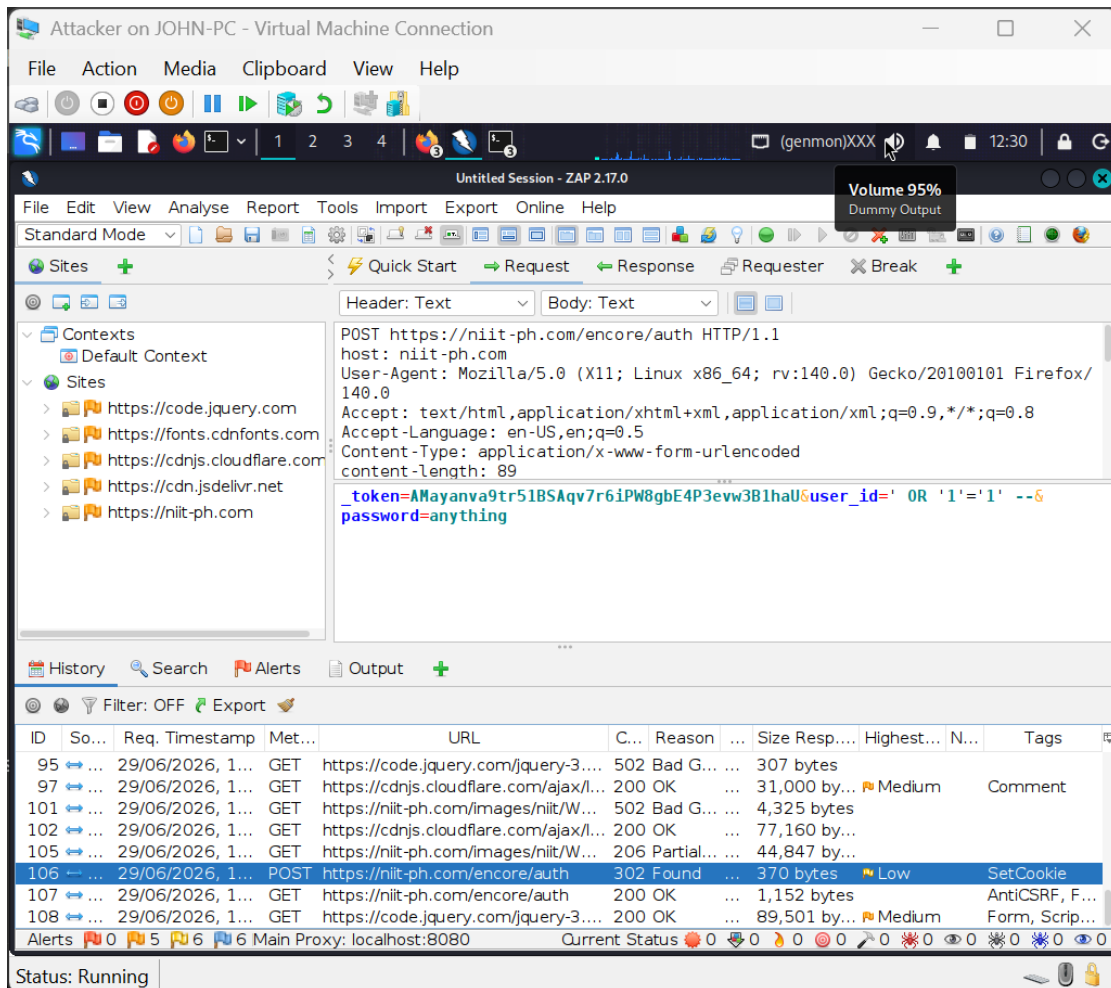


Figure C1

This figure shows a manual SQL injection attempt performed against the application authentication endpoint using OWASP ZAP to intercept and modify HTTP POST parameters.

Target endpoint:

POST /encore/auth

Injected payload:

' OR '1'='1

Modified request example:

user_id=' OR '1'='1' –&password=anything

Objective

The objective of this test was to determine whether the backend authentication logic was vulnerable to SQL injection attacks capable of bypassing credential validation.

Observation

- Request successfully intercepted and modified
- Payload delivered to server
- Application processed request without database error disclosure
- No authentication bypass achieved

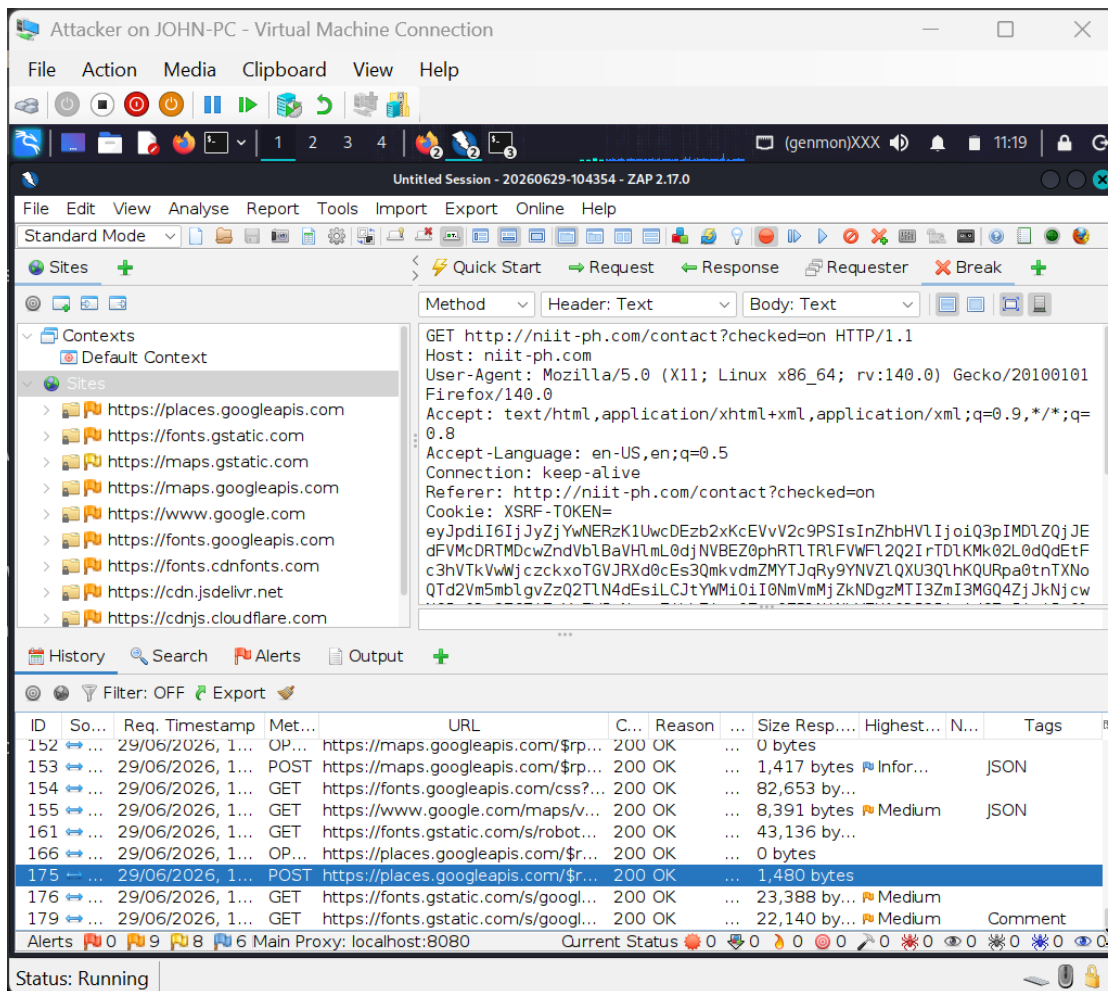
Security Interpretation

The absence of SQL error leakage suggests:

- backend input sanitization exists, or
- parameterized queries are in use, or
- framework protections mitigated payload execution

Result

SQL Injection exploitation was not successful.

Figure C2 — Cross-Site Scripting (XSS) Payload Injection**Figure C2**

This figure shows OWASP ZAP intercepting traffic generated while a deliberate XSS payload was inserted into the application's contact form to assess input validation and output encoding controls.

Payload used:

```
<script>alert(1)</script>
```

Injection point:

- Contact form message field

Objective

To determine whether the application improperly handles user-supplied HTML/JavaScript content, allowing script execution in browser contexts.

Observation

- Payload successfully submitted into input field
- Script execution was not observed
- Payload appeared filtered, sanitized, or neutralized

Security Interpretation

The observed behavior suggests:

- basic XSS filtering exists
- output encoding or sanitization likely implemented
- client-side script execution blocked

Result

No successful XSS exploitation was confirmed.

Figure C3 — Backend Request Manipulation and Authentication Testing

The screenshot displays the ZAP 2.17.0 interface. The main pane shows a POST request to `https://niit-ph.com/encore/auth` with the following headers and body:

```

POST https://niit-ph.com/encore/auth HTTP/1.1
Host: niit-ph.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded
Content-Length: 80
Origin: https://niit-ph.com
Connection: keep-alive
Referer: https://niit-ph.com/encore/auth

token=edbRWiKyzVo4ez14ydtFlg150Twwr3W89bABJXXM&user_id=User2&password=Password2
  
```

The History table at the bottom shows the following requests:

ID	So...	Req. Timestamp	Method	URL	Co...	Reason	R...	Size Res...	Highest ...	Note	Tags
228	...	30/06/2026, 0...	GET	https://niit-ph.com/login	404	Not F...	2...	6,603 by...			Comment
229	...	30/06/2026, 0...	GET	https://niit-ph.com/encore	302	Found	3...	370 bytes	Low		SetCookie
230	...	30/06/2026, 0...	GET	https://niit-ph.com/encore/auth	200	OK	2...	1,075 by...			AntiCSR...
231	...	30/06/2026, 1...	GET	https://niit-ph.com/encore/ad...	404	Not F...	1...	6,603 by...			Comment
232	...	30/06/2026, 1...	GET	https://niit-ph.com/encore/da...	504	Gate...	2...	190 bytes			
233	...	30/06/2026, 1...	GET	https://niit-ph.com/encore/da...	404	Not F...	4...	6,603 by...			Comment
234	...	30/06/2026, 1...	GET	https://niit-ph.com/api	404	Not F...	4...	6,603 by...			Comment
235	...	30/06/2026, 1...	GET	https://niit-ph.com/encore/auth	200	OK	4...	1,075 by...			AntiCSR...

The status bar at the bottom indicates "Status: Running" and "Main Proxy: localhost:8080".

Figure C3

HTTP interception via OWASP ZAP enabled direct manipulation of authentication request parameters.

Observed parameters:

`user_id=User2&password=Password2`

Modified variants included:

- invalid usernames
- invalid passwords
- administrative username attempts
- malformed credential structures

Objective

To assess:

- authentication robustness
- input validation
- parameter tampering resistance
- session handling

Observation

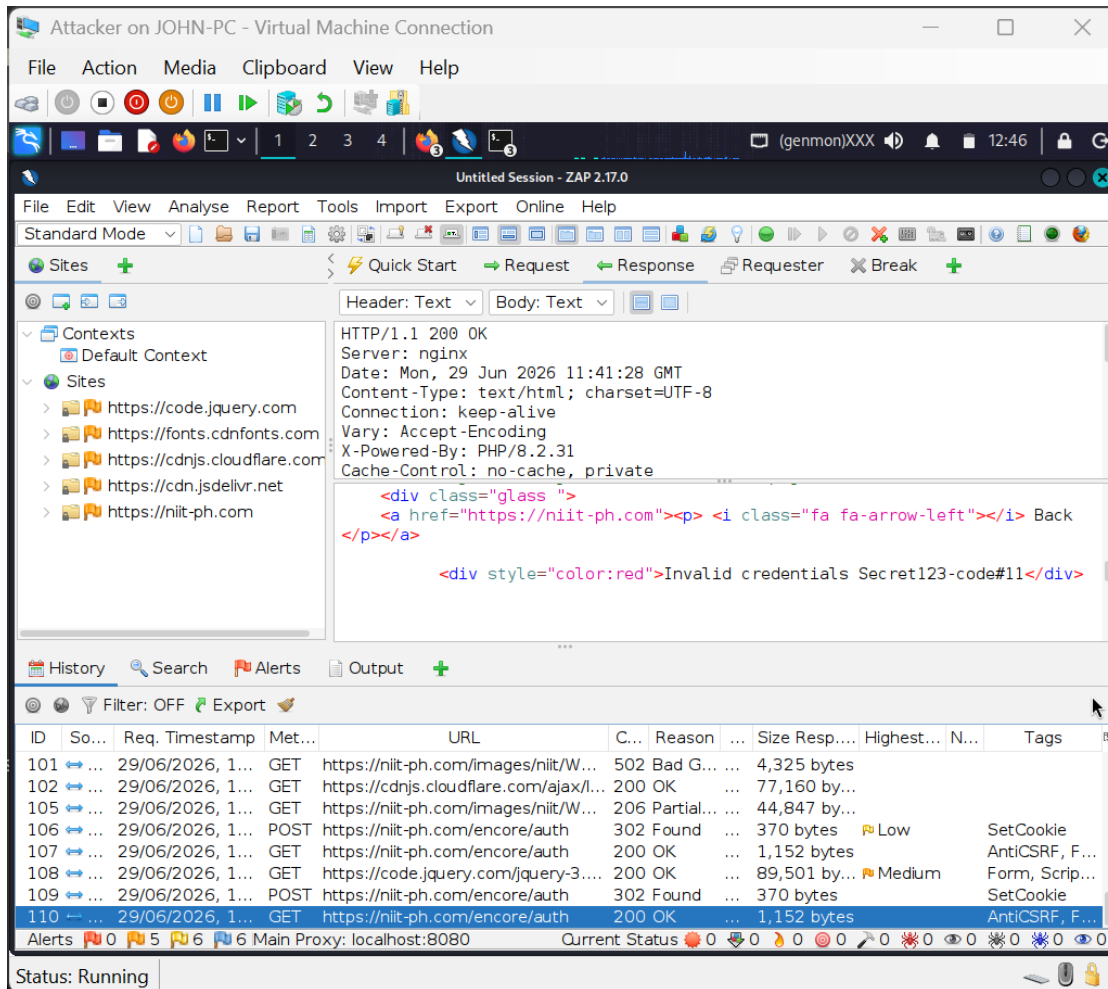
- Server returned controlled HTTP responses
- Authentication flow remained consistent
- No unauthorized access obtained
- No session bypass achieved

Security Interpretation

The authentication workflow demonstrated resilience against direct request tampering.

Result

Authentication bypass was not achieved.

Figure C4 — Error Message Disclosure During Authentication Failure**Figure C4**

During repeated authentication tests, the application returned structured credential failure messages.

Observed response:

Invalid credentials Secret123-code#11

Objective

To determine whether application error handling reveals internal application state or sensitive logic.

Observation

- Numeric suffix changed between failed attempts
- Error messages exposed internal code references
- Backend state changes became externally observable

Security Interpretation

This behavior may indicate:

- backend counters
- request identifiers
- internal error-state leakage

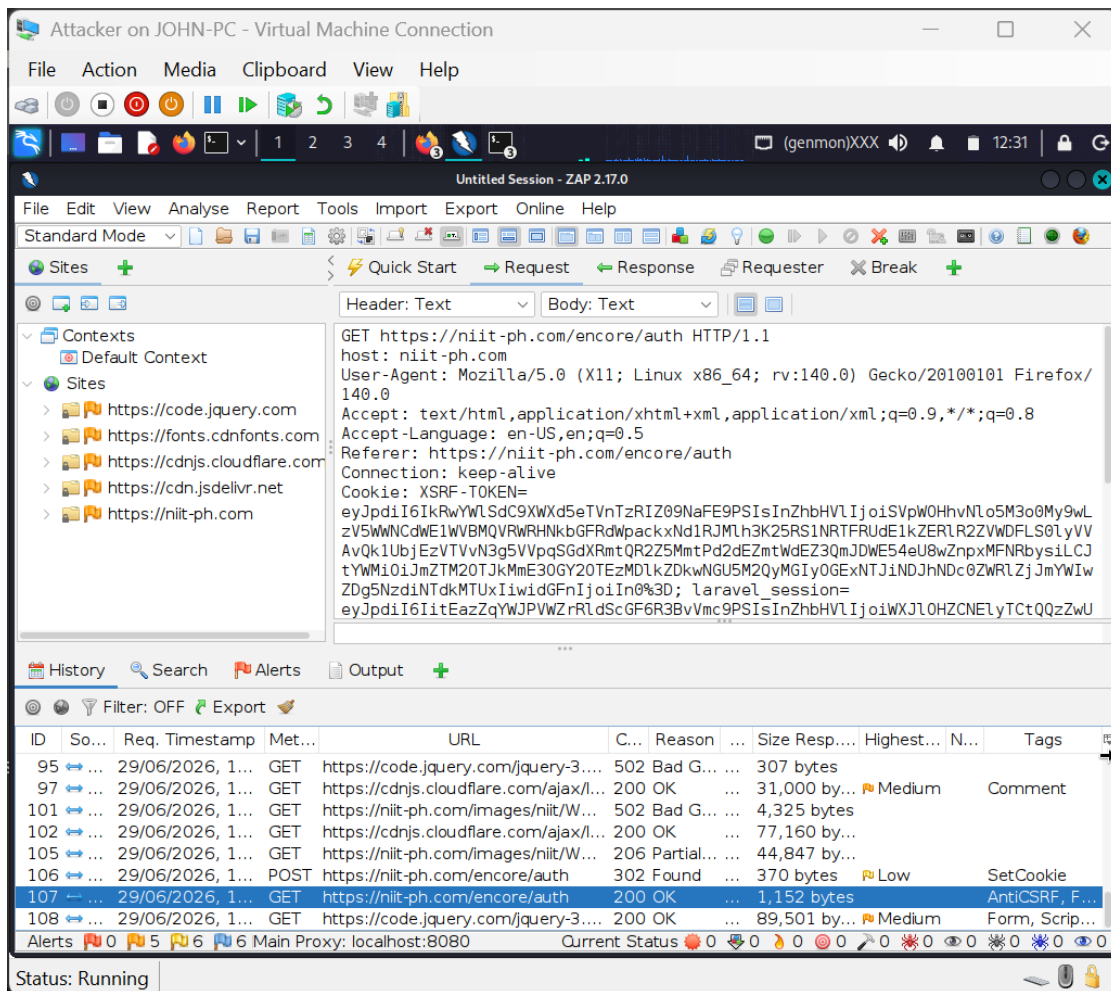
Attackers may leverage such information for:

- fuzzing
- response analysis
- credential enumeration

Result

Potential information disclosure identified.

Severity: **Medium**

Figure C5 — Authentication Redirect Flow Analysis**Figure C5**

HTTP response analysis in the ZAP History panel showed the application authentication flow using controlled redirection.

Observed flow:

POST /encore/auth → 302 Found → GET /encore/auth → 200 OK

Objective

To assess:

- session creation
- redirect logic
- login flow integrity

Observation

Authentication requests triggered:

- 1. POST submission
- 2. 302 redirect
- 3. Auth page reload (200 OK)

Security Interpretation

This indicates:

- session workflow functioning correctly
- redirect-based authentication handling
- no direct session hijack observed

Penetration Testing Summary

Authorized penetration testing focused on authentication workflows, input validation, and web application resilience against common web attacks.

Attacks Performed

- SQL Injection testing
- Cross-Site Scripting testing
- Parameter tampering
- Authentication bypass attempts
- Error handling analysis

Findings

Test	Result
SQL Injection	Failed
XSS	Failed
Auth Bypass	Failed
Parameter Tampering	Failed
Error Disclosure	Partial weakness

Overall Assessment

The application demonstrated moderate resilience against common web exploitation techniques. While no critical exploit path was successfully weaponized, minor weaknesses were observed in application error disclosure and response handling.

APPENDIX D

Malware Analysis & Network Forensics Evidence

Figure D1 — Suspicious Malware Artifact Identification

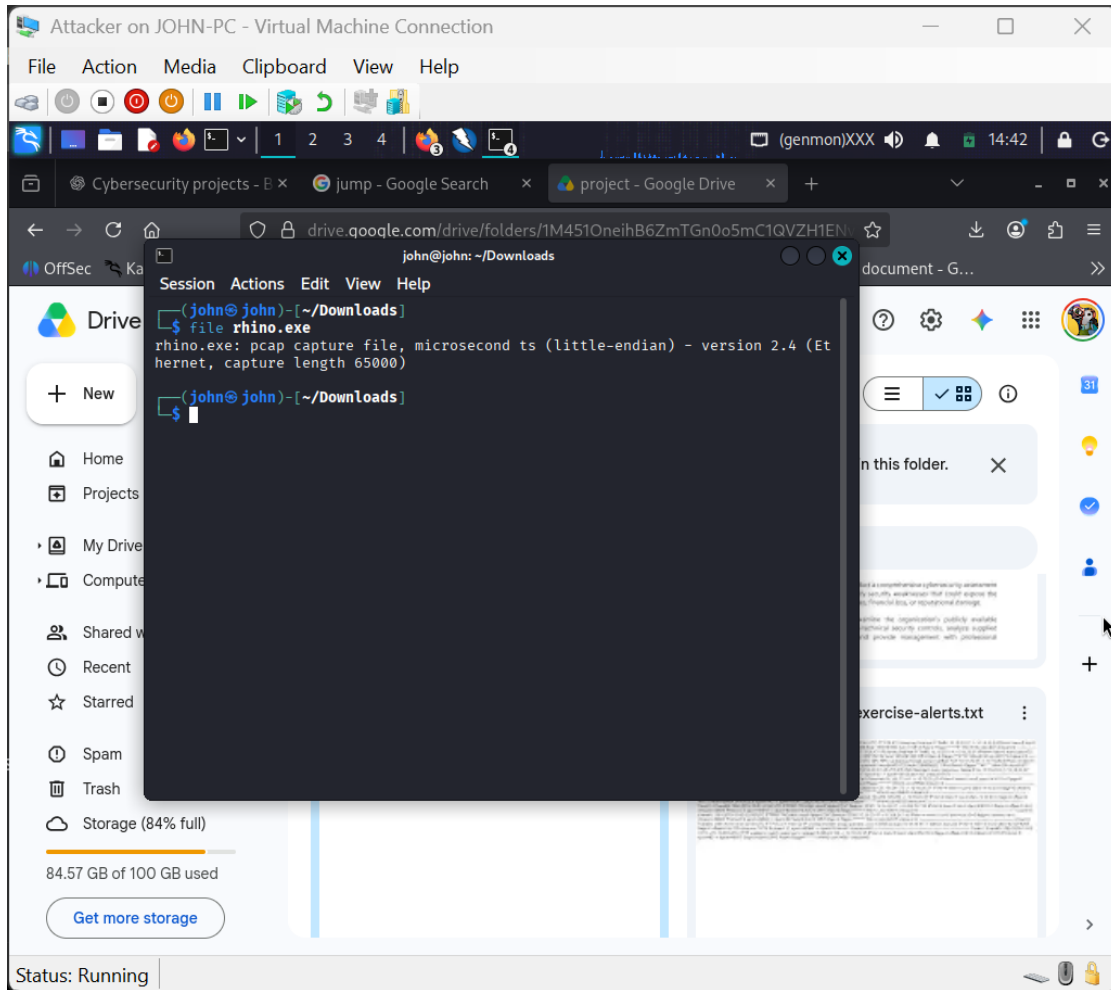


Figure D1

Initial artifact triage was performed on the suspicious file:

file rhino.exe

Observed result:

pcap capture file

Objective

To determine whether rhino.exe was an executable malware binary or another artifact type.

Observation

Although the file carried an .exe extension, forensic inspection revealed that it was not a Portable Executable (PE) binary. Instead, it was identified as a packet capture (PCAP) file containing network traffic data.

Security Interpretation

This indicates deliberate artifact masquerading or deceptive naming intended to mislead analysts or users.

Result

rhino.exe was confirmed to be a disguised PCAP file, not an executable malware sample.

Figure D2 — Packet Capture Loading and Traffic Overview

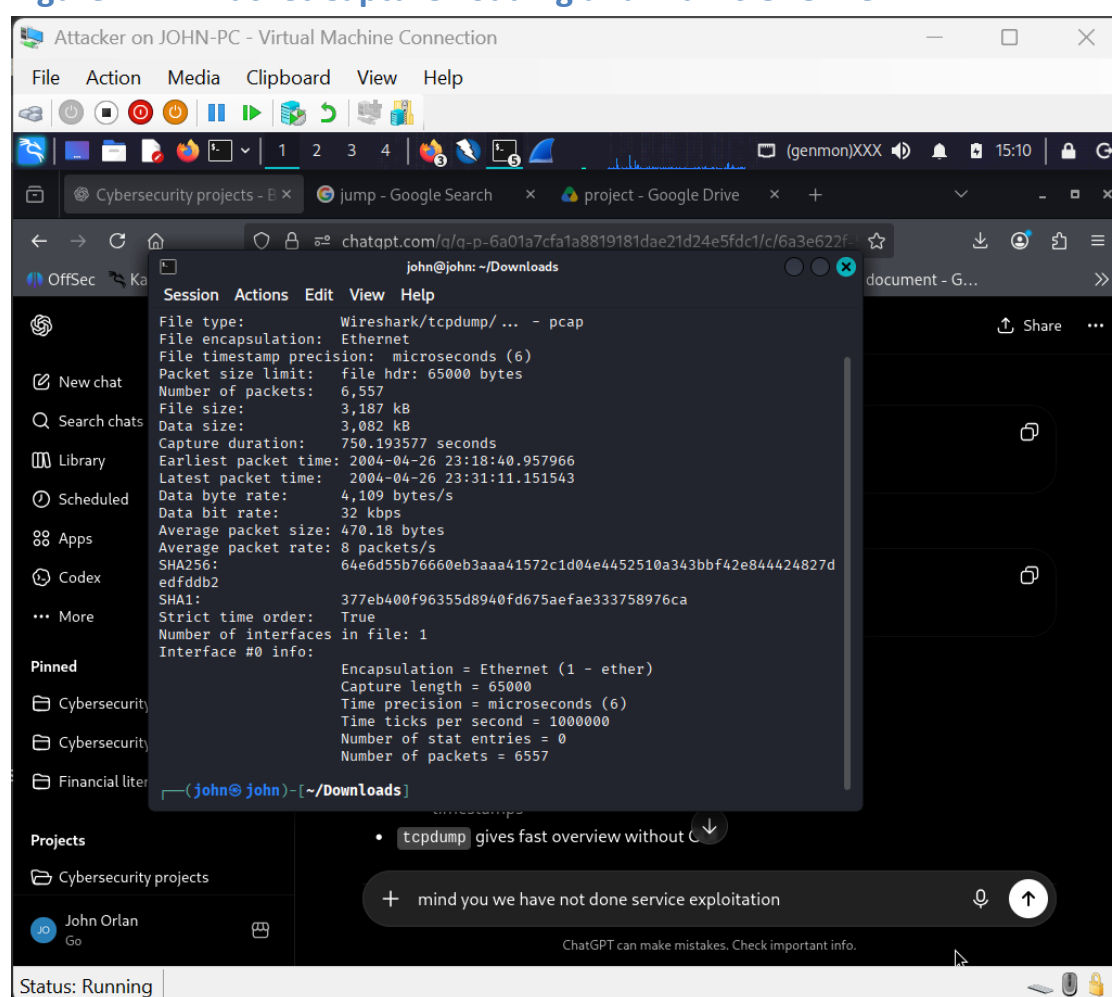


Figure D2

The PCAP was loaded into Wireshark/Tshark for network behavior analysis.

Observed characteristics:

- Packet count: 6,557
- Traffic volume: 3,187 kB
- File type: Wireshark/tcpdump pcap, Ethernet encapsulation

Objective

To establish baseline traffic characteristics and identify suspicious communication patterns.

Observation

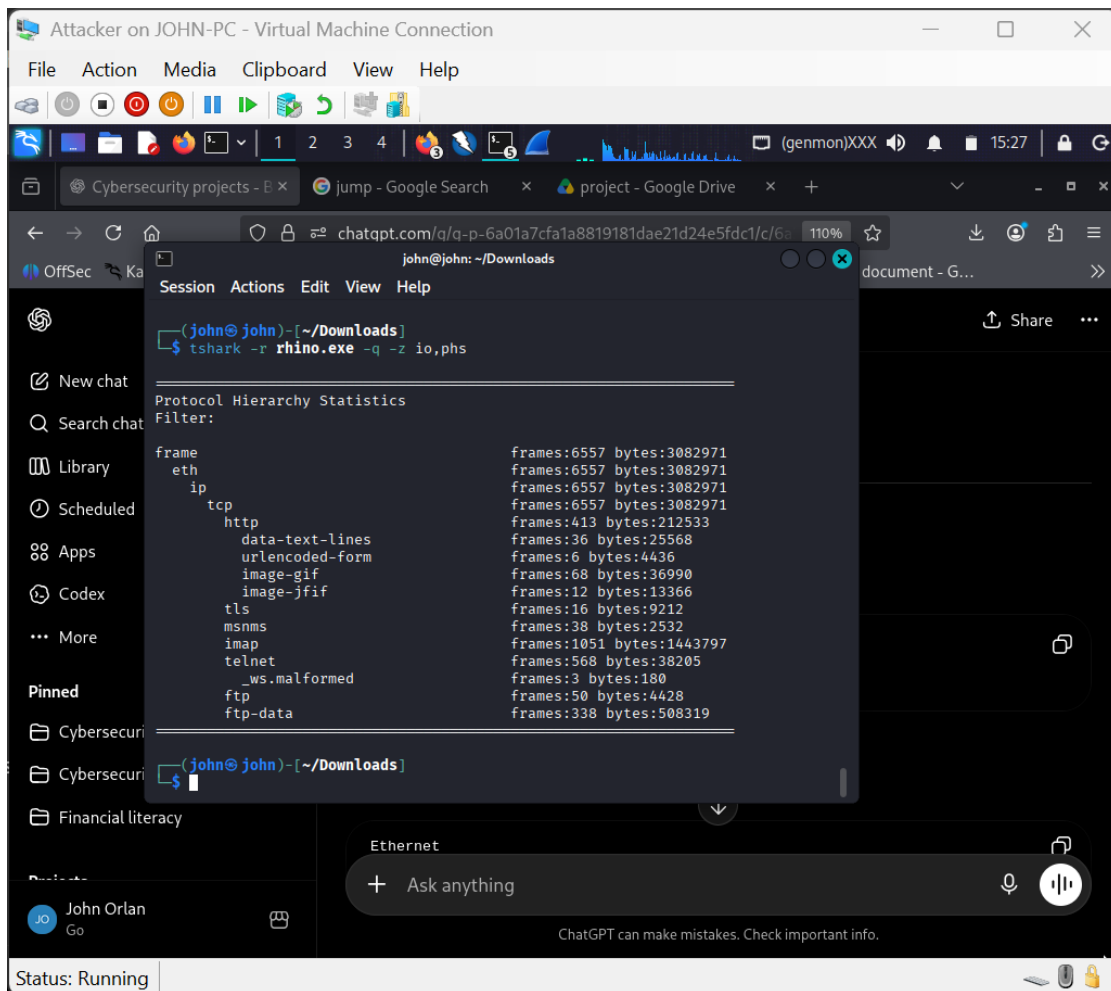
Traffic included both legitimate browsing behavior and suspicious credential-bearing communications.

Protocols observed included:

- HTTP
- FTP
- IMAP
- TCP/TLS
- Telnet

Result

Network activity contained multiple suspicious communication channels requiring deeper inspection.

Figure D3 — Protocol Hierarchy Analysis**Figure D3**

Protocol hierarchy statistics (`tshark -r rhino.exe -q -z io,phs`) revealed protocol distribution across the captured traffic.

Objective

To identify communication channels relevant to malware behavior and data movement.

Security Interpretation

The coexistence of plaintext protocols and file transfer channels increased the likelihood of credential exposure and unauthorized data movement.

Figure D4 — FTP Authentication Credential Recovery

```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help
john@john: ~/Downloads
Session Actions Edit View Help
(john@john)-[~/Downloads]
$ tshark -r rhino.exe -Y ftp.request -T fields -e frame.number -e ftp.request.command -e ftp.request.arg
1529
1532 USER gnome
1534
1536 PASS gnome123
1538
1540 TYPE I
1541
1544 PORT 137,30,122,253,6,121
1545
1546 STOR rhino1.jpg
1550
1612
1614 QUIT
1615
1616
1623
1625 USER gnome
1627
1629 PASS gnome123
1631
1647 PORT 137,30,122,253,6,124
1648
1649 STOR rhino3.jpg
1653
1737
1755 TYPE I
1756
1761 PORT 137,30,122,253,6,126
1762
1763 STOR rhino3.jpg
1767
1851
1858 QUIT
1859
1860
5624
5633 USER gnome
5635
5637 PASS gnome123
Status: Running

```

Figure D4

FTP sessions were extracted using packet inspection (`tshark -r rhino.exe -Y ftp.request`).

Recovered credentials:

USER gnome PASS gnome123

Objective

To determine whether credentials were exposed in plaintext during network communication.

Observation

Credentials were transmitted without encryption and were fully recoverable from captured traffic.

Security Interpretation

Plaintext credential exposure allows attackers performing packet sniffing to immediately compromise authenticated services.

Result

Valid FTP credentials were recovered from traffic.

Severity: **Critical**

Figure D5 — Suspicious FTP File Transfers

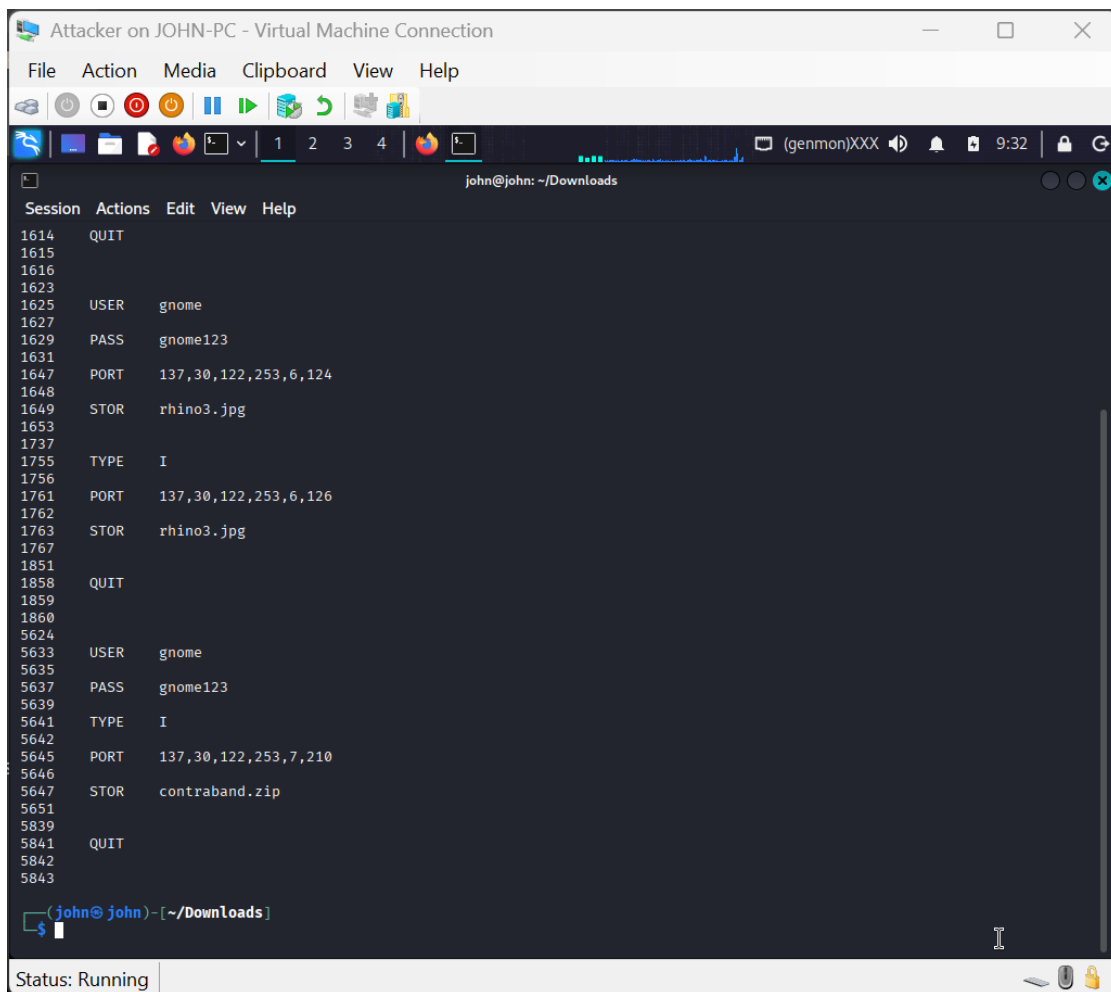


Figure D5

File transfer analysis revealed outbound uploads to the FTP server.

Transferred files included:

rhino1.jpg rhino3.jpg contraband.zip

Objective

To identify potentially malicious file movement.

Observation

Multiple files were uploaded during authenticated FTP sessions, including compressed archive data.

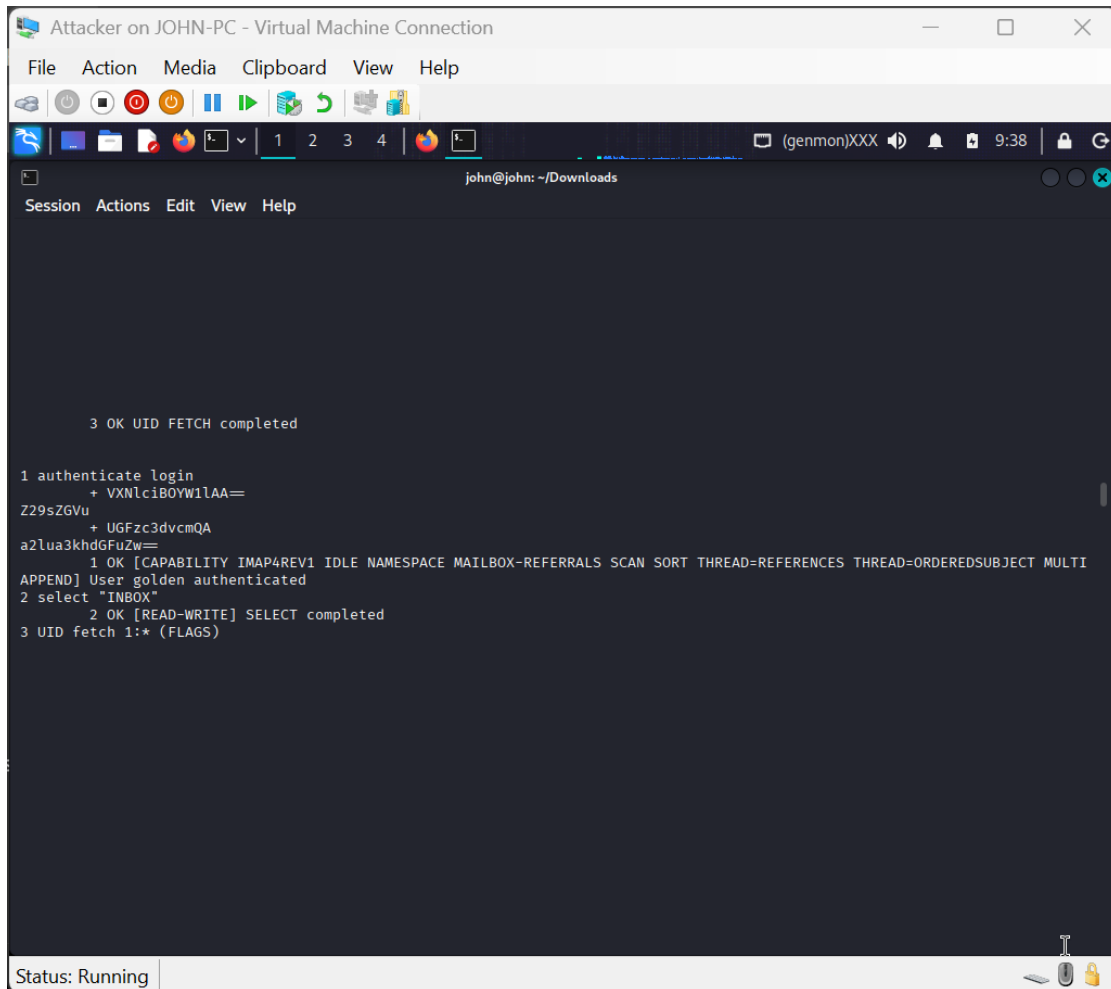
Security Interpretation

The ZIP archive was particularly suspicious because compressed archives are commonly used for:

- staging stolen data
- exfiltration
- payload delivery
- concealment

Result

Suspicious file transfer activity consistent with possible exfiltration was observed.

Figure D6 — IMAP Authentication Session*Figure D6*

IMAP traffic inspection revealed email authentication activity.

Observed mailbox user:

golden

Authentication flow:

AUTH LOGIN → User golden authenticated

Objective

To determine whether email infrastructure was accessed during the incident.

Observation

The mailbox was successfully accessed and authenticated.

Security Interpretation

Unauthorized email access may facilitate:

- credential theft
- phishing
- message harvesting
- business email compromise

Result

Email account access was confirmed.

Severity: **High**

Figure D7 — Mailbox Enumeration and Email Deletion

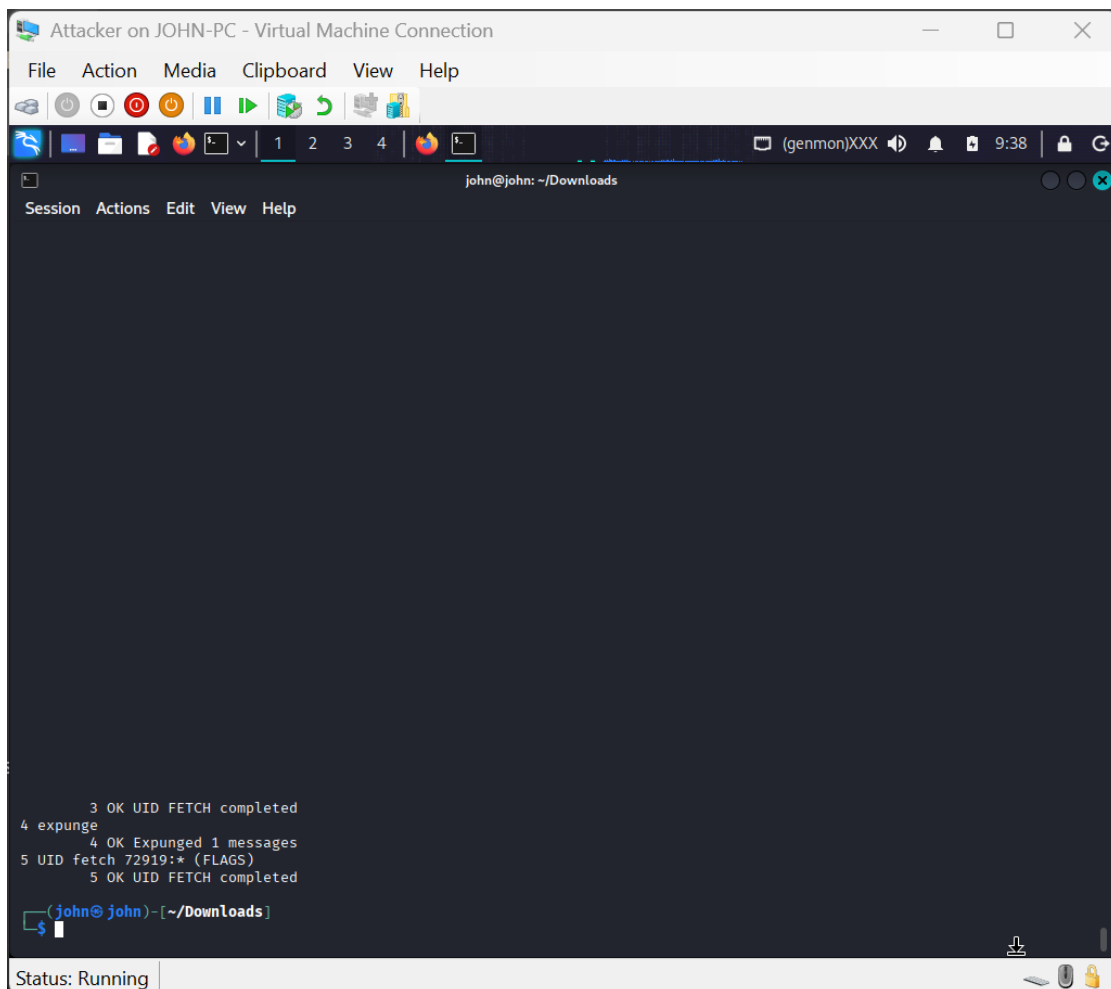


Figure D7

Further IMAP analysis revealed mailbox operations.

Observed commands:

SELECT INBOX → UID FETCH → EXPUNGE

Server response:

OK Expunged 1 messages

Objective

To determine whether mailbox contents were modified.

Observation

At least one email message was permanently removed during the session.

Security Interpretation

Message deletion may indicate:

- mailbox cleanup
- evidence removal
- anti-forensic behavior

Result

Email deletion activity was observed.

Figure D8 — HTTP Traffic Correlation

```

Attacker on JOHN-PC - Virtual Machine Connection
File Action Media Clipboard View Help
john@john: ~/Downloads
Session Actions Edit View Help

3 OK UID FETCH completed
4 expunge
4 OK Expunged 1 messages
5 UID fetch 72919:* (FLAGS)
5 OK UID FETCH completed

(john@john)~/Downloads
$ tshark -r rhino.exe -Y http.request -T fields -e http.host -e http.request.uri
www.google.com /
www.hotmail.com /
loginnet.passport.com /login.srf?id=26svc=mail&cbid=243256msppjph=16tw=06fs=16fsa=16fsat=12960006lc=10336_lang=EN
login.passport.net /uilogin.srf?id=2
login.passport.net /1033/L/PPIE.css
cb.msn.com /passport/cbhm.js.ashx?PP_SERVICE=login&PP_PAGE=pplogin&lid=1033
www.hotmail.msn.com /cgi-bin/sbox?did=16t=5LHMxSLAzDcbWqI**W0G0mTQlkz0csSyk7jxTDIdFJquWLxMGsmTekKmwWMqt7!0016VY1N9aCSeW
utL5F*BkphA$5p=5d0IPg6t5FGamSY3bkIwY007*5WW7Nse!95wrr2YLpQ6IXqW*Z9TVXUikhQgLCiiA58KxS7BogwzyCMBRCh25hWY1bXlfoohNxR2mQ*LExr
PXar*QoyPzb12LRmhd8tveGeIQusoQXYTBtdGZQHWnZ9H5xIPZPPsH0aky331748i5WvieMDocG!J6OpB0SsknH0i208Rtcx7Y$
by17fd.bay17.hotmail.msn.com /cgi-bin/hmhome?curmbox=F0000000018a=e/d2833da567c33fea303dc0c2e8e4f66fti=yes
by17fd.bay17.hotmail.msn.com /cgi-bin/dasp/EN/hotmail__9080000065.css
by17fd.bay17.hotmail.msn.com /cgi-bin/dasp/EN/helppane__9080000001F.js
by17fd.bay17.hotmail.msn.com /cgi-bin/dasp/EN/hotmail__90815000014.js
64.4.48.24 /crs_918.gif
64.4.48.24 /spacer.gif
sc.msn.com /5N/VV82S]3UE33C7URIUIE[!.jpg
h.msn.com /c.gif?RF=6PI=443646DI=74746PS=8313
rad.msn.com /ADSAdClient31.dll?GetAd?PG=HOTO45?SC=PP?HM=04544b4654584a12505655475905477679084e3757042154155a535d52460e3
14149616d?LOC=H?TF=?ID=00064000865D48DD?UC=100?PS=55043?PI=44364?AP=1255?NA=1140?NC=9523?AT=0
popup.msn.com /lbpopupframe.asp?PG=HOTP446msid=00064000865D48DD6country=US&UC=100
64.4.48.24 /tab.bg.dln.gif
64.4.48.24 /lgo_msn_118x35.gif
popup.msn.com /lbpopupad.asp?PG=HOTP446msid=00064000865D48DD6country=US&UC=100
64.4.48.24 /tab.separator.on.l.gif
64.4.48.24 /tab.slide.hm.li.gif
rad.msn.com /ADSAdClient31.dll?GetAd?PG=HOTHIA?AP=?TF=_blank
64.4.48.24 /tab.separator.on.r.gif
64.4.48.24 /tab.bg.on.gif
64.4.48.24 /tab.bg.off.gif

Status: Running

```

Figure D8

HTTP request analysis (`tshark -r rhino.exe -Y http.request`) identified web destinations contacted during the captured session.

Objective

To correlate web activity with email and FTP findings.

Security Interpretation

HTTP activity aligned with:

- browser-based email access
- user authentication
- communication workflow reconstruction

Malware Analysis & Network Forensics Summary

Network forensic analysis revealed strong indicators of suspicious activity involving credential exposure, unauthorized file transfers, and email access.

Key Findings

Finding	Severity
Disguised artifact (rhino.exe)	Medium
Plaintext FTP credentials	Critical
Suspicious archive transfer	Critical
Email compromise	High
Message deletion activity	High

Overall Assessment

Although no standalone malware executable was recovered, behavioral analysis of network traffic revealed activity consistent with credential compromise, suspicious file movement, and possible anti-forensic actions. The combined evidence suggests a high-probability security incident involving unauthorized access and data movement.

APPENDIX E

Digital Forensics Evidence (USB Media Analysis)

Figure E1 — Disk Image Identification and Validation

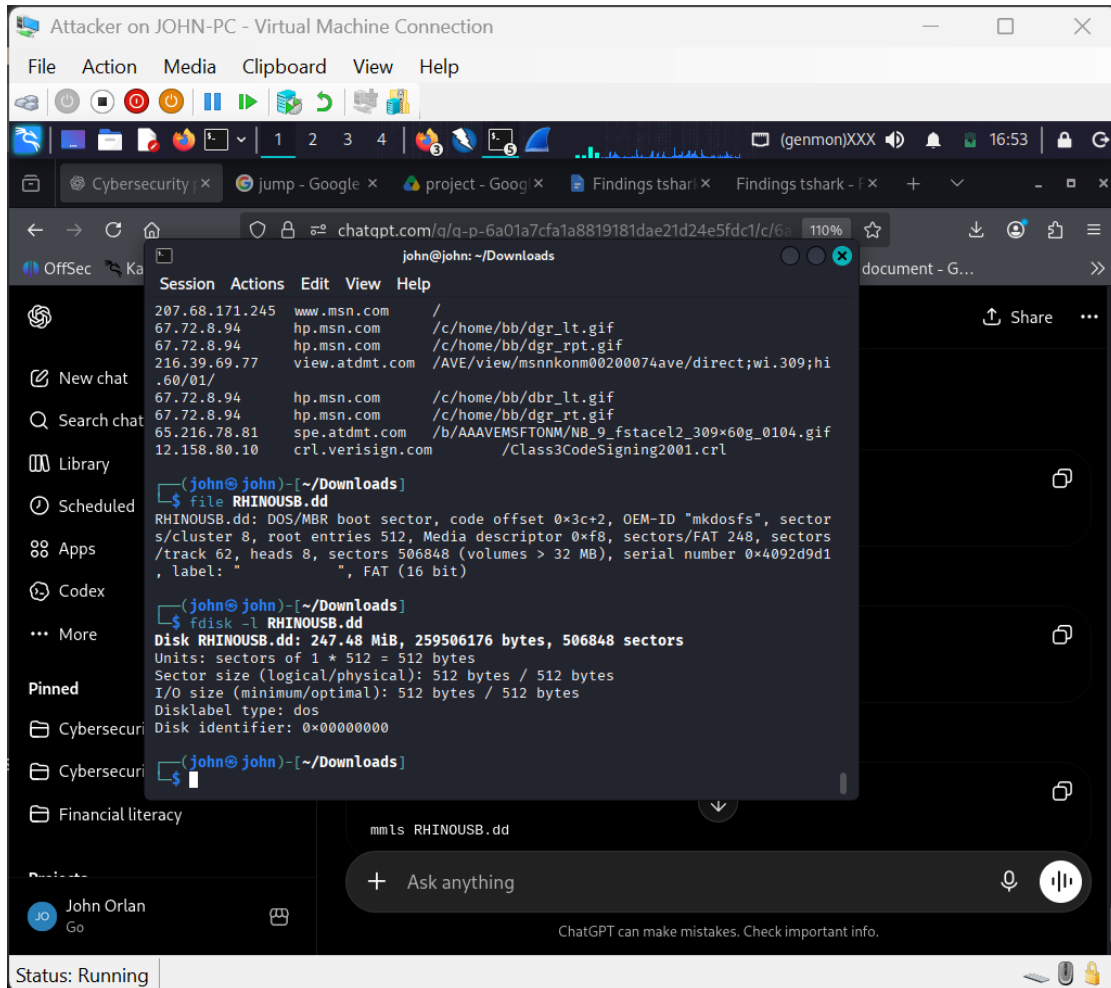


Figure E1

Initial forensic validation was performed on the acquired disk image artifact:

file RHINOUSB.dd

Observed result:

DOS/MBR boot sector

Objective

To determine the type and structure of the supplied storage artifact.

Observation

The evidence file RHINOUSB.dd was confirmed to be a raw disk image representing removable storage media containing a DOS/MBR partition structure.

Security Interpretation

Validation of disk format ensures that subsequent forensic analysis is performed against a legitimate storage image rather than a corrupted or malformed artifact.

Result

The evidence artifact was confirmed to be a valid disk image.

Figure E2 — Disk Metadata and Partition Analysis

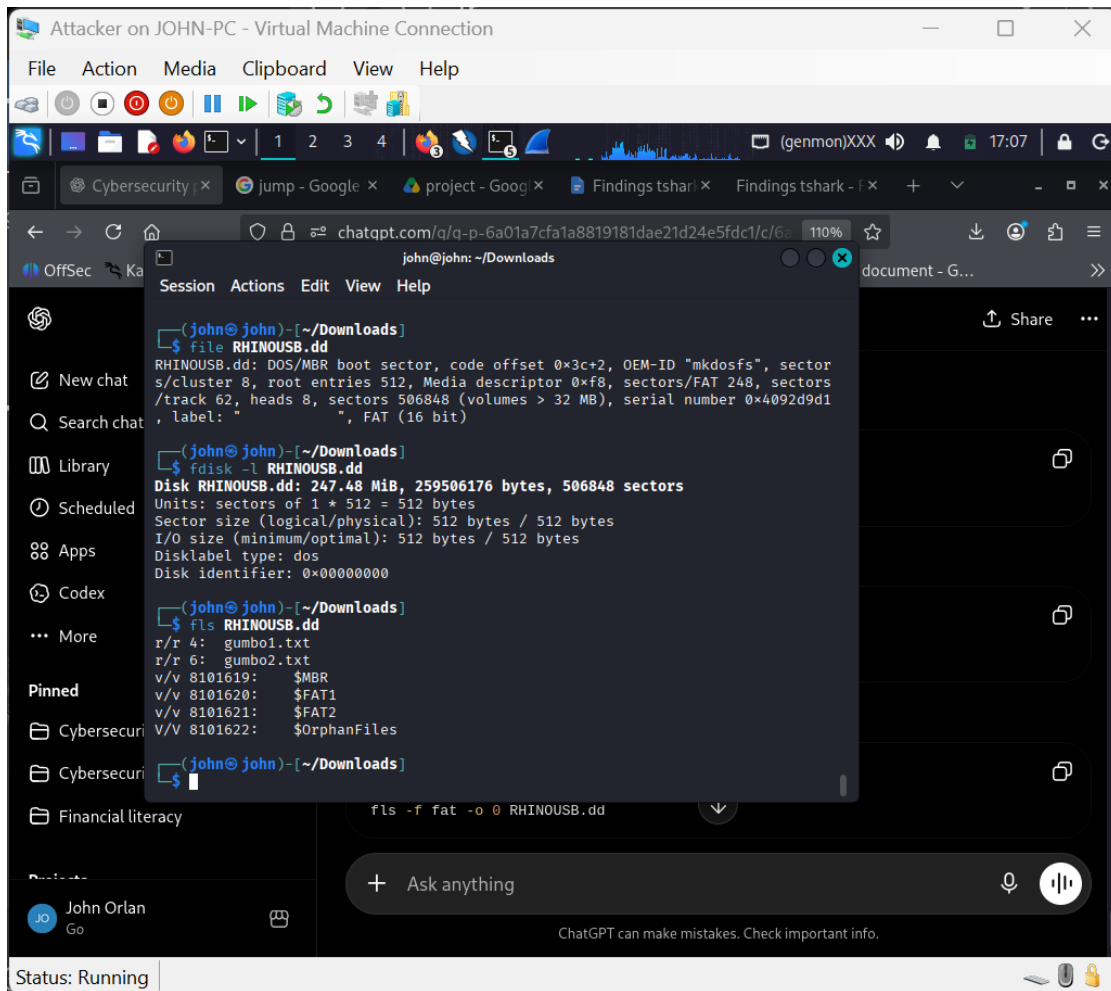


Figure E2

Partition metadata was extracted using:

```
fdisk -l RHINOUSB.dd
```

Observed metadata:

Attribute	Value
Disk Size	~247 MB
Sector Size	512 bytes
Partition Style	DOS / MBR
Filesystem	FAT16

Objective

To identify filesystem structure and partition layout.

Observation

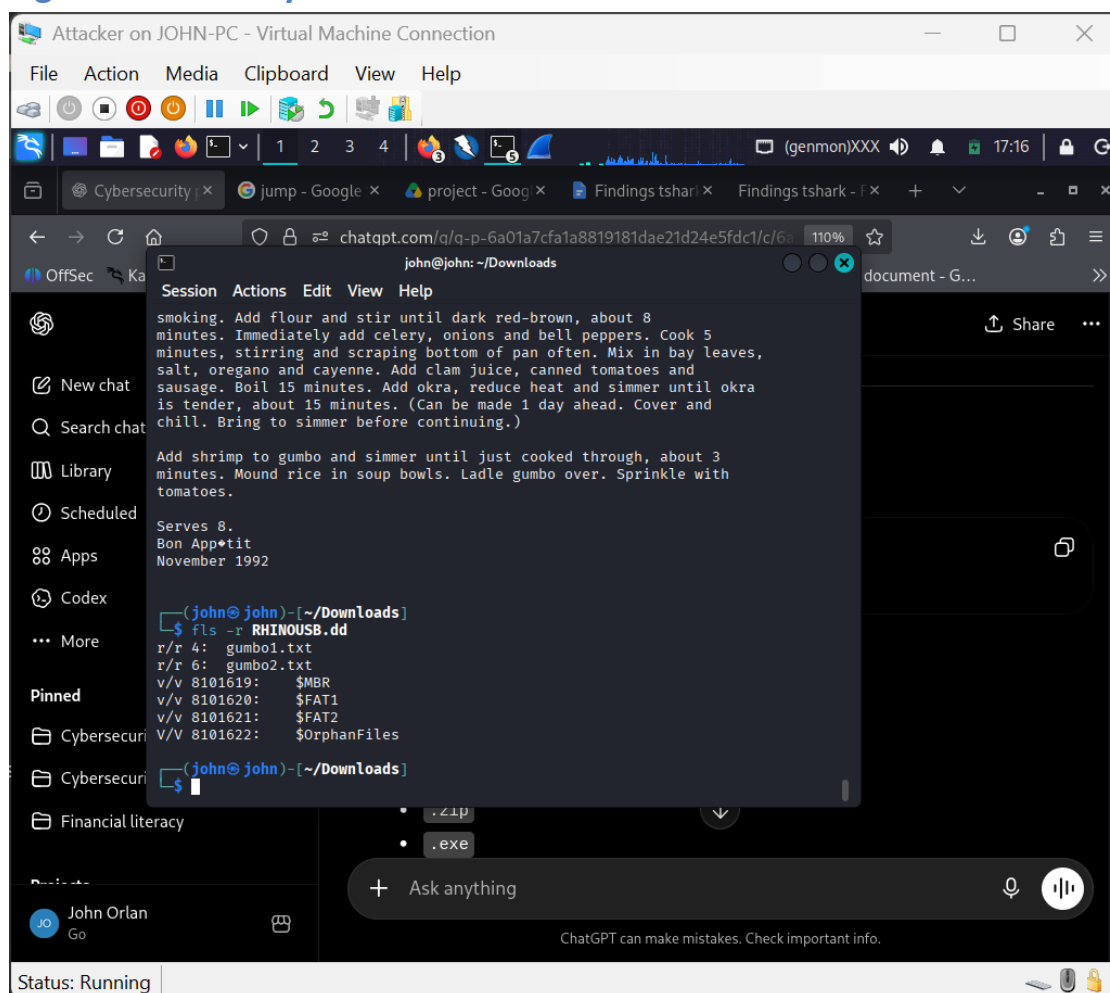
The image contained a FAT16-formatted partition commonly used in removable USB devices.

Security Interpretation

FAT-based filesystems frequently preserve recoverable deleted metadata, making them useful for forensic artifact recovery.

Result

Disk structure successfully mapped.

Figure E3 — File System Enumeration**Figure E3**

Filesystem enumeration was performed using Sleuth Kit.

Command:

```
fls -r RHINOUSB.dd
```

Recovered entries included:

```
gumbo1.txt, gumbo2.txt, $MBR, $FAT1, $FAT2, $OrphanFiles
```

Objective

To enumerate active and system-level filesystem artifacts.

Observation

The image contained both user files and filesystem metadata structures required for low-level forensic analysis.

Security Interpretation

Enumeration helps identify recoverable user content and determine whether hidden or deleted artifacts exist.

Result

Filesystem artifacts successfully enumerated.

Figure E4 — Artifact Recovery from File Inodes

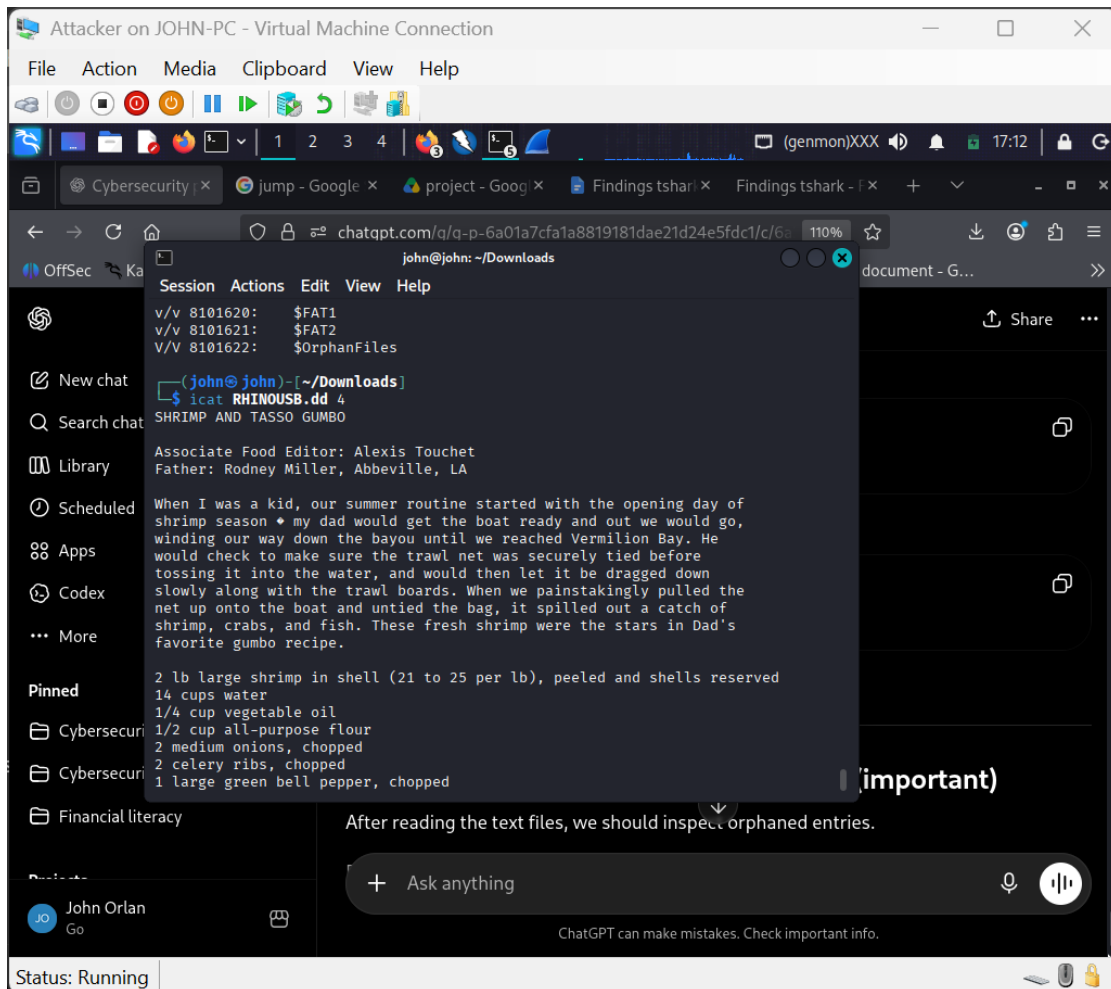


Figure E4

Artifact extraction was performed using inode recovery.

Command:

```
icat RHINOUSB.dd 4
```

Recovered artifact:

```
gumbo1.txt
```

Objective

To recover contents of individual filesystem entries.

Observation

Recovered content consisted of readable plaintext user data (a recipe document).

Security Interpretation

Recovered text files can reveal user activity, stored instructions, or hidden operational notes.

Result

Recovered file contents successfully extracted.

Figure E5 — Secondary Artifact Recovery

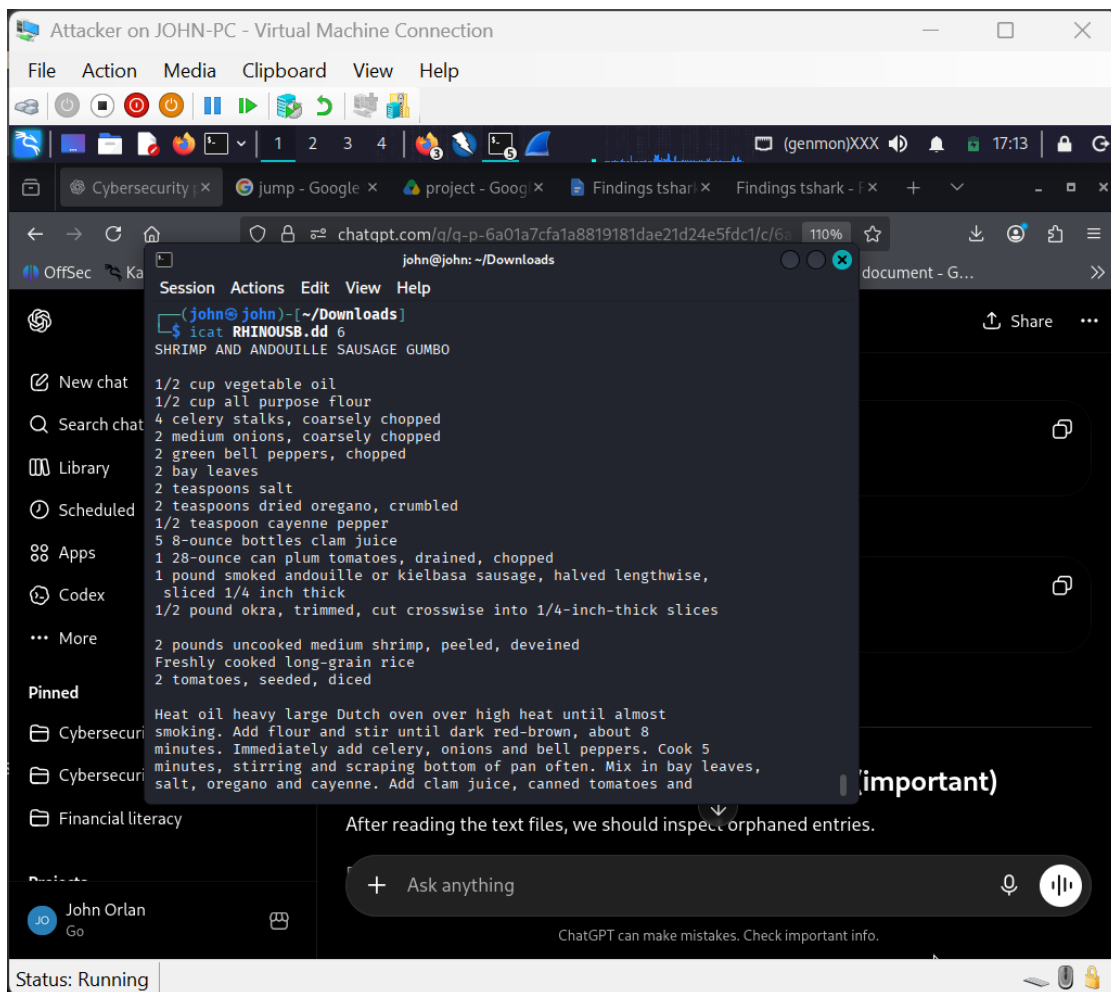


Figure E5

Further extraction recovered an additional text artifact.

Command:

```
icat RHINOUSB.dd 6
```

Recovered artifact:

```
gumbo2.txt
```

Observation

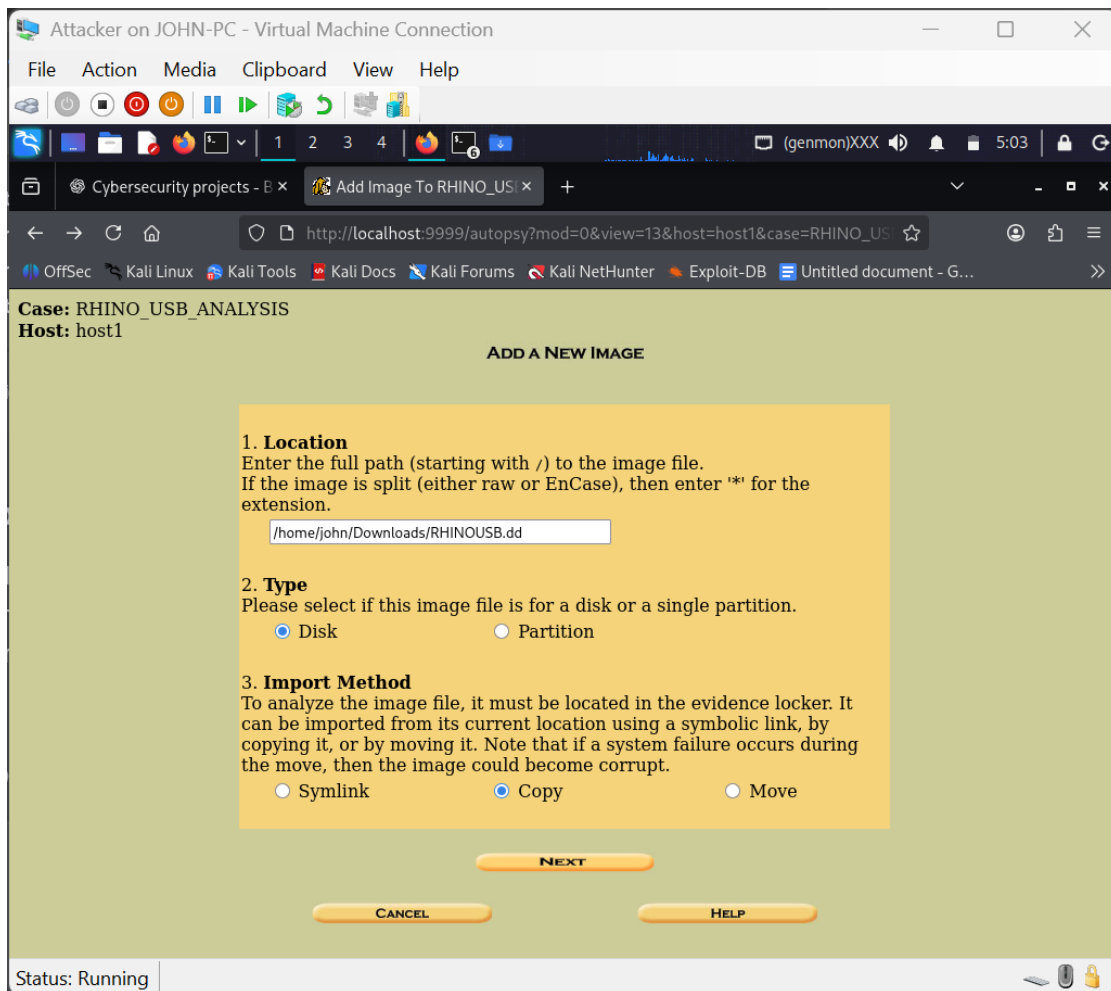
The file contained benign textual content relating to recipe instructions.

Security Interpretation

No direct malicious code or executable payload was identified within active filesystem artifacts.

Result

Recovered artifact appeared benign.

Figure E6 — Autopsy Case Creation and Evidence Loading*Figure E6*

Graphical forensic validation was performed using Autopsy.

Case created:

RHINO_USB_ANALYSIS

Objective

To validate command-line findings using graphical forensic tooling.

Observation

The disk image was successfully loaded into Autopsy for structured examination.

Security Interpretation

Using multiple forensic tools improves evidence reliability through cross-validation.

Result

Disk image successfully loaded into Autopsy.

Figure E7 — Volume Detection and Filesystem Verification

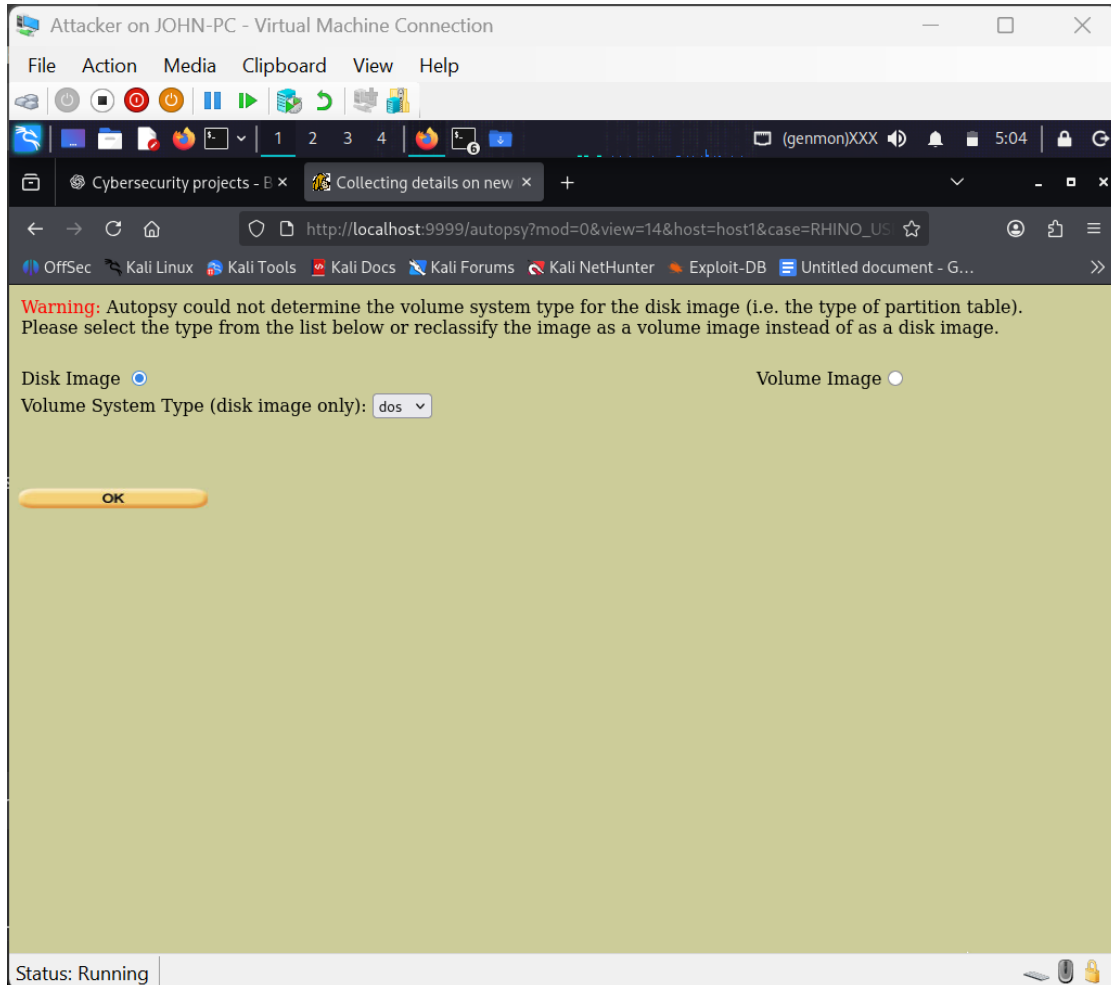


Figure E7

Autopsy image-addition workflow required manual confirmation of volume and filesystem details before analysis could proceed.

Objective

To ensure proper partition parsing.

Observation

Manual volume selection successfully enabled filesystem interpretation.

Security Interpretation

Manual verification reduced the risk of misinterpreting partition structures during automated analysis.

Result

Filesystem parsing successfully corrected.

Figure E8 — Carved File Recovery

Name	S	C	O	Modified Time	Change Time	Access Time
f0000000.txt			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0103512.jpg			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0103704.jpg			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0104520.jpg			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0105328.jpg			1	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0105848.jpg			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0105864.jpg			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0106320.gif			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00
f0106344.gif			0	0000-00-00 00:00:00	0000-00-00 00:00:00	0000-00-00 00:00:00

Figure E8

Autopsy's \$CarvedFiles module was used to recover unallocated data structures that could not be tied to an active filesystem entry.

Objective

To recover deleted or fragmented content from unallocated disk space that would not appear in a standard filesystem listing.

Observation

Carving recovered a mixed set of artifacts, including numerous .txt fragments and several .jpg / .gif image files, all timestamped 0000-00-00 — consistent with carved data lacking original filesystem metadata (i.e., recovered purely from unallocated space rather than an intact directory entry).

Security Interpretation

The presence of recoverable carved data confirms that deleted content remained physically present on the media and was not securely wiped, increasing the risk of sensitive data recovery by unauthorized parties.

Result

Recoverable carved artifacts identified.

Figure E9 — Recovered Image Artifact

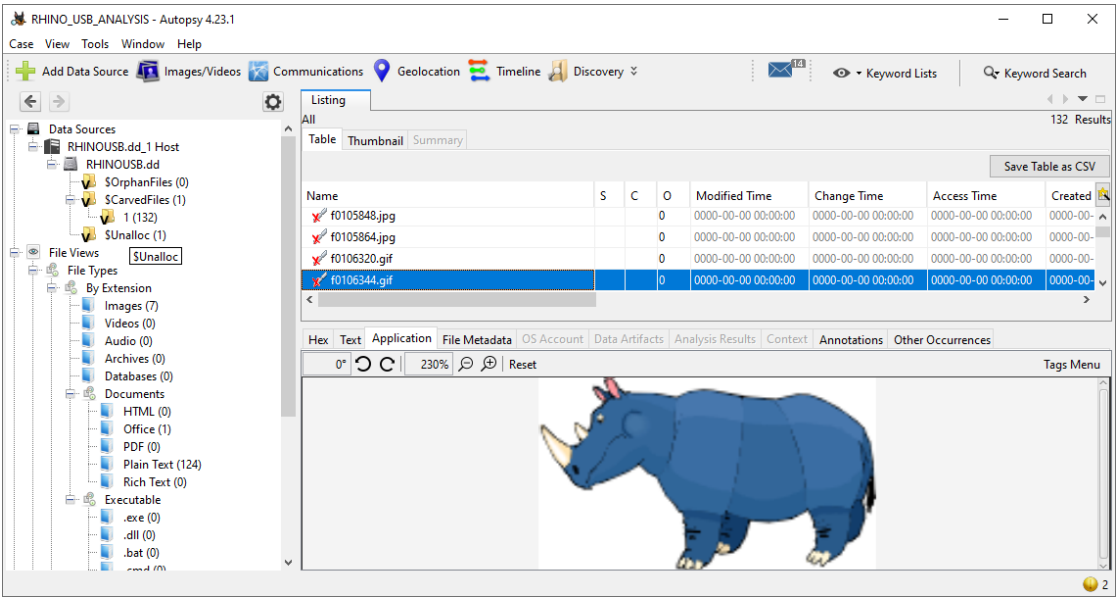


Figure E9

Carved image files were isolated under Autopsy’s Images category for individual review.

Objective

To determine whether recovered image artifacts contained sensitive, suspicious, or evidentiary content.

Observation

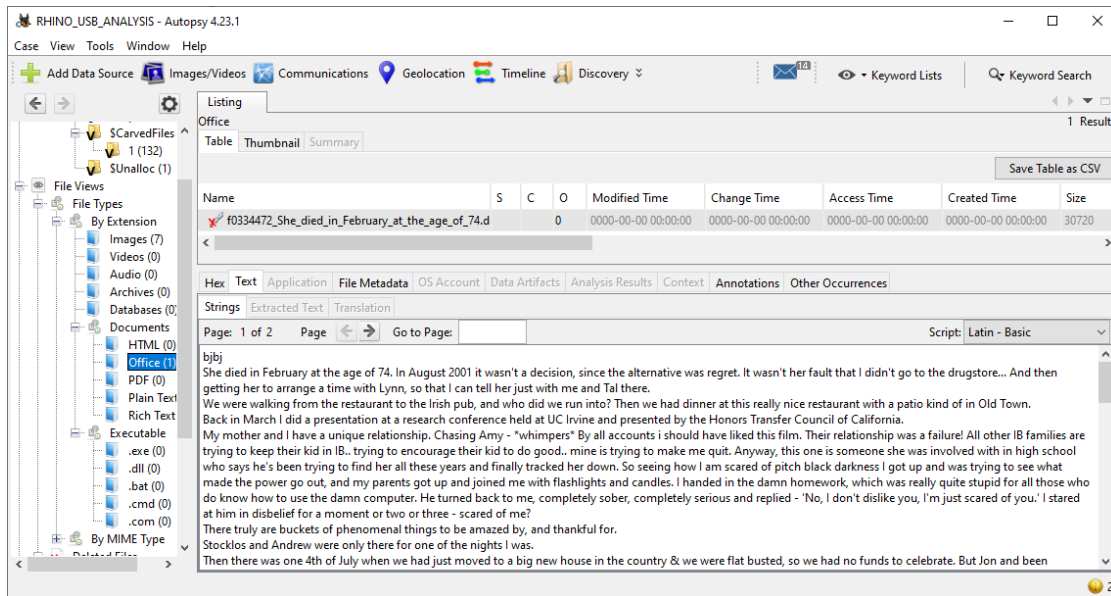
Multiple .jpg and .gif image fragments were recovered from unallocated space, each lacking valid filesystem timestamps — consistent with file-carved (rather than actively indexed) recovery.

Security Interpretation

Recoverable image artifacts confirm that previously deleted visual content remained forensically retrievable, reinforcing the storage sanitization concerns raised elsewhere in this report.

Result

Image artifacts recovered successfully.

Figure E10 — Recovered Document Fragment*Figure E10*

A carved plain-text fragment was reviewed in Autopsy's content viewer pane, showing narrative, diary-like personal content recovered from unallocated disk space.

Objective

To assess whether recovered document fragments contained personal, sensitive, or evidentiary information.

Observation

The recovered fragment contained coherent personal narrative text carved from unallocated space, with no associated filename or metadata recovered alongside it — indicating the original file had been deleted and partially overwritten, leaving only a content fragment recoverable.

Security Interpretation

Recovery of personal narrative content demonstrates that meaningful, potentially sensitive information can persist and be reconstructed from deleted data long after deletion, underscoring the need for secure deletion procedures on removable media.

Result

Partial document artifacts recovered, containing sensitive personal content.

Digital Forensics Summary

Digital forensic analysis of the USB disk image (RHINOUSB.dd) revealed a valid FAT16 filesystem containing both active and recoverable artifacts.

Key Findings

Finding	Assessment
Valid disk image	Confirmed
FAT16 filesystem	Confirmed
Text artifacts recovered	Confirmed
Image artifacts recovered	Confirmed
Malware executable recovered	Not confirmed

Overall Assessment

The forensic investigation recovered multiple artifacts from the USB media, including text and image data. While no executable malware payload was recovered from the storage image, the recovered artifacts provided valuable contextual evidence supporting broader incident analysis.